



*Asociación Profesional de Cuerpos Superiores
de Sistemas y Tecnologías de la Información
de las Administraciones Públicas.*

Temario para la preparación de la Oposición al Cuerpo Superior de
Sistemas y Tecnologías de la Información de la Administración del
Estado.

TEMAS ESPECÍFICOS – BLOQUE B

I. ORGANIZACIÓN Y GESTIÓN DE LOS SISTEMAS DE INFORMACIÓN

**Tema 48. Seguridad de sistemas (2). El Esquema Nacional de
Seguridad. Adecuación al Esquema Nacional de Seguridad.
Estrategia Nacional de Seguridad. CCN-STIC**

AUTOR: Miguel A. Amutio Gómez

REVISOR: María Teresa Avelino Carmona

Creación: septiembre 2022

ÍNDICE

1. LA CIBERSEGURIDAD EN LA SEGURIDAD NACIONAL	4
1.1. El Sistema de Seguridad Nacional.....	4
1.2. Consejo Nacional de Ciberseguridad	6
1.3. La Estrategia de Seguridad Nacional	7
1.4. La Estrategia Nacional de Ciberseguridad.....	10
1.5. La protección de infraestructuras críticas	11
1.6. La seguridad de las redes y sistemas de información.....	15
2. EL ESQUEMA NACIONAL DE SEGURIDAD	19
2.1. La seguridad para la administración digital.....	19
2.2. El Esquema Nacional de Seguridad	21
2.3. Objetivos del ENS	25
2.4. Estructura y contenido del ENS.....	26
2.5. Ámbito de aplicación del ENS.....	26
2.6. Los principios básicos	28
2.7. La política de seguridad	28
2.8. Los requisitos mínimos.....	29
2.9. El mecanismo para el cumplimiento de los requisitos mínimos y la categorización de los sistemas de información	31
2.10. Las medidas de seguridad	33
2.11. El uso de infraestructuras y servicios comunes	39
2.12. Los perfiles de cumplimiento específicos	39
2.13. La respuesta a incidentes de seguridad	40
2.14. El uso de productos y servicios de seguridad	41
2.15. Las instrucciones técnicas de seguridad	42
2.16. La formación	43
2.17. Gobernanza, cooperación y comunidad	43
3. ADECUACIÓN AL ENS, AUDITORÍA DE LA SEGURIDAD, CONFORMIDAD E INFORME DEL ESTADO DE LA SEGURIDAD .	45
3.1. Adecuación al Esquema Nacional de Seguridad.....	45
3.2. La auditoría de la seguridad.....	46
3.3. La conformidad con el Esquema Nacional de Seguridad y relación con los mecanismos de certificación europeos	48
3.4. El Esquema Nacional de Seguridad y la norma ISO/IEC 27001	50
3.5. El informe nacional del estado de la seguridad (INES)	51

4. CAPACIDADES DE CIBERSEGURIDAD, EL CCN-CERT Y LAS GUÍAS CCN-STIC.....	52
4.1. El CCN-CERT.....	52
4.2. Soluciones de ciberseguridad proporcionadas por el CCN	53
4.3. Las guías de seguridad CCN-STIC	53
4.4. El Centro de Operaciones de Ciberseguridad de la Administración General del Estado y sus Organismos Públicos.....	53
4.5. La Red Nacional de Centros de Operaciones de Ciberseguridad	54
5. MÁS CUESTIONES A LAS QUE HAY QUE PRESTAR ATENCIÓN	55
5.1. En el ámbito europeo.....	55
5.2. En el ámbito nacional	56
6. RESUMEN ESQUEMÁTICO	57
7. GLOSARIO	60
8. TEST	64
8.1. Preguntas de test.....	64
8.2. Soluciones a las preguntas de test	65
9. BIBLIOGRAFÍA.....	66
9.1. Bibliografía básica	66
9.2. Bibliografía complementaria	66
9.3. Bibliografía para ampliar	67

1. LA CIBERSEGURIDAD EN LA SEGURIDAD NACIONAL

1.1. El Sistema de Seguridad Nacional

Según el artículo 3 de la «Ley 36/2015, de 28 de septiembre, de Seguridad Nacional», se entiende por **Seguridad Nacional** la *acción del Estado dirigida a proteger la libertad y el bienestar de sus ciudadanos, a garantizar la defensa de España y sus principios y valores constitucionales, así como a contribuir junto a nuestros socios y aliados a la seguridad internacional en cumplimiento de los compromisos asumidos*.

Se establece también en dicha ley la noción de la Política de Seguridad Nacional como una política pública en la que bajo la dirección del Presidente del Gobierno y la responsabilidad del Gobierno, participan todas las Administraciones Públicas, de acuerdo con sus respectivas competencias, y la sociedad en general, para responder a las necesidades de la Seguridad Nacional. Y se indica que los principios básicos que la orientan son: unidad de acción, anticipación, prevención, eficiencia, sostenibilidad en el uso de los recursos, capacidad de resistencia y recuperación, coordinación y colaboración.

Tras el diseño adelantado por la Estrategia de Seguridad Nacional de 2013, la Ley de Seguridad Nacional asienta la **estructura institucional del Sistema de Seguridad Nacional**, como el *conjunto de órganos, organismos, recursos y procedimientos que permite a los órganos competentes en materia de Seguridad Nacional ejercer sus funciones*, con el Presidente del Gobierno en su centro, asistido por un **Consejo de Seguridad Nacional**, con el fin de poder responder a la necesidad de hacer frente de forma coordinada, rápida e integral, a las distintas amenazas y desafíos a la seguridad.

Efectivamente la Ley asigna funciones concretas a los órganos competentes de la Seguridad Nacional: Cortes Generales, el Gobierno, el Presidente del Gobierno, los Ministros, el Consejo de Seguridad Nacional, los Delegados del Gobierno en las Comunidades Autónomas y en las ciudades con Estatuto de Autonomía de Ceuta y Melilla, así como los órganos que correspondan de las distintas Comunidades Autónomas según lo dispuesto en los respectivos Estatutos de Autonomía en conexión con las competencias relacionadas con la Seguridad Nacional y las autoridades locales.

Además, crea el **Consejo de Seguridad Nacional** que tiene la condición de Comisión Delegada del Gobierno para la Seguridad Nacional, al objeto de asistir al Presidente del Gobierno en la dirección de la política de Seguridad Nacional y del Sistema de Seguridad Nacional y en las demás funciones que el ordenamiento jurídico le atribuya. El **Departamento de Seguridad Nacional (DSN)** ejerce las funciones de Secretaría Técnica y órgano de trabajo permanente del Consejo de Seguridad Nacional y de sus órganos de apoyo, Comités Especializados, como, por ejemplo, el Consejo Nacional de Ciberseguridad, que ejercen funciones en ámbitos de actuación previstos en la Estrategia de Seguridad Nacional.

Desde el punto de vista de la ciberseguridad **interesan los siguientes componentes** asentados en la Estrategia Nacional de Ciberseguridad 2019:

- El **Consejo de Seguridad Nacional**, Comisión Delegada del Gobierno para la Seguridad Nacional que asiste al Presidente del Gobierno en la dirección de la Política de Seguridad Nacional.
- El **Departamento de Seguridad Nacional**, ejerce las funciones de Secretaría Técnica y órgano de trabajo permanente del Consejo de Seguridad Nacional y de sus órganos de apoyo y comités especializados.
- El **Comité Especializado de Situación**, único para el conjunto del Sistema de Seguridad Nacional. Es convocado para llevar a cabo la gestión de las situaciones de crisis en el ámbito de la ciberseguridad, que desborden los límites de capacidad de respuesta eficaz por parte de los mecanismos habituales previstos. El Comité Especializado de Ciberseguridad y el Comité Especializado de Situación actuarán de forma complementaria.
- El **Consejo Nacional de Ciberseguridad**, comité especializado que da apoyo al Consejo de Seguridad Nacional en el ámbito de la ciberseguridad. Entre sus funciones se encuentra la de reforzar las relaciones de coordinación, colaboración y cooperación entre las distintas Administraciones Públicas con competencias en materia de ciberseguridad, así como entre los sectores público y privado, así como facilitar la toma de decisiones del Consejo de

Seguridad Nacional mediante el análisis, estudio y propuesta de iniciativas en el ámbito de la ciberseguridad.

- **La Comisión Permanente de Ciberseguridad** persigue facilitar la coordinación interministerial a nivel operacional en el ámbito de la ciberseguridad. Presidida por el Departamento de Seguridad Nacional, se compone de aquellos órganos y organismos representados en el Consejo Nacional de Ciberseguridad con responsabilidades operativas. Es el órgano al que corresponde asistir al Consejo Nacional de Ciberseguridad sobre aspectos relativos a la valoración técnica y operativa de los riesgos y amenazas a la ciberseguridad.
- **El Foro Nacional de Ciberseguridad** actúa en la potenciación y creación de sinergias público privadas, particularmente en la generación de conocimiento sobre las oportunidades y los desafíos y amenazas a la seguridad en el ciberespacio. Constituido en 2020, el Foro Nacional de Ciberseguridad, compuesto, además de por los organismos públicos con competencia en la materia, por 16 organizaciones representantes de la sociedad civil y el sector privado, persigue fomentar la cultura de ciberseguridad, ofrecer apoyo a la Industria e I+D+i y promover la formación y el talento, todo ello a través de un entorno de colaboración público-privada bajo el paraguas del Consejo de Seguridad Nacional. El Foro aporta un espacio de colaboración público-privada, un foro de debate destinado a transformar la información en conocimiento generando acciones orientadas a dinamizar aspectos esenciales como la Industria, el talento y la cultura de ciberseguridad.
- **Las Autoridades públicas competentes en materia de seguridad de las redes y sistemas de información y los CSIRT de referencia nacionales** complementan el marco estratégico e institucional de la ciberseguridad.

Asimismo, los CSIRT de las Comunidades Autónomas, de las Ciudades Autónomas, de las Entidades Locales y sus organismos vinculados o dependientes, los de las entidades privadas, la red de CSIRT.es y otros servicios de ciberseguridad relevantes deberán estar coordinados con los anteriores en función de las competencias de cada uno de ellos.

Según lo establecido en el «Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información», son equipos de respuesta a incidentes de seguridad informática (CSIRT) de referencia en materia de seguridad de las redes y sistemas de información, los siguientes:

El **CCN-CERT**, del Centro Criptológico Nacional, al que corresponde la comunidad de referencia constituida por las entidades del ámbito subjetivo de aplicación de la Ley 40/2015, de 1 de octubre.

El **INCIBE-CERT**, del Instituto Nacional de Ciberseguridad de España, al que corresponde la comunidad de referencia constituida por aquellas entidades no incluidas en el ámbito subjetivo de aplicación de la Ley 40/2015, de 1 de octubre. El INCIBE-CERT será operado conjuntamente por el INCIBE y el CNPIC en todo lo que se refiera a la gestión de incidentes que afecten a los operadores críticos. El INCIBE-CERT será, así mismo, equipo de respuesta a incidentes de referencia para los ciudadanos, entidades de derecho privado y otras entidades.

El **ESPDEF-CERT**, del Ministerio de Defensa, que cooperará con el CCN-CERT y el INCIBE-CERT en aquellas situaciones que éstos requieran en apoyo de los operadores de servicios esenciales y, necesariamente, en aquellos operadores que tengan incidencia en la Defensa Nacional y que reglamentariamente se determinen.

Los CSIRT de referencia se coordinarán entre sí y con el resto de CSIRT nacionales e internacionales en la respuesta a los incidentes y gestión de riesgos de seguridad que les correspondan.

En los supuestos de especial gravedad que reglamentariamente se determinen y que requieran un nivel de coordinación superior al necesario en situaciones ordinarias, el CCN-CERT ejercerá la coordinación nacional de la respuesta técnica de los CSIRT.

Cuando las actividades que desarrollen puedan afectar de alguna manera a un operador crítico, los CSIRT de referencia se coordinarán con el Ministerio del Interior, a través de la Oficina de Coordinación de Ciberseguridad.

Los CSIRT de las Administraciones Públicas consultarán, cuando proceda, con los órganos con competencias en materia de seguridad nacional, seguridad pública, seguridad ciudadana y protección de datos de carácter personal y colaborarán con ellos en el ejercicio de sus respectivas funciones.

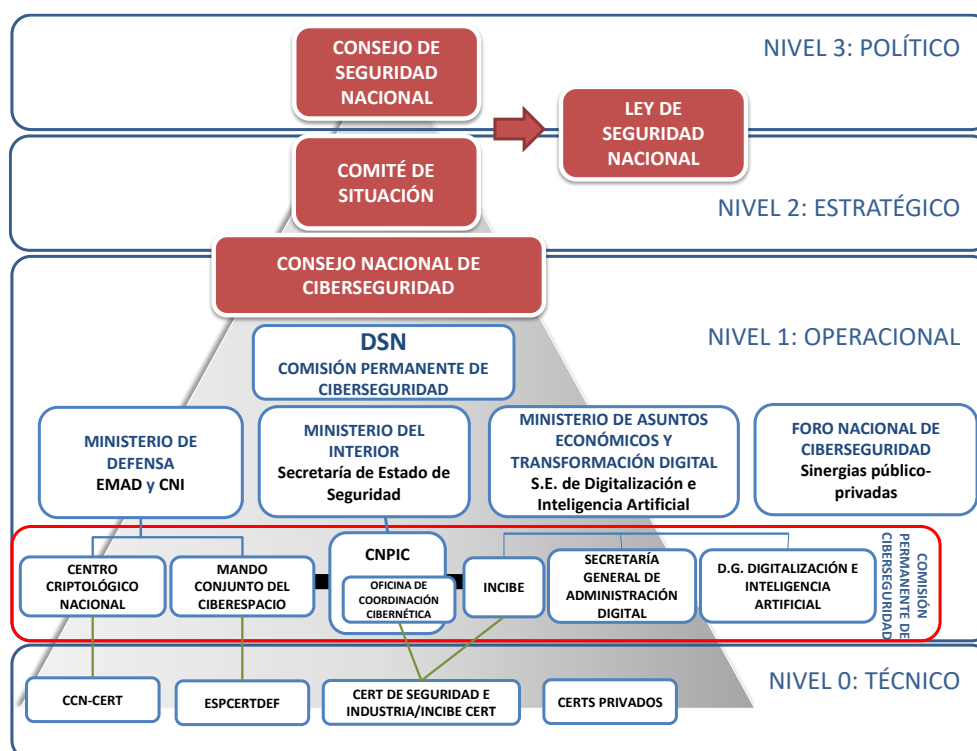


Figura 1. Panorámica de la Seguridad Nacional en Ciberseguridad (Fuente: Departamento de Seguridad Nacional)

1.2. Consejo Nacional de Ciberseguridad

El Consejo de Seguridad Nacional acordó en su reunión de 5 de diciembre de 2013 crear el Comité Especializado de Ciberseguridad bajo el nombre del **Consejo Nacional de Ciberseguridad (CNCS)**, como un órgano de apoyo de los previstos en el artículo 20.3 de la Ley 36/2015, de 28 de septiembre, de Seguridad Nacional, al que corresponde ejercer las funciones asignadas por aquél en el ámbito de la ciberseguridad y en el marco del Sistema de Seguridad Nacional.

El CNCS refuerza las relaciones de coordinación, colaboración y cooperación entre las entidades de la Administración con competencias en materia de ciberseguridad, así como entre los sectores público y privado, y facilita la toma de decisiones del Consejo de Seguridad Nacional mediante el análisis, estudio y propuesta de iniciativas en el ámbito de la ciberseguridad.

El Consejo de Seguridad Nacional, en su reunión de 1 de diciembre de 2017, actualizó el acuerdo de 5 de diciembre de 2013, mediante un nuevo acuerdo por el que se regula el Consejo Nacional de Ciberseguridad: la «Orden PRA/33/2018, de 22 de enero, por la que se publica el Acuerdo del Consejo de Seguridad Nacional, por el que se regula el Consejo Nacional de Ciberseguridad», que detalla cuestiones como el régimen jurídico, sus funciones, su composición y otros detalles.

Constituido el 25 de febrero de 2014, el CNCS tiene, a la fecha, la siguiente composición:

- Presidencia: La Secretaria de Estado Directora del CNI.
- Vicepresidencia: Director del Departamento de Seguridad Nacional.
- Vocales: con rango mínimo de subdirector general o asimilado u Oficial General de cada departamento ministerial y organismo público con representación en el Consejo de Seguridad Nacional, que será designado por el titular del ministerio y organismo respectivo. También

podrá formar parte del Consejo un representante del resto de los departamentos ministeriales u organismos públicos cuya presencia sea así acordada por el Presidente, en función de los asuntos a tratar.

1.3. La Estrategia de Seguridad Nacional

La «Estrategia de Seguridad Nacional 2021», sucesora de las anteriores de 2017, 2013 y 2011, es el marco de referencia para la política de Seguridad Nacional. Aprobada por el Gobierno mediante el Real Decreto 1150/2021, de 28 de diciembre, profundiza en algunos de los conceptos y líneas de acción ya definidos en 2017 y avanza en la adaptación de dicha Política y los instrumentos y recursos del Estado que la conforman ante nuevos desarrollos de un entorno de seguridad en cambio constante. Cuenta con la siguiente estructura de contenidos:

- Resumen ejecutivo
- Introducción
- Capítulo 1. Seguridad Global y Vectores de Transformación
- Capítulo 2. Una España Segura y Resiliente
- Capítulo 3. Riesgos y amenazas
- Capítulo 4. Un Planeamiento Estratégico Integrado
- Capítulo 5. El Sistema de Seguridad Nacional y la Gestión de Crisis.

A continuación, se exponen los aspectos principales de estos capítulos destacando los aspectos que se refieren al ciberespacio y a la ciberseguridad.

En el capítulo 1, titulado “Seguridad global y vectores de transformación” se identifica la pandemia de la COVID-19 como un factor que ha producido una aceleración de las principales dinámicas globales que afectan a la seguridad, y destaca la incertidumbre sobre un futuro donde la transformación digital y la transición ecológica se configuran como las principales palancas de cambio en un escenario de mayor competición geopolítica.

Este capítulo 1 desarrolla ampliamente el impacto de la transformación digital señalando argumentos como los siguientes que se recogen de forma pormenorizada por su interés:

- El incremento de infraestructuras y servicios digitales, potenciado por tecnologías disruptivas y emergentes como la computación en la nube, la computación cuántica, la Inteligencia Artificial, la virtualización de redes o el Internet de las Cosas, implica una transformación digital imparable que ofrece innumerables oportunidades, pero que a la vez presenta serios desafíos para la Seguridad Nacional.
- La pandemia de la COVID-19 ha supuesto una aceleración del proceso de digitalización, que ha situado a la interacción digital en el centro de las actividades públicas, privadas y profesionales.
- La digitalización de todo tipo de actividades ha ampliado la superficie de exposición a posibles ciberataques de organizaciones, tanto públicas como privadas, y ha dificultado la adecuada protección de la información.
- La magnitud y frecuencia de los ciberincidentes y del uso ilícito del ciberespacio han aumentado en los últimos años y han convertido la ciberseguridad en una prioridad de organizaciones y gobiernos.
- La transformación digital no es un fenómeno solo tecnológico, sino que tiene impacto en las relaciones sociales y la configuración geopolítica, pues los cambios tecnológicos generan cambios de poder.
- La estabilidad económica y las políticas monetarias también se ven afectadas por la irrupción de tecnologías potencialmente disruptivas, como la implantación de divisas digitales.
- Los riesgos se ven amplificados por la prevalencia de criterios comerciales frente a los de seguridad en el diseño de productos de hardware y software, así como de sistemas y

servicios, tales como el 5G. Este hecho dificulta los procesos de certificación y puede comprometer la cadena de suministro.

- La vulnerabilidad ante posibles injerencias de terceros es extensible al dominio de infraestructuras digitales, como los centros de procesamiento de datos o los cables submarinos, y a los activos que sustentan la propiedad intelectual e industrial del sector empresarial.
- Con el dato convertido ya en un recurso estratégico de primer orden, se ha intensificado el debate sobre la ética y la defensa de derechos digitales, condicionado especialmente por la concentración de la información en las grandes compañías tecnológicas y por su uso abusivo por parte de algunos actores políticos.
- El acceso seguro a los servicios públicos y privados, en particular a los servicios esenciales en línea, supone que la ciudadanía pueda proteger su identidad y controlar los datos que comparte y cómo se utilizan, de manera que se garantice la privacidad y la protección de datos personales. Disponer de una identidad digital segura es una pieza clave para la ciberseguridad.
- Finalmente señala que la gobernanza democrática sobre el futuro digital es de máxima importancia para resolver las inquietudes relativas a los derechos y libertades y a la competición geopolítica.

En el capítulo 2 “Una España segura y resiliente”, se traza un perfil de España y su seguridad.

En el capítulo 3 “Riesgos y amenazas” se recogen los riesgos y las amenazas a la Seguridad Nacional, cuyas principales características son su interrelación y dinamismo, siendo la inclusión de las campañas de desinformación la principal actualización en el mapa de riesgos; además, se señalan la tecnología y las estrategias híbridas como elementos transversales al conjunto de riesgos y amenazas a la Seguridad Nacional.

En relación con la **vulnerabilidad del ciberespacio** se señalan dos tipologías generales de amenazas en el ciberespacio: por un lado, los ciberataques, entendidos como acciones disruptivas que actúan contra sistemas y elementos tecnológicos; y, por otro lado, el uso del ciberespacio para realizar actividades ilícitas, como el cibercrimen, el ciberespionaje, la financiación del terrorismo o el fomento de la radicalización. Se apunta el impacto del desarrollo de las redes 5G, del dato como nuevo ámbito de poder, la inteligencia artificial, el big data y el salto tecnológico que supone la computación cuántica con usos difíciles de prever hoy en día en materia de comunicaciones seguras, cifrado y descifrado y sistemas de vigilancia avanzados, entre otros posibles.

En el capítulo 4, titulado “Un planeamiento estratégico integrado”, se establecen tres objetivos, que marcan las prioridades de la Seguridad Nacional para este ciclo estratégico. El primer objetivo es avanzar en materia de gestión de crisis; el segundo objetivo es favorecer la dimensión de la seguridad de las capacidades tecnológicas y los sectores estratégicos; y el tercer objetivo es desarrollar la capacidad preventiva, de detección y respuesta frente a las estrategias híbridas.

En el ámbito específico del ciberespacio, la Estrategia:

- Apunta, en primer lugar, que se requiere garantizar el uso seguro y fiable del ciberespacio, para proteger los derechos y las libertades de los ciudadanos y promover el progreso socio económico; y que para ello es importante incrementar las capacidades (tecnológicas, humanas y económicas) de la ciberseguridad nacional dirigidas a la prevención, detección, respuesta, recuperación, investigación y defensa activa.
- Señala, en segundo lugar, la importancia de la Carta de Derechos Digitales que supone un paso adelante en la protección de los derechos de la ciudadanía en el entorno virtual actual, incluyendo el reconocimiento del derecho a la igualdad en los ámbitos digitales, la no discriminación y la no exclusión.
- Subraya, en tercer lugar, sobre la Administración pública que *“es ineludible avanzar en el modelo de gobernanza de la ciberseguridad nacional, sobre la base de una mayor eficiencia en los recursos y la integración de las capacidades nacionales. En este sentido, el Centro de Operaciones de Ciberseguridad permitirá, mediante la prestación de servicios horizontales, aumentar las capacidades de vigilancia, detección y respuesta ante ciberataques contra la Administración General del Estado y sus organismos públicos, así como contra las*

administraciones autonómicas y locales. Un aspecto relevante será el desarrollo de las infraestructuras de ciberseguridad en las Comunidades y Ciudades Autónomas.”

- En cuarto lugar, señala como prioridades adicionales la creación de un sistema de observación y medición de la situación de la ciberseguridad nacional, así como la puesta en marcha de una plataforma nacional de notificación y seguimiento de ciberincidentes (prevista en el Real Decreto 43/2021 que se trata más adelante) que permita medir el intercambio de información entre organismos públicos y privados en tiempo real.
- Y, finalmente, apunta que será preciso implementar los nuevos requerimientos previstos en el marco de la Unión Europea en la Estrategia de Ciberseguridad de la UE para la Era Digital y en la adecuación de las nuevas propuestas normativas, que han de incluir la legislación necesaria para la protección de las redes y sistemas.

En cuanto a las líneas de acción indicadas en este capítulo 4 para los espacios globales, en relación con el ciberespacio se incluye lo siguiente:

“L.A.17. Avanzar en la integración del modelo de gobernanza de la ciberseguridad en el marco del Sistema de Seguridad Nacional.”

El capítulo 5 “El Sistema de Seguridad Nacional y la Gestión de Crisis” está dedicado a la gestión de crisis en el marco del Sistema de Seguridad Nacional, siendo destacables el desarrollo de un sistema de alerta temprana y análisis con indicadores que faciliten la toma de decisiones basada en datos objetivos concretos, así como la integración de la información de la Seguridad Nacional a través de soluciones tecnológicas.



Figura 2. Panorámica del Sistema de Seguridad Nacional (Fuente: Estrategia de Seguridad Nacional 2021)



Figura 3. Órganos competentes en Seguridad Nacional (Fuente: Estrategia de Seguridad Nacional 2021)

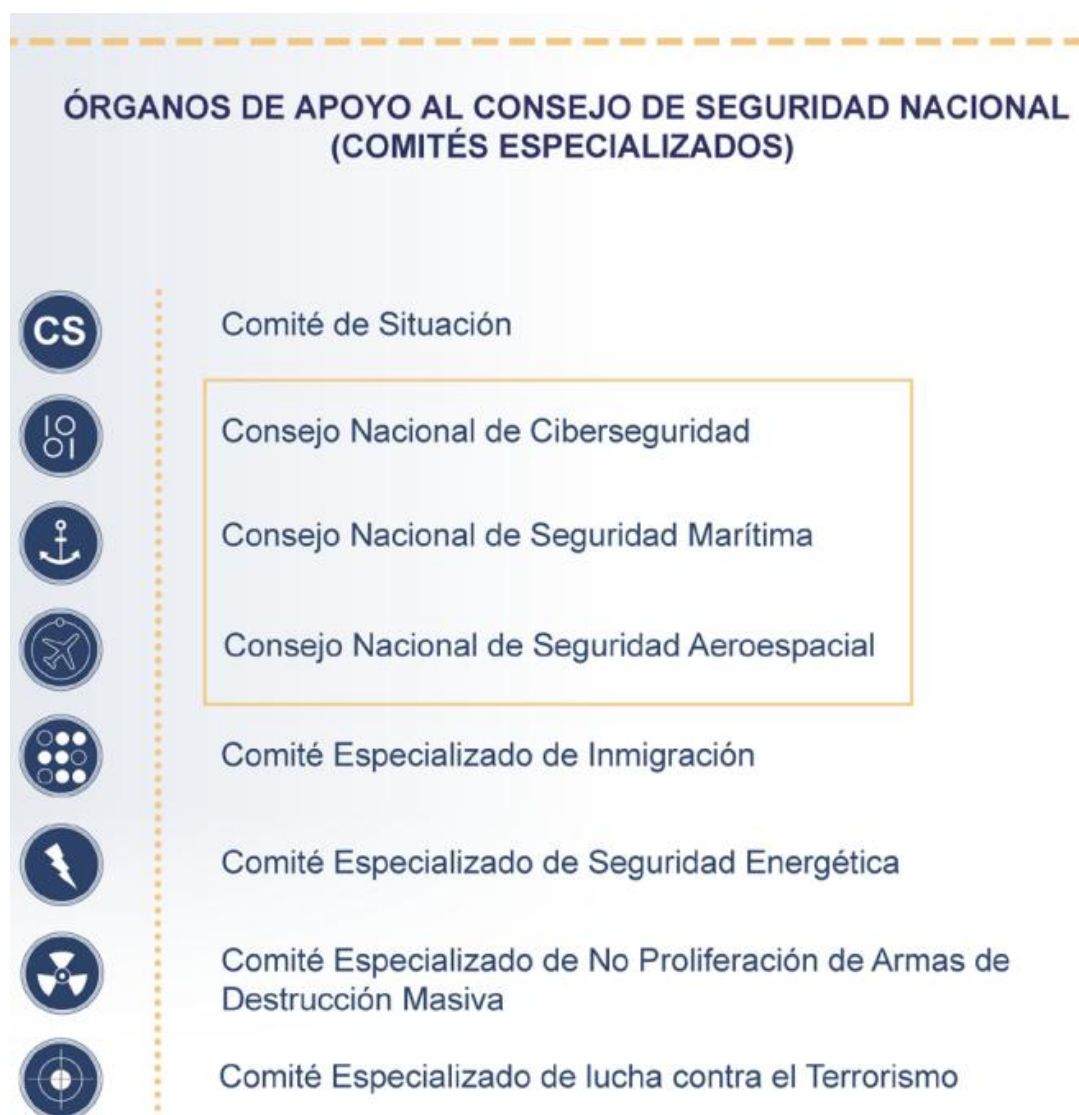


Figura 4. Órganos de apoyo al Consejo de Seguridad Nacional (Fuente: Estrategia de Seguridad Nacional 2021)

1.4. La Estrategia Nacional de Ciberseguridad

El Consejo de Seguridad Nacional aprobó el 12 de abril de 2019 la «Estrategia Nacional de Ciberseguridad 2019», atendiendo a lo previsto en la «Orden PCI/870/2018, de 3 de agosto, por la que se publica el Acuerdo del Consejo de Seguridad Nacional, por el que se aprueba el procedimiento para la elaboración de una nueva Estrategia de Ciberseguridad Nacional», que comunicaba el mandato del Consejo de Seguridad Nacional de 16 de julio de 2018. Publicada en el BOE de 30 de abril de 2019, la Estrategia Nacional de Ciberseguridad 2019 establece la posición de España ante una nueva concepción de la ciberseguridad en el marco de la Política de Seguridad Nacional.

La Estrategia Nacional de Ciberseguridad 2019, que viene a sustituir a la de 2013, establece el propósito y los principios por los que se rige (unidad de acción, anticipación, eficiencia y resiliencia), así como los objetivos, uno general y cinco específicos que resultan transversales a todos los ámbitos.

El objetivo general se expresa en términos de que *España garantizará el uso seguro y fiable del ciberespacio, protegiendo los derechos y las libertades de los ciudadanos y promoviendo el progreso socio económico.*

Los **5 objetivos específicos** son:

- Objetivo I: Seguridad y resiliencia de las redes y los sistemas de información y comunicaciones del sector público y de los servicios esenciales.
- Objetivo II: Uso seguro y fiable del ciberespacio frente a su uso ilícito o malicioso.
- Objetivo III: Protección del ecosistema empresarial y social y de los ciudadanos.
- Objetivo IV: Cultura y compromiso con la ciberseguridad y potenciación de las capacidades humanas y tecnológicas.
- Objetivo V: Seguridad del ciberespacio en el ámbito internacional.

Las **7 líneas de acción** son:

- Línea de Acción 1. Reforzar las capacidades ante las amenazas provenientes del ciberespacio.
- Línea de Acción 2. Garantizar la seguridad y resiliencia de los activos estratégicos para España.
- Línea de Acción 3. Reforzar las capacidades de investigación y persecución de la cibercriminalidad, para garantizar la seguridad ciudadana y la protección de los derechos y libertades en el ciberespacio.
- Línea de Acción 4. Impulsar la ciberseguridad de ciudadanos y empresas
- Línea de Acción 5. Potenciar la industria española de ciberseguridad, y la generación y retención de talento, para el fortalecimiento de la autonomía digital.
- Línea de Acción 6. Contribuir a la seguridad del ciberespacio en el ámbito internacional, promoviendo un ciberespacio abierto, plural, seguro y confiable, en apoyo de los intereses nacionales.
- Línea de Acción 7. Desarrollar una cultura de ciberseguridad.

Estas líneas de acción se desarrollan en 65 medidas.

La Estrategia recoge entre sus objetivos el **“1. Seguridad y resiliencia de las redes y los sistemas de información y comunicaciones del sector público y de los servicios esenciales”**, desarrollado por dos líneas de acción, **“1. Reforzar las capacidades ante las amenazas provenientes del ciberespacio”**, y especialmente **“2. Garantizar la seguridad y resiliencia de los activos estratégicos para España”** que incluye entre sus medidas las dos siguientes: **“3. Asegurar la plena implantación del Esquema Nacional de Seguridad, del Sistema de Protección de las Infraestructuras Críticas, y el cumplimiento y armonización de la normativa sobre protección de infraestructuras críticas y servicios esenciales, con un enfoque prioritario basado en el riesgo.”** y **“5. Desarrollar el Centro de Operaciones de Ciberseguridad de la Administración General del Estado que mejore las capacidades de prevención, detección y respuesta, e impulsar el desarrollo de centros de operaciones de ciberseguridad en el ámbito autonómico y local.”**

El 29 de marzo de 2022, el Consejo de Ministros aprobó el **Plan Nacional de Ciberseguridad** cuyo principal objetivo es concretar, a través de actuaciones y proyectos específicos, para los tres próximos años, medidas recogidas en la Estrategia Nacional de Ciberseguridad 2019.

Para mayor detalle sobre la Estrategia véase el tema **“Ciberseguridad. La estrategia nacional de ciberseguridad”**.

1.5. La protección de infraestructuras críticas

En este apartado se tratan los aspectos principales de la protección de infraestructuras críticas teniendo presente la perspectiva de la ciberseguridad:

- el marco legal;

- el concepto de infraestructura crítica;
- los 12 sectores estratégicos;
- la estructura organizativa del sistema PIC, con el Centro Nacional para la Protección de las Infraestructuras Críticas (CNPIC) y su Oficina de Coordinación Cibernética (OCC) y la Comisión Nacional PIC;
- los planes estratégicos sectoriales (PES);
- los operadores críticos y sus obligaciones principales;
- las figuras de la seguridad integral;
- y el Nivel de Alerta en Infraestructuras Críticas (NAIC).

El marco legal que respalda la Protección de Infraestructuras Críticas en España viene dado esencialmente por:

- El «Acuerdo Consejo de Ministros sobre Protección de Infraestructuras Críticas, de 2 de noviembre de 2007».
- La «Ley 8/2011, de 28 de abril, por la que se establecen medidas para la Protección de las Infraestructuras Críticas».
- El «Real Decreto 704/2011 por la que se aprueba el Reglamento para la Protección de las Infraestructuras Críticas».

También cuenta la protección de infraestructuras críticas con el correspondiente respaldo en la Estrategia de Seguridad Nacional 2021 y en la Estrategia Nacional de Ciberseguridad 2019.

La **Ley 8/2011**, que transpone la Directiva 2008/114/CE, **tiene por objeto**, por un lado, regular la protección de las infraestructuras críticas contra ataques deliberados de todo tipo, tanto de carácter físico como cibernético, y, por otro lado, la definición de un sistema organizativo de protección de dichas infraestructuras que aglutine a las Administraciones Públicas y entidades privadas afectadas.

Esta ley sienta las bases del **Catálogo Nacional de Infraestructuras Estratégicas**, conforme a la comunicación del Consejo de la Unión Europea de 20 de octubre de 2004, que señala que cada sector y cada Estado miembro deberá identificar las infraestructuras que son críticas en sus respectivos territorios y del **Plan Nacional de Protección de Infraestructuras Críticas**, como principales herramientas en la gestión de la seguridad de nuestras infraestructuras.

El Real Decreto 704/2011:

- **Establece una terminología y un marco de referencia comunes** en lo relativo a la protección de los activos contra ataques deliberados, que puedan ser utilizados tanto por los poderes públicos como por el sector privado.
- **Crea una estructura organizativa (Sistema de Protección de Infraestructuras Críticas)** a nivel nacional, en la que se distribuyan las funciones y responsabilidades que los diversos agentes, tanto públicos como privados, deben tener en el marco de la seguridad de las infraestructuras que proveen a la sociedad de los servicios esenciales, contando como pieza central del mismo con el CNPIC, como órgano director y coordinador.
- **Diseña un sistema de planificación** en el que se puedan incardinar los Planes de Seguridad del Operador y que se integre en una estrategia de seguridad que permita la interacción y el reparto de responsabilidades entre las Administraciones públicas y los operadores de infraestructuras críticas.
- **Marca hitos que permitan a medio/largo plazo la implantación de planes integrales de seguridad** que contemplen de una forma homogénea y sistemática las amenazas, tanto de carácter físico como cibernético, contra los activos a proteger.
- **Finalmente, establece una red de comunicaciones segura** en la que se garantice la confidencialidad y protección de los datos existentes sobre las diferentes instalaciones sensibles y estén representados todos los agentes del Sistema de Protección de Infraestructuras Críticas. Todo ello, bajo la coordinación del CNPIC y teniendo como eje el Catálogo Nacional de Infraestructuras Estratégicas.

Para completar este marco, el **Plan Nacional de Protección de Infraestructuras Críticas (PNPIC)**, que actualiza el anterior de 2007, fue aprobado mediante Instrucción número 1/2016, de la Secretaría de Estado de Seguridad. Este Plan contiene los criterios y las directrices para movilizar las capacidades operativas de respuesta, articulando medidas para asegurar la protección permanente, actualizada y homogénea de las infraestructuras críticas, de cualquiera de los sectores estratégicos recogidos en la Ley PIC, frente a las amenazas de carácter deliberado; todo ello en línea y de forma coordinada con lo establecido por el Plan de Prevención y Protección Antiterrorista, con el que está vinculado.

El concepto de “infraestructura crítica”. La Ley 8/2011 define **infraestructura crítica** como “*Las infraestructuras estratégicas (es decir, aquellas que proporcionan servicios esenciales) cuyo funcionamiento es indispensable y no permite soluciones alternativas, por lo que su perturbación o destrucción tendría un grave impacto sobre los servicios esenciales*”.

Los 12 sectores estratégicos contemplados por la normativa española para la identificación de infraestructuras críticas son: **Administración**, Agua, Alimentación, Energía, Espacio, Industria Química, Industria Nuclear, Instalaciones de Investigación, Salud, Sistema Financiero y Tributario, **Tecnologías de la Información y las Comunicaciones (TIC)** y Transporte.

En cuanto a la estructura organizativa del sistema PIC, la Ley 8/2011 establece el **Centro Nacional para la Protección de las Infraestructuras Críticas (CNPIC)** como órgano de asistencia al Secretario de Estado de Seguridad en la ejecución de las funciones que se le encomiendan a éste como órgano responsable del sistema. El CNPIC fue creado en el año 2007, mediante el Acuerdo de Consejo de Ministros de 2 de noviembre, para impulsar, coordinar y supervisar todas las actividades relativas a la protección de las infraestructuras críticas.

La **Comisión Nacional PIC** es el órgano colegiado adscrito a la Secretaría de Estado de Seguridad, que desarrolla las funciones que le encomiendan la Ley 8/2011 y su reglamento de desarrollo, el Real Decreto 704/2011. La primera reunión de la Comisión Nacional PIC se celebró el 30 de junio de 2014. Entre sus funciones figuran:

- Aprobar los **Planes Estratégicos Sectoriales (PES)**.
- **Designar a los operadores críticos**.
- Aprobar la creación, modificación o supresión de grupos de trabajo sectoriales o de carácter técnico, estableciendo sus objetivos y sus marcos de actuación.
- **Identificar los servicios esenciales** (Real Decreto-ley 12/2018).
- **Designar los operadores de los servicios esenciales** (Real Decreto-ley 12/2018).

Dicha Comisión Nacional PIC cuenta con un Grupo de Trabajo Interdepartamental PIC que prepara el trabajo de aquella. Se abren grupos de trabajo sectoriales en función de los planes estratégicos sectoriales a elaborar. Ciertos documentos tienen naturaleza de información clasificada.

Los Planes Estratégicos Sectoriales (PES) permiten identificar los servicios esenciales prestados a la sociedad por los sectores objeto de estudio, el funcionamiento general de éstos, las principales amenazas de origen deliberado sobre los mismos y sus principales vulnerabilidades, las infraestructuras críticas que proporcionan servicio y los operadores propietarios o gestores de las mismas. Estos planes culminan con una evaluación de las consecuencias potenciales de su inactividad, así como con una propuesta de medidas estratégicas para su mantenimiento. A la fecha, de los 18 PES previstos correspondientes a los 12 sectores PIC, 16 PES están aprobados y quedan pendientes 2, siendo el **PES del Sector Administración** uno de ellos y el PES de Instalaciones de investigación el otro.

En cuanto a los Operadores Críticos, a la luz de lo previsto en el Real Decreto 704/2011, una vez aprobado el PES e identificadas las infraestructuras críticas, se produce la designación de los **Operadores Críticos (OC)** que son los Agentes del Sistema, tanto del sector público como del sector privado, responsables del funcionamiento diario de una instalación, red, sistema o equipo físico o de tecnología de la información designada como infraestructura crítica conforme a la Ley 8/2011. Forman parte del Sistema de Protección de Infraestructuras Críticas, con una especial relación con las autoridades competentes, a través del CNPIC.

Los Operadores Críticos tienen las siguientes **obligaciones** principales:

- Elaborar el **Plan de Seguridad del Operador** y proceder a su actualización periódicamente o cuando las circunstancias así lo exijan, conforme a lo que establece el Capítulo III, Título III del reglamento.
- Elaborar un **Plan de Protección Específico** por cada una de las infraestructuras consideradas como críticas en el Catálogo, así como proceder a su actualización periódicamente o cuando las circunstancias así lo exijan, conforme a lo establecido en el Capítulo IV, Título III del presente reglamento.
- Designar a un **Responsable de Seguridad y Enlace**, en virtud de lo dispuesto en el artículo 34 del reglamento.
- Designar a un **Delegado de Seguridad** por cada una de sus infraestructuras consideradas Críticas o Críticas Europeas por la Secretaría de Estado de Seguridad, comunicando su designación a los órganos correspondientes en virtud de lo dispuesto en el artículo 35 del reglamento.
- **Facilitar las inspecciones** que las autoridades competentes lleven a cabo para verificar el cumplimiento de la normativa sectorial, en el marco de lo establecido en el Título III del reglamento.

Las figuras de la seguridad integral son los actores que desempeñan un papel trascendental en la coordinación, canalización y notificación de todas las materias relacionadas con seguridad integral de las infraestructuras críticas y los servicios esenciales. Siguiendo al CNPIC como fuente, son las siguientes:

- **Responsable de seguridad y enlace (RSE).** Persona designada por el operador crítico como representante y enlace con ante la Secretaría de Estado de Seguridad en todas las materias de seguridad de la protección de las infraestructuras críticas.
- **Responsable de seguridad de la información (RSI).** Persona designada por el operador de servicios esenciales como punto de contacto y de coordinación técnica con las autoridades competentes en materia de seguridad de las redes y sistemas de información.
- **Delegados de seguridad de la infraestructura crítica (DS).** Persona designada por el operador crítico como enlace operativo y el canal de información con las autoridades competentes en todo lo referente a la seguridad concreta de la infraestructura crítica.

El Nivel de alerta en infraestructuras críticas (NAIC) es una escala compuesta por varios niveles complementarios, cada uno de los cuales se encuentra asociado a un grado de riesgo que, por lo general, va en concordancia con los niveles de alerta del Plan de Prevención y Protección Antiterrorista, en función de la valoración de la amenaza terrorista que se aprecie en cada momento.

Siguiendo al CNPIC como fuente:

Existen **cinco niveles de activación**, al igual que en la clasificación prevista en el Plan de Prevención y Protección Antiterrorista, asociados a un determinado nivel de riesgo: el Nivel 1 corresponde a riesgo bajo, el Nivel 2 a riesgo moderado, el Nivel 3 a riesgo medio, el Nivel 4 a riesgo alto y el Nivel 5 a riesgo muy alto.

La activación de cada nivel lleva aparejada la puesta en marcha gradual de un conjunto de medidas específicas adaptadas al estado y naturaleza de la amenaza.

La **activación de un nivel** compete al Ministerio del Interior, a través de la Secretaría de Estado de Seguridad, correspondiéndose con el grado de riesgo detectado en cada momento, en atención a la valoración de la amenaza y las demás circunstancias concurrentes.

La **activación de los distintos niveles** vendrá, por lo general, condicionada a la activación del nivel de alerta que marque en cada momento el Plan de Protección y Prevención Antiterrorista, en atención a la valoración de la amenaza y otras circunstancias asociadas a la misma. Pero se considerará especialmente la intención, capacidad y probabilidad de comisión de un ataque deliberado contra infraestructuras críticas que proporcionan servicios esenciales a la ciudadanía.

1.6. La seguridad de las redes y sistemas de información

En este apartado se tratan: el marco legal de la seguridad de las redes y sistemas de información; los servicios esenciales y los servicios digitales; los operadores de servicios esenciales y los prestadores de servicios digitales; las autoridades competentes; los CSIRTs de referencia; las obligaciones de seguridad de los operadores de servicios esenciales y de los proveedores de servicios digitales; y la obligación de los operadores de servicios esenciales y de los proveedores de servicios digitales de notificar a la autoridad competente, a través del correspondiente CSIRT de referencia, los incidentes de seguridad que puedan tener efectos perturbadores significativos.

La «Directiva 2016/1148/UE, sobre seguridad de las redes y sistemas de información», conocida como **Directiva NIS**, prevé el establecimiento de medidas de seguridad de los sistemas de redes y de información de una serie de operadores de la Unión Europea, operadores de servicios esenciales y proveedores de servicios digitales, con el objetivo de *"lograr un elevado nivel común de seguridad de las redes y sistemas de información dentro de la Unión, a fin de mejorar el funcionamiento del mercado interior"*.

La Directiva NIS fue transpuesta a través del **«Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información»**. Este Real Decreto-ley tiene por objeto *"regular la seguridad de las redes y sistemas de información utilizados para la provisión de los servicios esenciales y de los servicios digitales, y establecer un sistema de notificación de incidentes"*, a la vez que *"establece un marco institucional para la coordinación entre autoridades competentes y con los órganos de cooperación relevantes en el ámbito comunitario"*.

El Real Decreto-ley 12/2018 es de aplicación a la prestación de los **servicios esenciales** dependientes de las redes y sistemas de información comprendidos en los sectores estratégicos definidos en el anexo de la Ley 8/2011 PIC; y de los **servicios digitales**, considerados como "servicios de la sociedad de la información" (véase la Ley 34/2002, anexo, letra a), que sean mercados en línea, motores de búsqueda en línea y servicios de computación en nube. Su ámbito de aplicación se extiende también a sectores que no están incluidos en la Directiva para adoptar un enfoque más global.

¿Quiénes están sometidos a este Real Decreto-ley? Pues los operadores de servicios esenciales establecidos en España; también los servicios esenciales que los operadores residentes o domiciliados en otro Estado ofrezcan a través de un establecimiento permanente situado en España; y los proveedores de servicios digitales que tengan su sede social en España y que constituya su establecimiento principal en la Unión Europea, así como los que, no estando establecidos en la Unión Europea, designen en España a su representante en la Unión para el cumplimiento de la Directiva (UE) 2016/1148. No obstante, no se aplicará a los operadores de redes y servicios de comunicaciones electrónicas y los prestadores de servicios electrónicos de confianza que no sean designados como operadores críticos; ni a los proveedores de servicios digitales cuando se trate de microempresas o pequeñas empresas.

La identificación de los servicios esenciales y de los operadores que los presten se alinea con los mecanismos y procedimientos previstos en la Ley 8/2011 PIC. En la disposición final primera del Real Decreto-ley se recoge que corresponde a la Comisión Nacional PIC la aprobación de una primera lista de servicios esenciales dentro de los sectores incluidos en el ámbito de aplicación (Energía, Transporte, Salud, Sistema financiero, Agua y TIC), así como la identificación de los operadores que los presten. La Comisión PIC ya ha designado en 2018 a 132 Operadores Esenciales de los 71 Servicios Esenciales aprobados, siendo todos ellos, a su vez, operadores críticos. Y antes del 9 de noviembre de 2019 la Comisión PIC deberá aprobar los servicios esenciales y designar los operadores correspondientes del resto de los sectores estratégicos recogidos en el anexo de la Ley 8/2011 PIC (Administración, Espacio, Industria nuclear, Industria química, Instalaciones de investigación y Alimentación).

En relación con el marco estratégico e institucional interesan especialmente las autoridades competentes (artículo 9), sus funciones (artículo 10), los equipos de respuesta a incidentes de seguridad informática de referencia (artículo 11), los Requisitos y funciones de los CSIRT de referencia (artículo 12) y el punto de contacto único (artículo 13).

En cuanto a las **autoridades competentes** en materia de seguridad (artículo 9) se establece lo siguiente:

a) **Para los operadores de servicios esenciales:**

- En el caso de que éstos sean, además, designados como operadores críticos conforme a la Ley 8/2011: la Secretaría de Estado de Seguridad, del Ministerio del Interior, a través del Centro Nacional de Protección de Infraestructuras y Ciberseguridad (CNPIC).
- En el caso de que no sean operadores críticos: la autoridad sectorial correspondiente por razón de la materia, según se determine reglamentariamente.

b) **Para los proveedores de servicios digitales:** la Secretaría de Estado para el Avance Digital, del Ministerio de Economía y Empresa.

c) **Para los operadores de servicios esenciales y proveedores de servicios digitales que no siendo operadores críticos se encuentren comprendidos en el ámbito de aplicación de la Ley 40/2015**, de 1 de octubre, de Régimen Jurídico del Sector Público: el Ministerio de Defensa, a través del Centro Criptológico Nacional.

El artículo 11 del Real Decreto-ley recoge los tres **CSIRT de referencia** que se coordinarán entre sí y con el resto de equipos nacionales e internacionales en la respuesta a incidentes y gestión de riesgos. **Para el Sector público, el CSIRT de referencia es el CCN-CERT**, del Centro Criptológico Nacional. Además, se señala que *“en los supuestos de especial gravedad que reglamentariamente se determinen y que requieran un nivel de coordinación superior al necesario en situaciones ordinarias, el CCN-CERT ejercerá la coordinación nacional de la respuesta técnica de los CSIRT”*. Los otros dos CSIRT son el INCIBE-CERT para la comunidad que no pertenezca al CCN-CERT, ciudadanos y entidades de derecho privado (operado conjuntamente por el INCIBE y el CNPIC en la gestión de los incidentes que afecten a los operadores críticos) y el ESPDEF-CERT, del Mando Conjunto de Ciberdefensa, que cooperará con los otros dos CSIRT en aquellas situaciones que éstos requieran en apoyo de los operadores de servicios esenciales y, necesariamente, en aquellos que tengan incidencia en la Defensa Nacional.

En relación con las obligaciones de seguridad de los operadores de servicios esenciales y de los proveedores de servicios digitales (artículo 16) se establece que los operadores de servicios esenciales y los proveedores de servicios digitales deberán adoptar medidas técnicas y de organización, adecuadas y proporcionadas, para gestionar los riesgos

En el artículo 19 se establece la **obligación de los operadores de servicios esenciales y de los proveedores de servicios digitales de notificar** a la autoridad competente, a través del correspondiente CSIRT de referencia, **los incidentes** que puedan tener efectos perturbadores significativos en dichos servicios. Se incluye la posibilidad de notificar sucesos o incidencias que puedan afectar a las redes y sistemas de información empleados para la prestación de los servicios esenciales, pero que aún no hayan tenido un efecto adverso real sobre aquéllos.

También señala que las autoridades competentes y los CSIRT de referencia utilizarán una plataforma común para facilitar y automatizar los procesos de notificación, comunicación e información sobre incidentes (a modo de las funcionalidades que ofrece la solución LUCIA del CCN-CERT), que se concreta en la Plataforma Nacional de Notificación y Seguimiento de Ciberincidentes.

Se contempla en el artículo 20 la protección de la entidad notificante y de los empleados y el personal que notifique sobre dichos incidentes de forma que *“no podrán sufrir consecuencias adversas en su puesto de trabajo o con la empresa, salvo en los supuestos en que se acredite mala fe en su actuación”*.

Los operadores de servicios esenciales y los proveedores de servicios digitales tienen la obligación de resolver los incidentes de seguridad que les afecten, y de solicitar ayuda especializada, incluida la del CSIRT de referencia, cuando no puedan resolver por sí mismos los incidentes (artículo 28).

El Real Decreto-ley incluye, en su artículo 39, un régimen de sanciones que puede ir hasta 100.000 euros para las infracciones leves, hasta 500.000 euros para las infracciones graves y hasta un millón de euros para las muy graves. No obstante, se establecen condiciones para no iniciar el procedimiento sancionador en favor de que se acredite la adopción de las medidas correctoras pertinentes.

Se establecen las condiciones de información al público o a terceros y se contempla la notificación voluntaria de incidentes para los que no se establezca la obligación de notificación.

Se tienen presente las obligaciones sectoriales, en particular, el Esquema Nacional de Seguridad, cuando se tratan tanto las obligaciones de seguridad de los operadores de servicios esenciales y de

los proveedores de servicios digitales, como la obligación de notificar los incidentes que puedan tener efectos perturbadores significativos.

El Real Decreto 43/2021, de 26 de enero, por el que se desarrolla el Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información **desarrolla lo relativo al marco estratégico e institucional de seguridad de las redes y sistemas de información, a la gestión de incidentes de seguridad y al cumplimiento de las obligaciones de seguridad** de los operadores de servicios esenciales y de los proveedores de servicios digitales. Cabe destacar los siguientes aspectos principales:

- Pormenoriza la designación de **autoridades competentes** en materia de seguridad de las redes y sistemas de información.
- Desarrolla los **supuestos de cooperación y coordinación** entre los equipos de respuesta a incidentes de seguridad informática (CSIRT) de referencia, y de estos con las autoridades competentes, que se instrumentan a través de la Plataforma Nacional de Notificación y Seguimiento de Ciberincidentes.
- Desarrolla las **funciones de enlace de la figura del punto de contacto único** para garantizar la cooperación transfronteriza con las autoridades competentes de otros Estados miembros de la Unión Europea, así como con el grupo de cooperación y la red de CSIRT.
- Establece la figura del **responsable de la seguridad de la información** que ejercerá las funciones de punto de contacto y coordinación técnica con la autoridad competente y CSIRT de referencia que le corresponda.
- Desarrolla las previsiones relativas a las **medidas para el cumplimiento de las obligaciones de seguridad** de forma que los operadores de servicios esenciales y los proveedores de servicios digitales deberán adoptar las medidas técnicas y de organización adecuadas y proporcionadas para gestionar los riesgos que afecten a la seguridad de las redes y sistemas de información utilizados para la prestación de sus servicios.

Los operadores de servicios esenciales deberán aprobar **políticas de seguridad** que contemplen los siguientes aspectos: Análisis y gestión de riesgos; Gestión de riesgos de terceros o proveedores; Catálogo de medidas de seguridad, organizativas, tecnológicas y físicas; Gestión del personal y profesionalidad; Adquisición de productos o servicios de seguridad; Detección y gestión de incidentes; Planes de recuperación y aseguramiento de la continuidad de las operaciones; Mejora continua; Interconexión de sistemas; y Registro de la actividad de los usuarios.

Las medidas de seguridad habrán de concretarse en una **declaración de aplicabilidad** de medidas de seguridad suscrita por el responsable de seguridad de la información del operador, cuyas funciones también se desarrollan en este real decreto. Las medidas de seguridad **tomarán como referencia las recogidas en el anexo II del Esquema Nacional de Seguridad** en el ámbito de la Administración Electrónica, en la medida en que sean aplicables, y se basarán, cuando sea posible, en otros esquemas nacionales de seguridad existentes.

- Desarrolla las **obligaciones de notificación** por parte de los operadores de servicios esenciales de los incidentes que puedan tener efectos perturbadores significativos en dichos servicios, así como de los incidentes que puedan afectar a las redes y sistemas de información empleados para la prestación de los servicios esenciales aun cuando no hayan tenido un efecto adverso real sobre aquellos, por referencia a los niveles de impacto y peligrosidad, según sea el caso, previstos en la Instrucción nacional de notificación y gestión de ciberincidentes incluida en anexo en la disposición.
- Articula el **procedimiento de notificación de incidentes** a través de la **Plataforma Nacional de Notificación y Seguimiento de Ciberincidentes**, a fin de permitir el intercambio de información entre los operadores de servicios esenciales y proveedores de servicios digitales, las autoridades competentes y los CSIRT de referencia, garantizando la confidencialidad, integridad y disponibilidad de la información.
- Desarrolla la **obligación de colaboración de los operadores de servicios esenciales y los proveedores de servicios digitales con las autoridades competentes**, que podrán requerir, asimismo, la colaboración de los CSIRT de referencia para el ejercicio de su función de supervisión.

- Recoge el régimen jurídico aplicable al Banco de España teniendo en cuenta su especial configuración jurídica como entidad de Derecho público con personalidad jurídica propia y plena capacidad pública y privada.

2. EL ESQUEMA NACIONAL DE SEGURIDAD

2.1. La seguridad para la administración digital

La transformación digital agudiza la dependencia de las tecnologías de la información. El Sector Público de España, particularmente la Administración, no es ajeno a esta transformación digital inevitable e ineludible. La transformación digital ha de ir acompañada de medidas organizativas y técnicas de seguridad proporcionadas a los riesgos. La información y los servicios están sometidos a los riesgos provenientes de las acciones malintencionadas o ilícitas, los errores o fallos y los accidentes o desastres.

Las entidades del Sector Público, junto con sus proveedores de soluciones y prestadores de servicios, por la naturaleza de la información que manejan y de los servicios que prestan, están particularmente expuestas a un crecimiento en número, alcance y severidad de los ciberataques y, especialmente, de aquellos orientados a la información, con sustracción con o sin revelación de la misma, alteración (incluyendo el fraude por inserción de documentos falsos) o destrucción (incluyendo el cifrado irrecuperable de datos y documentos); así como de aquellos orientados a los servicios, con quiebra en su disponibilidad y en el derecho de acceso a la información. Además, buena parte de los sistemas de información de la Administración, la información contenida en ellos y los servicios que prestan, constituyen por acumulación activos estratégicos y, como tales, están sometidos a las ciberamenazas, de carácter malintencionado o ilícito (así como también a errores o fallos y accidentes o desastres).

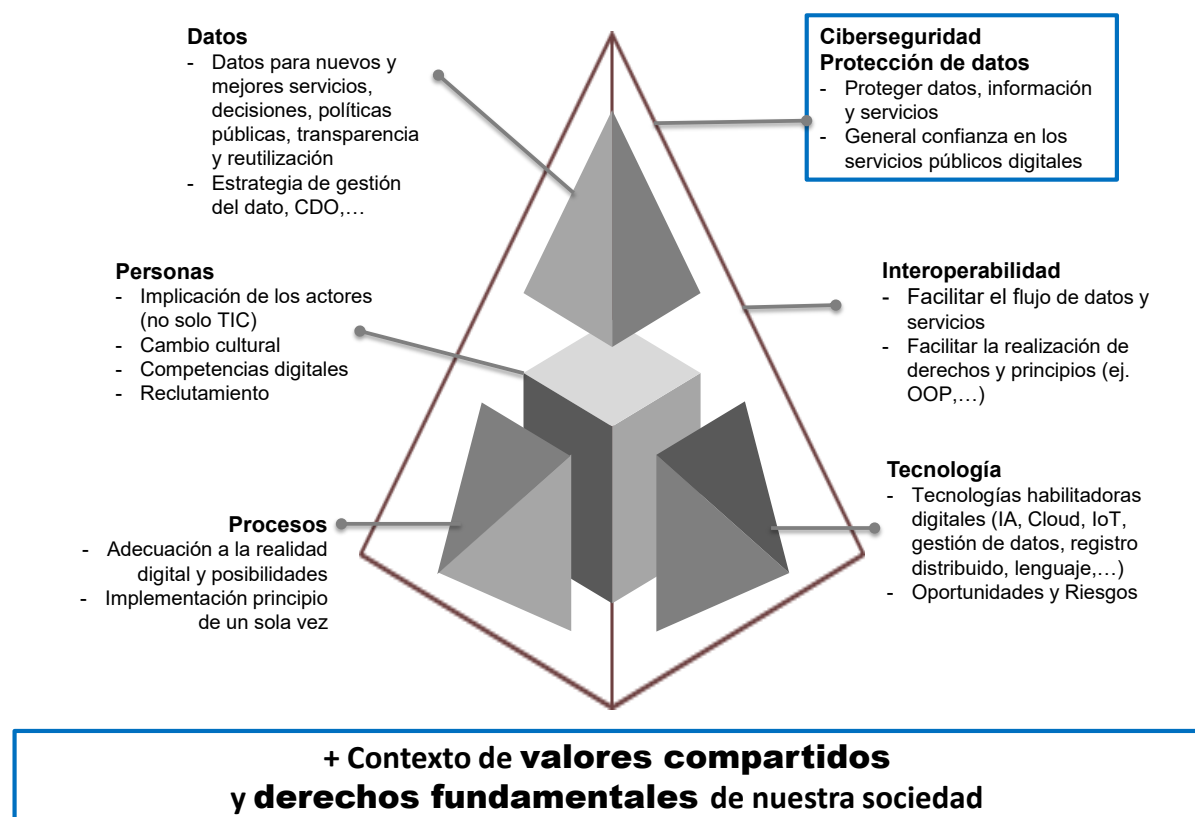
La materialización de los ciberataques tiene impacto en el ejercicio de derechos y libertades, así como en el cumplimiento de deberes; en el normal desenvolvimiento de la sociedad, instituciones, empresas y ciudadanía; en el esfuerzo en recursos para la recuperación ante incidentes; y en la reputación.

Los ciudadanos esperan que los servicios digitales se presten en condiciones de confianza y seguridad, equivalentes a las que encuentran cuando se acercan personalmente a las oficinas de la Administración. Además, buena parte de la información y los servicios manejados por la Administración constituyen, por acumulación, activos nacionales estratégicos.

En este contexto, **se entiende por seguridad** la capacidad de las redes o de los sistemas de información de resistir, con un determinado nivel de confianza, toda acción que comprometa la disponibilidad, autenticidad, integridad o confidencialidad de los datos almacenados, transmitidos o tratados, o los servicios correspondientes ofrecidos por tales redes y sistemas de información o accesibles a través de ellos, según la definición recogida en la «Directiva (UE) 2016/1148 Del Parlamento Europeo y del Consejo, de 6 de julio de 2016, relativa a las medidas destinadas a garantizar un elevado nivel común de seguridad de las redes y sistemas de información en la Unión». Entendiendo también que en ‘toda acción’ entrarían las acciones ilícitas o malintencionadas, los errores o fallos y los accidentes.

Por otra parte, **se entiende por ciberseguridad** la protección de las redes y sistemas de información, sus usuarios y otras personas frente a las ciberamenazas, siendo éstas las amenazas a los sistemas y servicios presentes en el ciberespacio o alcanzables a través de éste.

Este proceso de transformación digital, en general, y de aplicación de la necesaria seguridad se asienta en tres pilares que desarrollaremos a continuación en relación con el Esquema Nacional de Seguridad: el marco legal, la cooperación y gobernanza, junto con las capacidades, servicios y soluciones de (ciber)seguridad.



Fuente: Miguel A. Amutio. Parte de la pirámide de Gartner intervenida para reubicar a las personas en el centro, añadiéndose las leyendas y el contexto de derechos y valores compartidos, con apoyo de edición del equipo de CCN.

Figura 5. La ciberseguridad como elemento transversal en la transformación digital (Fuente: Miguel A. Amutio).

El **marco legal** aporta la seguridad jurídica, principio que preside el esfuerzo de desarrollo de la legislación y normativa en materia de administración digital; **la cooperación y la gobernanza** son imprescindibles en un escenario en el que intervienen múltiples actores, de diferentes administraciones, y en el que, por un lado, hay que asegurar la “*cooperación para proporcionar información administrativa clara, actualizada e inequívoca*” y, por otro lado, hay que tener presente que dicho escenario es, además, altamente interconectado, de forma que la seguridad debe alcanzar una cierta homogeneidad o armonización para asentar la confianza en el flujo de información y servicios y para evitar que la falta de seguridad perjudique a terceros; mientras que las **capacidades, servicios y soluciones** aportan la realidad práctica.

La seguridad no es una cuestión exclusivamente técnica, sino que afecta a todas las personas que utilizan los medios electrónicos que la organización pone a su disposición para el desarrollo de su actividad profesional y a sus responsables jerárquicos, responsables a la postre de la información manejada y de los servicios prestados.

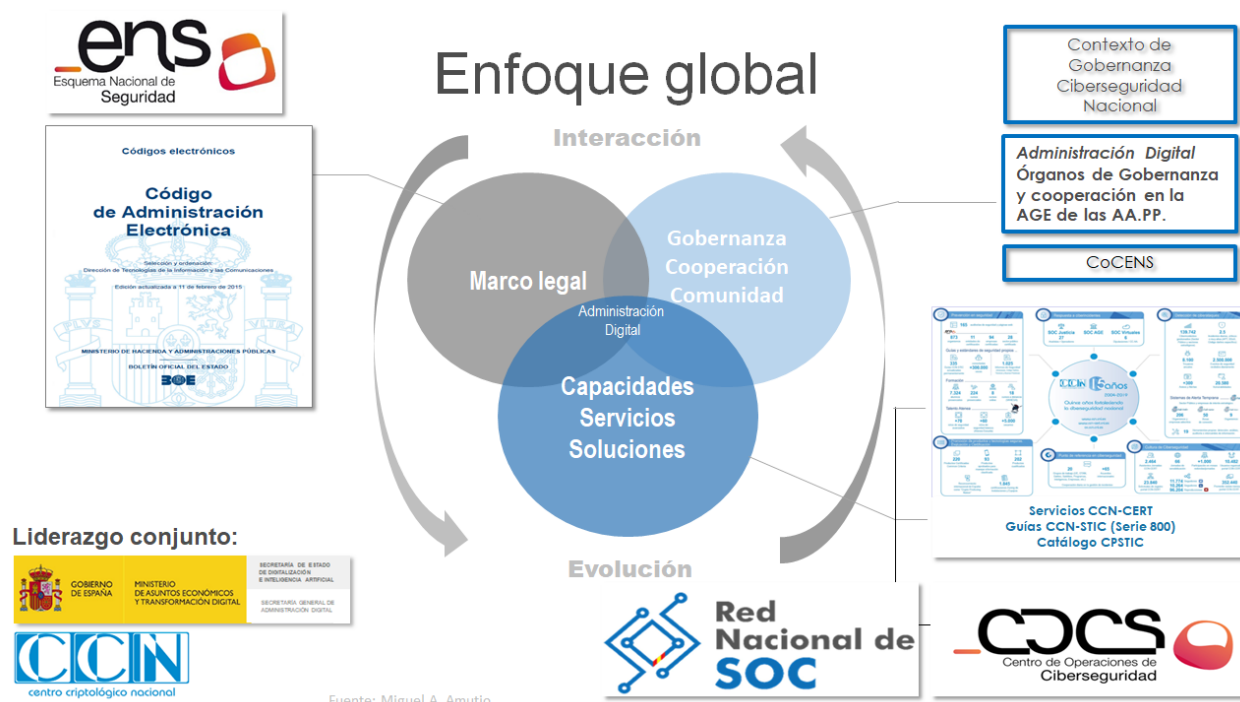


Figura 6. Pilares de la transformación digital y de la necesaria (ciber) seguridad (Fuente: Miguel A. Amutio).

2.2. El Esquema Nacional de Seguridad

El Esquema Nacional de Seguridad se creó en la «Ley 11/2007, de 22 de junio, de acceso electrónico de los ciudadanos a los Servicios Públicos», disposición derogada, y se materializó mediante el **«Real Decreto 3/2010, de 8 de enero, por el que se regula el Esquema Nacional de Seguridad (ENS) en el ámbito de la Administración Electrónica»**. En aquel momento pareció ineludible acompañar el impulso de la administración electrónica con las adecuadas medidas que aportaran seguridad a la información manejada y los servicios prestados.

El ENS que se materializó en el real decreto de 2010 fue elaborado con la participación de todas las administraciones públicas a través de los órganos colegiados vigentes en aquel momento que permitieron la participación de la Administración General del Estado por un lado, así como de las demás administraciones públicas por otro lado –Comunidades Autónomas, Entidades Locales a través de la Federación Española de Municipios y Provincias (FEMP) y Universidades Públicas a través de la Conferencia de Rectores de Universidades Españolas (CRUE)- más el ámbito de la Justicia (que cuenta con el EJIS – Esquema Judicial de Interoperabilidad y Seguridad); más aportaciones del Sector Privado a través de las asociaciones principales de la Industria del Sector TIC que contribuyeron al perfeccionamiento del proyecto y que partían de una valoración muy positiva del mismo al vislumbrar el potencial que ofrecía la armonización de los requisitos de un gran sector y el rigor con el que se afrontaba. En 2010 se trataba del Consejo Superior de Administración Electrónica para la Administración General del Estado y del Comité Sectorial de Administración Electrónica bajo la Conferencia Sectorial de Administración Pública.

Posteriormente, el ENS fue **modificado por el Real Decreto 951/2015**. Esta modificación se realizó a la luz de la experiencia obtenida hasta aquel momento en la implantación del ENS; de los comentarios recibidos por diversas vías, formales e informales; de los trabajos relativos al seguimiento del progreso de la adecuación al ENS realizados en 2013 y 2014 y de los resultados del informe del estado de la seguridad previsto en su artículo 35; de la evolución de la tecnología y las ciberamenazas; y de la evolución del contexto regulatorio internacional y europeo, especialmente por razón del «Reglamento nº 910/2014 del Parlamento Europeo y del Consejo, de 23 de julio de 2014, relativo a la identificación electrónica y los servicios de confianza para las transacciones electrónicas en el mercado interior y por el que se deroga la Directiva 1999/93/CE».

Dicha modificación, principalmente y de forma resumida, clarificó el papel del Centro Criptológico Nacional y del CCN-CERT, creó la figura de las instrucciones técnicas de seguridad y apuntó una primera lista; explicitó en el cuerpo de la norma la Declaración de Aplicabilidad; introdujo las nociones de la gestión continuada de la seguridad y de las medidas compensatorias; modificó una colección de medidas de seguridad del Anexo II, particularmente las afectadas por el citado Reglamento nº 910/2014; concretó el Anexo III, referido a la auditoría de seguridad; modificó el Glosario de términos recogido en el Anexo IV; y modificó la redacción de la cláusula administrativa particular contenida en el Anexo V.

Ese mismo año, por una parte, la «Ley 39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas» recogió entre los **derechos** de las personas en sus relaciones con las Administraciones Públicas, en el artículo 13, letra h), el relativo *“a la protección de datos de carácter personal, y en particular a la **seguridad y confidencialidad de los datos** que figuren en los ficheros, sistemas y aplicaciones de las Administraciones Públicas”*. Realizó, además, diversas menciones al cumplimiento de las garantías y medidas de seguridad al referirse a registros, archivo de documentos y copias.

Y, por otra parte, la «Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público» incluyó a la seguridad entre los **principios de actuación** de las administraciones públicas, así como la garantía de la protección de los datos personales, al señalar en su artículo 3 los principios generales relativos a las relaciones de las administraciones por medios electrónicos. Además, **recogió en su artículo 156 el Esquema Nacional de Seguridad** que *“tiene por objeto establecer la política de seguridad en la utilización de medios electrónicos en el ámbito de la presente Ley, y está constituido por los principios básicos y requisitos mínimos que garanticen adecuadamente la seguridad de la información tratada”*. También incluyó esta ley referencias concretas a la seguridad en apartados relativos a la sede electrónica, el archivo electrónico de documentos, los intercambios electrónicos en entornos cerrados de comunicaciones y las transmisiones de datos entre Administraciones Públicas.

Adicionalmente a lo anterior, la Disposición Adicional Primera de la «Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales» indicó en su apartado primero que *“el Esquema Nacional de Seguridad incluirá las medidas que deban implantarse en caso de tratamiento de datos de carácter personal, para evitar su pérdida, alteración o acceso no autorizado, adaptando los criterios de determinación del riesgo en el tratamiento de los datos a lo establecido en el artículo 32 del Reglamento (UE) 2016/679”*. También incluyó un apartado segundo que apunta dos cuestiones también relevantes. La primera es que *“Los responsables enumerados en el artículo 77.1 de esta ley orgánica deberán aplicar a los tratamientos de datos personales las medidas de seguridad que correspondan de las previstas en el Esquema Nacional de Seguridad,…”*; y la segunda es que *“En los casos en los que un tercero preste un servicio en régimen de concesión, encomienda de gestión o contrato, las medidas de seguridad se corresponderán con las de la Administración pública de origen y se ajustarán al Esquema Nacional de Seguridad”*.

Así mismo, en el «Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información» se recogió el papel del ENS en el ámbito sectorial que le corresponde, en relación, por una parte, con las obligaciones de seguridad de los operadores de servicios esenciales y de los proveedores de servicios digitales y, por otra parte, con la obligación de notificar incidentes. Después, el «Real Decreto 43/2021, de 26 de enero, por el que se desarrolla el Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información», en su artículo 6 ‘Medidas para el cumplimiento de las obligaciones de seguridad’ establece en su apartado 5 que *“Las medidas a las que se refieren los apartados anteriores tomarán como referencia las recogidas en el anexo II del Real Decreto 3/2010, de 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica, en la medida en que sean aplicables, y se basarán, cuando sea posible, en otros esquemas nacionales de seguridad existentes”*.

Además, la «Estrategia Nacional de Ciberseguridad 2019», en su línea de acción *“2. Garantizar la seguridad y resiliencia de los activos estratégicos para España”*, incluyó la medida *“3. Asegurar la plena implantación del Esquema Nacional de Seguridad…”*.

Desde su aparición en 2010, el ENS se ha desarrollado para ofrecer un planteamiento común de principios básicos, requisitos mínimos, medidas de seguridad, así como de mecanismos de conformidad en colaboración con la Entidad Nacional de Acreditación (ENAC), y de monitorización, a través del informe INES sobre el estado de la seguridad, junto con las instrucciones técnicas de

seguridad, las guías CCN-STIC y las soluciones del CCN-CERT, todo ello adaptado al cometido del sector público y de sus proveedores.



Esfuerzo colectivo, multidisciplinar, sostenido en el tiempo + liderazgo conjunto de

Figura 7. Desarrollo del Esquema Nacional de Seguridad (Fuente: Miguel A. Amutio)

A lo largo de estos años y, particularmente, desde la actualización en 2015, se ha acelerado la transformación digital que ha conducido a una mayor hiperconectividad y al trasvase de todo tipo de actividades al mundo digital (trabajo, educación, ocio, consumo, relaciones sociales) contribuyendo a un aumento notable de la superficie de exposición al riesgo; se han intensificado los ciberataques y las ciberamenazas; se ha incrementado la experiencia acumulada a lo largo de estos años en la implantación del ENS; se ha producido una evolución y especialización de los agentes afectados directa o indirectamente; se ha implantado la certificación de la conformidad con el ENS desde 2016 (que proporciona un amplio conocimiento a partir de las evaluaciones y certificaciones); y se ha constituido el Consejo de Certificación del ENS (CoCENS) en 2018.

Por estas razones **ha sido necesaria una nueva actualización del ENS publicada en 2022 mediante el «Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad»**. Esta actualización se ha abordado con la participación de los órganos colegiados que entienden en materia de tecnologías de la información y las comunicaciones, así como de administración electrónica; en la Administración General del Estado a través del Comité de Dirección de las Tecnologías de Información y las Comunicaciones (CDTIC), establecido en el «Real Decreto 806/2014, de 19 de septiembre, sobre organización e instrumentos operativos de las tecnologías de la información y las comunicaciones en la Administración General del Estado y sus Organismos Públicos», y para las demás administraciones públicas a través de la Comisión Sectorial de Administración Electrónica establecida en la disposición adicional novena de la Ley 40/2015. Todo ello junto con el correspondiente trámite de audiencia e información pública y resto de informes preceptivos.

La actualización del ENS ha perseguido tres grandes objetivos:

- Primero, alinear el ENS con el marco normativo de referencia a la fecha para facilitar la seguridad en la administración digital;
- Segundo, introducir la capacidad de ajustar los requisitos del ENS a necesidades específicas de determinados colectivos de entidades, o de determinados ámbitos tecnológicos, dando respuesta a las nuevas demandas provenientes de unas organizaciones más maduras y unos ciudadanos más exigentes con sus derechos, para una aplicación más eficaz y eficiente del ENS, sin menoscabo de la protección perseguida y exigible.
- Y, tercero, actualizar los principios básicos, los requisitos mínimos y las medidas de seguridad para facilitar la respuesta a las nuevas tendencias y necesidades de ciberseguridad, de modo que el ENS siga garantizando la protección de los sistemas de información en las entidades de su ámbito de aplicación, reduciendo vulnerabilidades y promoviendo la vigilancia continua.

Entre las **grandes novedades de la actualización del ENS** figuran:

- Se ha revisado y clarificado el **ámbito de aplicación**, en primer lugar, para que ambos sectores, público y privado (proveedores o suministradores tecnológicos de las entidades del sector público), sean conscientes de lo que les es exigible, en beneficio último de la ciberseguridad pública y de los derechos de los ciudadanos; en segundo lugar, para extender su aplicación a los sistemas que manejan o tratan información clasificada, sin perjuicio de que pudiera resultar necesario complementar las medidas de seguridad previstas en el ENS con otras específicas para tales sistemas.
- Se ha realizado la clarificación, precisión, homogeneización, simplificación, o actualización de distintos aspectos del texto, así como la eliminación de aspectos no necesarios o excesivos (un capítulo de ‘Comunicaciones electrónicas’, con tres artículos, ya superado por las leyes 39/2015, de 1 de octubre y 40/2015, de 1 de octubre, y su desarrollo reglamentario).
- Se ha añadido la figura de los **perfiles de cumplimiento específicos** que introducen la capacidad de ajustar los requisitos del ENS a necesidades específicas, mediante la definición de un conjunto de medidas de seguridad que resulten de aplicación a una entidad o sector de actividad concreta, y para una determinada categoría de seguridad (por ej. para Entidades Locales, Universidades, servicios en la nube, etc.).
- Se han revisado los **principios básicos**: el principio antes denominado ‘prevención, reacción y recuperación’ pasa a denominarse ‘prevención, detección, respuesta y conservación’. Se introduce el principio de ‘vigilancia continua’ para permitir la detección de actividades o comportamientos anómalos y su oportuna respuesta. Se clarifica la redacción del principio ‘responsabilidades diferenciadas’ para precisar los aspectos relativos al responsable de la seguridad y al responsable del sistema.
- Se han explicitado cuáles son los elementos principales que ha de incluir la **política de seguridad** y quiénes han de disponer de la citada política.
- Se ha clarificado el papel de las **figuras principales en la aplicación del ENS**: responsable de la información, responsable del servicio, responsable del sistema, responsable de la seguridad. Además, en el caso de los servicios externalizados es necesario contar con un punto de contacto.
- En relación con el **cumplimiento de los requisitos mínimos** se ha dejado abierta la posibilidad de que, una vez satisfechos los mínimos exigibles, el responsable de seguridad pueda, en función de los resultados del análisis de riesgos, a la luz del estado del arte de la tecnología, de la naturaleza de la información tratada y de los servicios prestados y de los riesgos identificados, ampliar las medidas de protección con los **refuerzos** que se identifican para las mismas.
- Se ha perfeccionado el **tratamiento de los incidentes de seguridad** y la clarificación del **papel de los principales actores** interesados en la cuestión.
- Se ha realizado una revisión exhaustiva de las **medidas de seguridad**; y se ha introducido un nuevo sistema de codificación de los requisitos de las medidas de seguridad y de sus refuerzos para facilitar su aplicación y la conformidad.
- La disposición transitoria única, sobre adecuación de sistemas, contempla un **plazo de veinticuatro meses para la adecuación al ENS** de los sistemas preexistentes a su entrada en vigor, circunstancia que se manifestará con la exhibición del correspondiente distintivo de conformidad derivados de declaraciones o certificaciones. La disposición tiene presente que habrá sistemas que ya contarán con los correspondientes distintivos de conformidad y que, según la práctica habitual con este tipo de distintivos, podrán mantener su vigencia procediendo a su renovación a medida que llegue su caducidad antes de que llegue el citado plazo. Los nuevos sistemas de información aplicarán lo establecido en el Real Decreto 311/2022 desde su concepción.

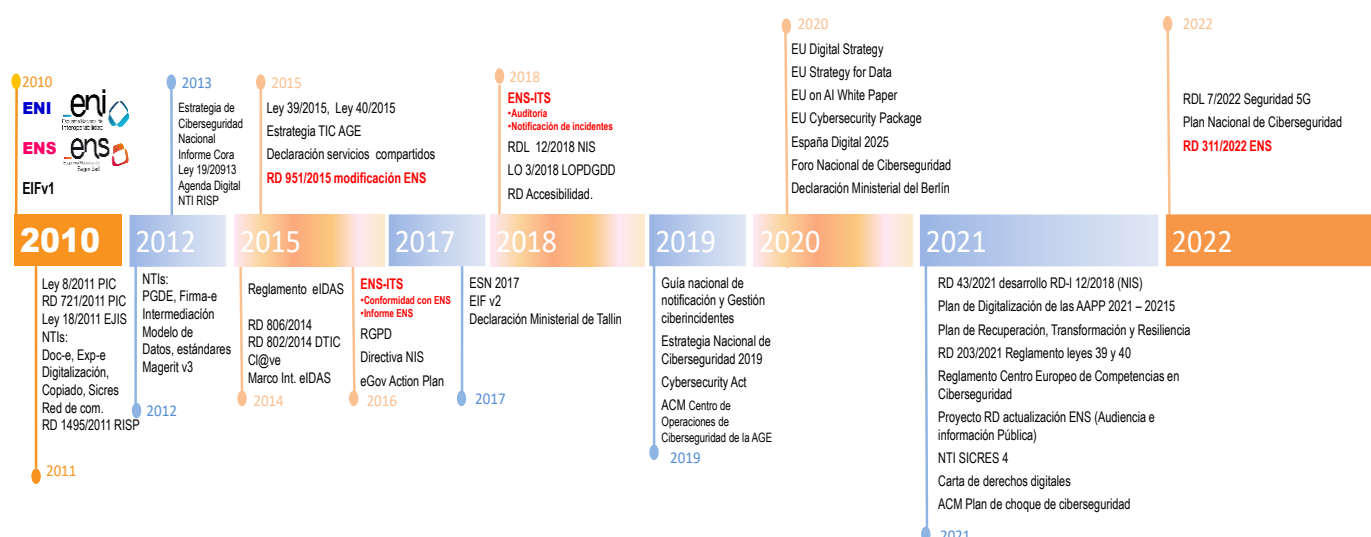


Figura 8. Actuaciones en materia de (ciber)seguridad a lo largo del tiempo. (Fuente: Miguel A. Amutio)

Finalmente, el Esquema Nacional de Seguridad se ha de entender en un contexto más general bien por los antecedentes bien por su ubicación en un escenario más global.

Entre los antecedentes cabe citar los «Criterios de seguridad, normalización y conservación de las aplicaciones utilizadas para el ejercicio de potestades», la firma del Arreglo sobre el Reconocimiento de los Certificados de Criterios Comunes en el campo de la Seguridad de la Tecnología de la Información, la creación del Centro Criptológico Nacional y del Organismo de Certificación, el lanzamiento del CCN-CERT, entre otros.

En el escenario más global entran en juego también la protección de las infraestructuras críticas, la protección de los servicios esenciales o la gobernanza de la ciberseguridad con una perspectiva nacional.

2.3. Objetivos del ENS

El Esquema Nacional de Seguridad es un instrumento que persigue fundamentar la confianza en que los sistemas de información prestarán sus servicios y custodiarán la información de acuerdo con sus especificaciones funcionales, sin interrupciones o modificaciones fuera de control y sin que la información pueda llegar al conocimiento de personas no autorizadas. Sus **objetivos principales** son los siguientes:

- **Crear las condiciones necesarias de seguridad en el uso de los medios electrónicos**, a través de medidas para garantizar la seguridad de los sistemas, los datos, las comunicaciones, y los servicios electrónicos, que permita el ejercicio de derechos y el cumplimiento de deberes a través de estos medios.
- **Promover la gestión continuada de la seguridad**, al margen de impulsos puntuales, o de su ausencia.
- **Promover la prevención detección y respuesta**, para una mejor resiliencia en el escenario de ciberamenazas y ciberataques.
- **Promover un tratamiento homogéneo de la seguridad** que facilite la cooperación en la prestación de servicios públicos digitales cuando participan diversas entidades. Esto supone proporcionar los elementos comunes que han de guiar la actuación de las entidades del Sector Público y sus proveedores en materia de seguridad de las tecnologías de la información; también aportar un lenguaje común para facilitar la interacción, así como la comunicación de los requisitos de seguridad de la información a la Industria.
- **Servir de modelo de buenas prácticas**, en línea con lo apuntado en las recomendaciones de la OCDE «*Digital Security Risk Management for Economic and Social Prosperity - OECD Recommendation and Companion Document*».

En el ENS la seguridad se concibe como una actividad integral, en la que no caben actuaciones puntuales o tratamientos coyunturales, debido a que la debilidad de un sistema la determina su punto más frágil y, a menudo, este punto es la coordinación entre medidas individualmente adecuadas, pero deficientemente ensambladas.

2.4. Estructura y contenido del ENS

Los **elementos principales** del «Real Decreto 311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad» son los siguientes:

- Las disposiciones generales, **objeto, ámbito de aplicación, sistemas de información que traten datos personales y definiciones** (artículos 1 a 4).
- Los **principios básicos** a considerar en las decisiones en materia de seguridad (artículos 5 a 11).
- Los **requisitos mínimos** que permitan una protección adecuada de la información (artículos 12 a 27).
- El mecanismo para lograr el cumplimiento de los principios básicos y de los requisitos mínimos mediante **la adopción de medidas de seguridad proporcionadas** a la naturaleza de la información y los servicios a proteger (artículos 28, 40, 41, Anexo I y Anexo II).
- El **uso de productos certificados** y el papel del Organismo de Certificación OC-CCN (artículo 19 y Anexo II).
- El uso de **infraestructuras y servicios comunes** (artículo 29).
- Los **perfiles de cumplimiento específicos** (artículo 30).
- La **auditoría de la seguridad** que verifique el cumplimiento del ENS (artículo 31 y Anexo III).
- El **informe del estado de la seguridad** (artículo 32).
- La **respuesta ante incidentes de seguridad** (artículos 33 y 34).
- La **conformidad con el ENS** (artículos 35 a 38).
- La **actualización permanente** (artículo 39).
- La **categorización de los sistemas de información** (artículos 40 y 41).
- La **formación** (disposición adicional primera).
- Las **instrucciones técnicas de seguridad** (disposición adicional segunda).
- Las **guías de seguridad** (disposición adicional segunda).
- Respeto del principio de «**no causar un perjuicio significativo**» al medioambiente (disposición adicional tercera).
- **Adecuación de sistemas** (disposición transitoria única).
- **Derogación normativa** (Disposición derogatoria única): queda derogado el Real Decreto 3/2010, de 8 de enero.

2.5. Ámbito de aplicación del ENS

El Esquema Nacional de Seguridad es de aplicación (artículo 2):

- **A todo el sector público**, en los términos en que este se define por el artículo 2 de la Ley 40/2015, de 1 de octubre, y de acuerdo con lo previsto en el artículo 156.2 de la misma.
- **A los sistemas que tratan información clasificada**, sin perjuicio de la aplicación de la Ley 9/1968, de 5 de abril, de Secretos Oficiales y otra normativa especial, pudiendo resultar necesario adoptar medidas complementarias de seguridad, específicas para dichos sistemas, derivadas de los compromisos internacionales contraídos por España o de su pertenencia a organismos o foros internacionales.
- **A los sistemas de información de las entidades del sector privado**, incluida la obligación de **contar con la política de seguridad**, cuando, de acuerdo con la normativa aplicable y en

virtud de una relación contractual, **presten servicios o provean soluciones** a las entidades del sector público para el ejercicio por estas de sus competencias y potestades administrativas.

Dicha política de seguridad será aprobada en el caso de estas entidades del sector privado por el órgano que ostente las máximas competencias ejecutivas.

- Además, los **pliegos de prescripciones administrativas o técnicas** de los contratos que celebren las entidades del sector público **contemplarán todos aquellos requisitos necesarios para asegurar la conformidad con el ENS** de los sistemas de información en los que se sustenten los servicios prestados por los contratistas, tales como la presentación de las correspondientes Declaraciones o Certificaciones de Conformidad con el ENS.
- **Esta cautela se extenderá también a la cadena de suministro** de dichos contratistas, en la medida que sea necesario y de acuerdo con los resultados del correspondiente análisis de riesgos.

Adicionalmente, el ámbito de aplicación incluye la precisión de que cuando las entidades del sector público lleven a cabo la instalación, despliegue y explotación de **redes 5G o la prestación de servicios 5G**, además de las previsiones de este real decreto será de aplicación lo establecido en el Real Decreto-ley 7/2022, de 29 de marzo, sobre requisitos para garantizar la seguridad de las redes y servicios de comunicaciones electrónicas de quinta generación, en particular, lo dispuesto en su artículo 17 relativo a la gestión de seguridad por las administraciones públicas, así como su normativa de desarrollo.

Por otra parte, dado que el ENS es de aplicación a los **sistemas que manejan información clasificada**, conviene recordar aquí, a título ilustrativo, que, según la «Ley 9/1968, de 5 de abril, sobre secretos oficiales», la información puede ser clasificada con el grado de SECRETO o RESERVADO, siendo el primero de ellos superior al segundo y, por tanto, con unos requisitos de protección más estrictos. Posteriormente, el Acuerdo de Consejo de Ministros, de 28 de noviembre de 1986, amplió esta protección a toda información derivada de los tratados y acuerdos internacionales válidamente celebrados por España que, una vez publicados oficialmente, se incorporan al ordenamiento jurídico español, en virtud de lo dispuesto en el artículo 96 de la Constitución. En consecuencia, tras la adhesión de España al Tratado del Atlántico Norte y a la Unión Europea y la adopción de las normas de seguridad de ambas organizaciones, se ampliaron los grados de clasificación de la información a CONFIDENCIAL y DIFUSIÓN LIMITADA, en orden decreciente y, a su vez inferiores a los ya existentes de SECRETO y RESERVADO, a los que se añadiría finalmente SIN CLASIFICAR. Para ampliar sobre esta cuestión véanse la guía «CCN-STIC-001 Información clasificada en la Administración» y el documento «Normas de la Autoridad Nacional para la Protección de la Información Clasificada».

Además, en el artículo 3 se recoge que **cuando un sistema al que afecte el ENS trate datos personales** le será de aplicación lo dispuesto en la legislación correspondiente (el Reglamento General de Protección de Datos y la Ley Orgánica 3/2018, de 5 de diciembre, de Protección de Datos Personales y garantía de los derechos digitales, la Ley Orgánica 7/2021, de 26 de mayo, de protección de datos personales tratados para fines de prevención, detección, investigación y enjuiciamiento de infracciones penales y de ejecución de sanciones penales, el resto de normativa de aplicación, así como los criterios que se establezcan por la Agencia Española de Protección de Datos).

2.6. Los principios básicos

Los principios básicos, recogidos en los artículos 5 a 11, constituyen fundamentos que deben regir toda acción orientada a asegurar la información y los servicios, de forma muy resumida, pues debe irse al texto del Real Decreto 311/2022 para los detalles completos:

- **La seguridad como un proceso integral** (artículo 6): la seguridad se entiende como un proceso integral, constituido por todos los elementos técnicos, humanos, materiales y organizativos relacionados. De forma que *“se prestará la máxima atención a la concienciación de las personas que intervienen en el proceso y la de los responsables jerárquicos, para evitar que, la ignorancia, la falta de organización y de coordinación o de instrucciones adecuadas, constituyan fuentes de riesgo para la seguridad”*.
- **Gestión de la seguridad basada en los riesgos** (artículo 7): el análisis y la gestión de los riesgos es parte esencial del proceso de seguridad y permitirá el mantenimiento de un entorno controlado, minimizando los riesgos a niveles aceptables.
- **Prevención, detección, respuesta y conservación** (artículo 8): la seguridad del sistema debe contemplar las acciones relativas a los aspectos de prevención, detección y respuesta, al objeto de minimizar sus vulnerabilidades y lograr que las amenazas sobre el mismo no se materialicen o que, en el caso de hacerlo, no afecten gravemente a la información que maneja o a los servicios que presta. Se introducen precisiones sobre la prevención, detección y respuesta en los apartados segundo a cuarto, y se añade en el quinto que, sin merma de los restantes principios básicos y requisitos mínimos establecidos, el sistema de información garantizará la conservación de los datos e información en soporte electrónico.
- **Existencia de líneas de defensa** (artículo 9): el sistema de información ha de disponer de múltiples capas de seguridad de forma que, cuando una de las capas sea comprometida, permitan desarrollar una reacción adecuada frente a los incidentes que no han podido evitarse, minimizar el impacto final sobre el mismo. Las líneas de defensa han de estar constituidas por medidas de naturaleza organizativa, física y lógica.
- **Vigilancia continua y reevaluación periódica** (artículo 10): la vigilancia continua permitirá la detección de actividades o comportamientos anómalos y su oportuna respuesta. La evaluación permanente del estado de la seguridad de los activos permitirá medir su evolución, detectando vulnerabilidades e identificando deficiencias de configuración. Las medidas de seguridad se reevaluarán y actualizarán periódicamente, adecuando su eficacia a la evolución de los riesgos y los sistemas de protección, pudiendo llegar a un replanteamiento de la seguridad, si fuese necesario.
- **Diferenciación de responsabilidades** (artículo 11): en los sistemas de información se diferenciará el responsable de la información, el responsable del servicio, el responsable de la seguridad y el responsable del sistema. La responsabilidad de la seguridad de los sistemas de información estará diferenciada de la responsabilidad sobre la explotación de los sistemas de información concernidos. Y la política de seguridad de la organización detallará las atribuciones de cada responsable y los mecanismos de coordinación y resolución de conflictos. El artículo 13 introduce precisiones sobre estas cuestiones.

2.7. La política de seguridad

El mandato principal del ENS es, sin duda, el establecido en el artículo 12 “Política de seguridad y requisitos mínimos de seguridad”. En este artículo:

- Se explicitan cuáles son los **elementos principales** que ha de incluir la política de seguridad.
- **Quiénes han de disponer de la citada política**, incluyendo cada administración al menos, y cada órgano o entidad con personalidad jurídica propia sin perjuicio de poder quedar incluidos en el ámbito subjetivo de la política de seguridad de la Administración con la que guarden relación de vinculación, dependencia o adscripción.
- Se precisa que, **en el ámbito de la Administración General del Estado**, cada ministerio contará con su política de seguridad, mientras que los organismos públicos o entidades pertenecientes al sector público institucional estatal podrán bien contar con su propia política

de seguridad o, bien quedar comprendidos en el ámbito de la política de seguridad del Departamento con el que mantengan relación de vinculación, dependencia o adscripción.

- También se precisa que **la Secretaría General de Administración Digital** del Ministerio de Asuntos Económicos y Transformación Digital dispondrá de su propia política de seguridad, que será aprobada por la persona titular de la misma.
- Y se apunta que **los municipios** podrán disponer de una política de seguridad común elaborada por la entidad local comarcal o provincial que asuma la responsabilidad de la seguridad de la información de los sistemas municipales.

2.8. Los requisitos mínimos

Los **requisitos mínimos**, tratados en los artículos 12 a 27, son exigencias necesarias para asegurar la información y los servicios, de forma muy resumida, pues debe irse al texto del Real Decreto 311/2022 para los detalles completos:

- **Organización e implantación del proceso de seguridad** (artículo 13): se clarifica el papel de las figuras principales en la aplicación del ENS citadas en el artículo 11: **responsable de la información, responsable del servicio, responsable del sistema, responsable de la seguridad**.

Además, para el caso de los servicios externalizados se establece que es necesario contar con una figura, punto o persona de contacto, que ayude a canalizar y supervisar el cumplimiento de los requisitos de seguridad del servicio que presta, así como la gestión de los posibles incidentes de seguridad razón por la cual se establece que dichos servicios han de contar con un punto de contacto.

En cualquier caso, la responsabilidad última reside en la entidad del sector público destinataria o contratante de los servicios en cuestión que ha de exigir a sus suministradores la debida diligencia en materia de seguridad.

- **Análisis y gestión de los riesgos** (artículo 14): Cada organización que desarrolle e implante sistemas para el tratamiento de la información o la prestación de servicios realizará su propia gestión de riesgos. Las medidas adoptadas para mitigar o suprimir los riesgos deberán estar justificadas y, en todo caso, existirá una proporcionalidad entre ellas y los riesgos.
- **Gestión de personal** (artículo 15): el personal, propio o ajeno, deberá ser formado e informado de sus deberes, obligaciones y responsabilidades en materia de seguridad. Su actuación, que deberá ser supervisada para verificar que se siguen los procedimientos establecidos, aplicará las normas y procedimientos operativos de seguridad aprobados.
- **Profesionalidad** (artículo 16): la seguridad de los sistemas estará atendida, revisada y auditada por personal cualificado, dedicado e instruido en todas las fases de su ciclo de vida. Las entidades en el ámbito de aplicación del ENS exigirán, de manera objetiva y no discriminatoria, que las organizaciones que les presten servicios de seguridad cuenten con profesionales cualificados y con unos niveles idóneos de gestión y madurez en los servicios prestados.
- **Autorización y control de los accesos** (artículo 17): el acceso controlado a los sistemas de información deberá estar limitado a los usuarios, procesos, dispositivos u otros sistemas de información, debidamente autorizados, y exclusivamente a las funciones permitidas.
- **Protección de las instalaciones** (artículo 18): los sistemas de información y su infraestructura de comunicaciones asociada deberán permanecer en áreas controladas y disponer de los mecanismos de acceso adecuados y proporcionales en función del análisis de riesgos, sin perjuicio de lo establecido en la Ley 8/2011, de 28 de abril, por la que se establecen medidas para la protección de las infraestructuras críticas y en su Real Decreto 704/2011 de desarrollo.
- **Adquisición de productos de seguridad y contratación de servicios de seguridad** (artículo 19): en la adquisición de productos de seguridad de las tecnologías de la información y comunicaciones que vayan a ser empleados por las Administraciones públicas se utilizarán, de forma proporcionada a la categoría del sistema y nivel de seguridad

determinados, aquellos que tengan certificada la funcionalidad de seguridad relacionada con el objeto de su adquisición. El Organismo de Certificación del Esquema Nacional de Evaluación y Certificación de Seguridad de las Tecnologías de la Información del Centro Criptológico Nacional determinará los requisitos funcionales de seguridad y de aseguramiento de la certificación; otras certificaciones de seguridad adicionales que se requieran normativamente; el criterio a seguir en los casos en que no existan productos o servicios certificados.

- **Mínimo privilegio** (artículo 20): Los sistemas de información deben diseñarse y configurarse otorgando los mínimos privilegios necesarios para su correcto desempeño, lo que implica que el sistema proporcionará la funcionalidad imprescindible para que la organización alcance sus objetivos competenciales o contractuales; que las funciones de operación, administración y registro de actividad serán las mínimas necesarias y que se eliminarán o desactivarán, mediante el control de la configuración, las funciones que sean innecesarias o inadecuadas al fin que se persigue; y que se aplicarán guías de configuración de seguridad para las diferentes tecnologías, adaptadas a la categorización del sistema, al efecto de eliminar o desactivar las funciones que sean innecesarias o inadecuadas.
- **Integridad y actualización del sistema** (artículo 21): la inclusión de cualquier elemento físico o lógico en el catálogo actualizado de activos del sistema, o su modificación, requerirá autorización formal previa. La evaluación y monitorización permanentes permitirán adecuar el estado de seguridad de los sistemas atendiendo a las deficiencias de configuración, las vulnerabilidades identificadas y las actualizaciones que les afecten, así como la detección temprana de cualquier incidente que tenga lugar sobre los mismos.
- **Protección de la información almacenada y en tránsito** (artículo 22): se prestará especial atención a la información almacenada o en tránsito a través de los equipos o dispositivos portátiles o móviles, los dispositivos periféricos, los soportes de información y las comunicaciones sobre redes abiertas. Se aplicarán procedimientos que garanticen la recuperación y conservación a largo plazo de los documentos electrónicos. Toda información en soporte no electrónico que haya sido causa o consecuencia directa de la información electrónica deberá estar protegida con el mismo grado de seguridad que ésta y se aplicarán las medidas que correspondan a la naturaleza del soporte, de conformidad con las normas que resulten de aplicación.
- **Prevención ante otros sistemas de información interconectados** (artículo 23): Se protegerá el perímetro del sistema de información, especialmente, si se conecta a redes públicas, tal y como se definen en la Ley 9/2014, de 9 de mayo, General de Telecomunicaciones, reforzándose las tareas de prevención, detección y respuesta a incidentes de seguridad. En todo caso, se analizarán los riesgos derivados de la interconexión del sistema con otros sistemas y se controlará su punto de unión.
- **Registro de actividad y detección de código dañino** (artículo 24): con plenas garantías del derecho al honor, a la intimidad personal y familiar y a la propia imagen de los afectados, y de acuerdo con la normativa sobre protección de datos personales, de función pública o laboral, y demás disposiciones que resulten de aplicación, se registrarán las actividades de los usuarios, reteniendo la información necesaria para monitorizar, analizar, investigar y documentar actividades indebidas o no autorizadas, permitiendo identificar en cada momento a la persona que actúa. Al objeto de preservar la seguridad de los sistemas de información, de conformidad con el Reglamento General de Protección de Datos, se podrán, en la medida estrictamente necesaria y proporcionada, analizar las comunicaciones entrantes o salientes, y únicamente para los fines de seguridad de la información, de forma que sea posible impedir el acceso no autorizado a las redes y sistemas de información, detener los ataques de denegación de servicio, evitar la distribución malintencionada de código dañino así como otros daños a las antedichas redes y sistemas de información. Para corregir o, en su caso, exigir responsabilidades, cada usuario que acceda al sistema de información deberá estar identificado de forma única.
- **Incidentes de seguridad** (artículo 25): se dispondrá de procedimientos de gestión de incidentes de seguridad y, en caso de tratarse de un operador de servicios esenciales o de un proveedor de servicios digitales, de acuerdo con lo previsto en el anexo del Real Decreto 43/2021, de 26 de enero. También se dispondrá de mecanismos de detección, criterios de

clasificación, procedimientos de análisis y resolución, así como de los cauces de comunicación a las partes interesadas y el registro de las actuaciones.

- **Continuidad de la actividad** (artículo 26): los sistemas dispondrán de copias de seguridad y establecerán los mecanismos necesarios para garantizar la continuidad de las operaciones, en caso de pérdida de los medios habituales.
- **Mejora continua del proceso de seguridad** (artículo 27): el proceso integral de seguridad implantado deberá ser actualizado y mejorado de forma continua. Para ello, se aplicarán los criterios y métodos reconocidos en la práctica nacional e internacional relativos a gestión de las tecnologías de la información.

2.9. El mecanismo para el cumplimiento de los requisitos mínimos y la categorización de los sistemas de información

Para el cumplimiento de los requisitos mínimos, según lo previsto en el artículo 28 del ENS, las entidades comprendidas en su ámbito de aplicación **aplicarán las medidas, sus requisitos y refuerzos de seguridad** teniendo en cuenta: los activos que constituyen los sistemas de información concernidos, la categoría del sistema; y las decisiones que se adopten para gestionar los riesgos identificados.

La noción de los **refuerzos de seguridad** se ha introducido en el Real Decreto 311/2022 para expresar una mayor exigencia en la aplicación de una medida de seguridad. Los refuerzos de seguridad se suman a los requisitos base de la medida de seguridad. Los refuerzos de seguridad no siempre son incrementales entre sí y para señalar que se puede elegir entre aplicar un refuerzo u otro se expresan entre corchetes y separados por “o” de la forma genérica [Rn o Rn+1], más un diagrama de flujo explicativo. Además, los refuerzos que no presentan vinculación a una categoría o nivel determinados quedan a aplicación en función de los riesgos que puedan determinarse en el análisis correspondiente. Como apunta el propio ENS en las precisiones que se incluyen a continuación de la tabla de medidas del Anexo II: *“algunos refuerzos son de carácter opcional, no siendo requeridos en todos los sistemas de información. Se aplicarán como medidas adicionales cuando el análisis de riesgos así lo recomiende”*.

La relación de medidas seleccionadas se formalizará en un documento denominado **Declaración de Aplicabilidad**, firmado por el responsable de seguridad. Y las medidas de seguridad referenciadas en el Anexo II del ENS podrán ser reemplazadas por otras compensatorias siempre y cuando se justifique documentalmente que protegen igual o mejor el riesgo sobre los activos y se satisfacen los principios básicos y los requisitos mínimos.

El mecanismo para lograr el cumplimiento de los requisitos mínimos, a través de la adopción de las correspondientes medidas de seguridad, responde a la necesidad de **modular el equilibrio** entre la importancia de la información que se maneja y de los servicios que se prestan, por un lado, y el esfuerzo de seguridad requerido, en función de los riesgos a los que se está expuesto, bajo el criterio del principio de proporcionalidad, por otro lado.

Para facilitar la aplicación del principio de proporcionalidad se contempla, según lo previsto en el Anexo I, la **categorización de los sistemas** en tres categorías, BÁSICA, MEDIA y ALTA, en función de la valoración del impacto que tendría un incidente que afectara a la seguridad de la información o de los servicios a proteger con perjuicio para las **dimensiones de seguridad**, disponibilidad, autenticidad, integridad, confidencialidad o trazabilidad, que a su vez se valoran en tres escalones BAJO, MEDIO y ALTO.

En la valoración del impacto sobre estas dimensiones cabe tener en cuenta la repercusión en la capacidad de la organización para el logro de sus objetivos, la protección de sus activos, el cumplimiento de sus obligaciones de servicio, el respeto de la legalidad y de los derechos de los ciudadanos, según los **criterios** que se indican a continuación.

El **nivel BAJO** se asignará cuando las consecuencias de un incidente de seguridad que afecte a alguna de las dimensiones de seguridad supongan un perjuicio limitado sobre las funciones de la organización, sobre sus activos o sobre los individuos afectados. Se entiende por perjuicio limitado:

- La reducción de forma apreciable de la capacidad de la organización para atender eficazmente con sus obligaciones corrientes, aunque estas sigan desempeñándose.

- El sufrimiento de un daño menor por los activos de la organización.
- El incumplimiento formal de alguna ley o regulación, que tenga carácter de subsanable.
- Causar un perjuicio menor a algún individuo, que aun siendo molesto pueda ser fácilmente reparable.
- Otros de naturaleza análoga.

El **nivel MEDIO** se asignará cuando las consecuencias de un incidente de seguridad que afecte a alguna de las dimensiones de seguridad supongan un perjuicio grave sobre las funciones de la organización, sobre sus activos o sobre los individuos afectados. Se entiende por perjuicio grave:

- La reducción significativa la capacidad de la organización para atender eficazmente a sus obligaciones fundamentales, aunque estas sigan desempeñándose.
- El sufrimiento de un daño significativo por los activos de la organización.
- El incumplimiento material de alguna ley o regulación, o el incumplimiento formal que no tenga carácter de subsanable.
- Causar un perjuicio significativo a algún individuo, de difícil reparación.
- Otros de naturaleza análoga.

El **nivel ALTO** se asignará cuando las consecuencias de un incidente de seguridad que afecte a alguna de las dimensiones de seguridad supongan un perjuicio muy grave sobre las funciones de la organización, sobre sus activos o sobre los individuos afectados. Se entiende por perjuicio muy grave:

- La anulación de la capacidad de la organización para atender a alguna de sus obligaciones fundamentales y que éstas sigan desempeñándose.
- El sufrimiento de un daño muy grave, e incluso irreparable, por los activos de la organización.
- El incumplimiento grave de alguna ley o regulación.
- Causar un perjuicio grave a algún individuo, de difícil o imposible reparación.
- Otros de naturaleza análoga.

A la luz de lo anterior, la **determinación de la categoría de un sistema de información** se realiza de acuerdo con lo siguiente:

- un sistema de información será de **categoría ALTA** si alguna de sus dimensiones de seguridad alcanza el nivel ALTO;
- de **categoría MEDIA** si alguna de sus dimensiones de seguridad alcanza el nivel MEDIO, y ninguna alcanza un nivel superior;
- y de **categoría BÁSICA** si alguna de sus dimensiones de seguridad alcanza el nivel BAJO, y ninguna alcanza un nivel superior.

La determinación de la categoría de un sistema sobre esta base no implica que se altere el nivel de las dimensiones de seguridad que no han influido en la determinación de su categoría.

A la hora de emprender la categorización se han de tener presente las siguientes consideraciones:

- **El valor tiende a concentrarse en unos pocos activos** que son la esencia del sistema y en unas pocas dimensiones por lo que conviene prestar especial atención a aquellos activos y dimensiones en los que el impacto de un incidente pueda ser mayor, obviando las combinaciones en las que el impacto pueda ser despreciable o irrelevante.
- **Conviene comenzar la valoración por los activos de tipo información** valorando en este orden confidencialidad, integridad, trazabilidad, autenticidad, y si fuera relevante disponibilidad.

- **Conviene seguir por los activos de tipo servicio** valorando la disponibilidad. Los requisitos de confidencialidad, integridad, trazabilidad y autenticidad suelen venir impuestos por los activos de información que maneja el servicio.
- **Un sistema asumirá, para cada dimensión, el valor máximo considerado para la misma** en los distintos tipos de información manejados por los servicios prestados.
- La **categoría del sistema** se determina considerando **el valor máximo de todas sus dimensiones**, para todos los servicios prestados por el sistema.
- La **responsabilidad de la valoración** de la información y de los servicios es del responsable de la información y del servicio respectivamente, aunque puede ser propuesta por el responsable del sistema, el responsable de la seguridad, o el comité de seguridad de las tecnologías de la información y las comunicaciones si lo hubiera. Las opiniones del responsable del sistema y del responsable de la seguridad suelen ser recabadas en el proceso de valoración.

Para ampliar esta cuestión de la categorización de forma más pormenorizada véanse el documento «Como categorizar un Sistema en el ENS», así como la «Guía CCN-STIC 803 ENS. Valoración de los sistemas» que entre otras cuestiones trata la valoración de las dimensiones de seguridad, confidencialidad, integridad, trazabilidad, autenticidad y disponibilidad con las consideraciones oportunas relativas a la información y los servicios.

Seguidamente, **la selección de las medidas de seguridad apropiadas** se habrá de realizar de acuerdo con las dimensiones de seguridad y sus niveles y, para determinadas medidas de seguridad, de acuerdo con la categoría del sistema.

2.10. Las medidas de seguridad

Las medidas de seguridad, recogidas en el anexo II, se estructuran en los siguientes tres grupos:

- **Marco organizativo:** constituido por el conjunto de medidas relacionadas con la organización global de la seguridad; particularmente, la política de seguridad, la normativa de seguridad, los procedimientos de seguridad y el proceso de autorización.
- **Marco operacional:** formado por las medidas a tomar para proteger la operación del sistema como conjunto integral de componentes para un fin: aspectos de planificación, control de acceso, explotación, servicios externos, continuidad del servicio y monitorización del sistema.
- **Medidas de protección:** formado por medidas que se centran en proteger activos concretos, según su naturaleza y la calidad exigida por el nivel de seguridad de las dimensiones afectadas: de instalaciones, personal, equipos, comunicaciones, soportes de información, aplicaciones, información y servicios.

Las medidas de seguridad seleccionadas han de ser proporcionales a las dimensiones de seguridad relevantes en el sistema a proteger, así como a la categoría de seguridad del sistema de información a proteger. La relación de medidas de seguridad seleccionadas se formalizará en un documento denominado **Declaración de Aplicabilidad**, firmado por el responsable de la seguridad.

Las medidas de seguridad referenciadas en el anexo II se pueden reemplazar por otras **medidas compensatorias**, siempre y cuando se justifique documentalmente que protegen, igual o mejor, del riesgo sobre los activos y se satisfacen los principios básicos y los requisitos mínimos. En su caso se indicará de forma detallada en la Declaración de aplicabilidad la correspondencia entre las medidas compensatorias implantadas y las medidas del anexo II que compensan.

El Real Decreto 311/2022 incluye la actualización de medidas de seguridad en el marco operacional y en las medidas de protección. Como resultado de estas modificaciones de detalle, algunas medidas han ampliado considerablemente su nivel de exigencia para determinadas categorías, y otras lo han aumentado levemente. Por el contrario, otras medidas han simplificado su nivel de exigencia, y algunas medidas han sido eliminadas y/o englobadas dentro de otras. Por último, se han creado nuevas medidas que no existían. El resto de las medidas sólo han sufrido cambios de redacción. Cabe destacar lo siguiente:

- Entre las nuevas medidas, se han incluido las relativas a servicios en la nube, interconexión de sistemas, protección de la cadena de suministro (alude a los proveedores o suministradores

tecnológicos de las entidades del sector público), medios alternativos, vigilancia y otros dispositivos conectados a la red.

- Se han reforzado medidas relativas a la identificación, la configuración de seguridad, la gestión de la configuración de seguridad, la protección frente al código dañino, el registro de actividad, la gestión de capacidad, la detección de intrusión, el sistema de métricas y la aceptación y puesta en servicio.
- Otras medidas con un refuerzo más ligero incluyen los requisitos de acceso, la gestión de cambios, la gestión de incidentes, mantenimiento y actualizaciones de seguridad, protección de la confidencialidad y copias de seguridad.
- Se han simplificado algunas medidas como segregación de tareas, sellos de tiempo, calificación de la información, protección de dispositivos portátiles, protección frente a denegación de servicio o perímetro seguro.
- Se han eliminado medidas tales como las relativas a personal alternativo, medios alternativos, protección de los registros de actividad por estar cubiertas por otras medidas.

La siguiente **tabla de medidas de seguridad**, recogida en el Anexo II del Real Decreto 311/2022, muestra la correspondencia entre los niveles de seguridad exigidos en cada dimensión y las medidas de seguridad con sus refuerzos.

Con el fin de ayudar a la implantación y revisión de las medidas de seguridad **se han codificado sus requisitos**.

Además, recordando lo dicho más arriba por su interés como novedad frente a la versión anterior del ENS, para indicar una mayor exigencia se emplean los **refuerzos de seguridad, también codificados**, que se suman a los requisitos base de la medida, pero que no siempre son incrementales entre sí; en ciertos casos, se puede elegir entre aplicar un refuerzo u otro de entre los recogidos para las medidas en función del análisis de los riesgos y del criterio del responsable de la seguridad. Así, para indicar una mayor exigencia se emplean los refuerzos de seguridad (R) que se suman (+) a los requisitos base de la medida, pero que no siempre son incrementales entre sí. Para señalar que se puede elegir entre aplicar un refuerzo u otro, se indica entre corchetes y separados por «o» [Rn o Rn+1].

Medidas de Seguridad		Por categoría o dimensión(es)	NIVEL DE LAS DIMENSIONES DE SEGURIDAD		
			BAJO	MEDIO	ALTO
			CATEGORÍA DE SEGURIDAD DEL SISTEMA		
			BÁSICA	MEDIA	ALTA
org	Marco organizativo				
org.1	Política de seguridad	Categoría	aplica	aplica	aplica
org.2	Normativa de seguridad	Categoría	aplica	aplica	aplica
org.3	Procedimientos de seguridad	Categoría	aplica	aplica	aplica
org.4	Proceso de autorización	Categoría	aplica	aplica	aplica
op	Marco operacional				
op.pl	Planificación				
op.pl.1	Análisis de riesgos	Categoría	aplica	+ R1	+ R2
op.pl.2	Arquitectura de Seguridad	Categoría	aplica	+ R1	+ R1 + R2 + R3
op.pl.3	Adquisición de nuevos componentes	Categoría	aplica	aplica	aplica
op.pl.4	Dimensionamiento/gestión de la capacidad	D	aplica	+ R1	+ R1
op.pl.5	Componentes certificados	Categoría	n.a.	aplica	aplica
op.acc	Control de acceso				
op.acc.1	Identificación	T A	aplica	+ R1	+ R1
op.acc.2	Requisitos de acceso	C I T A	aplica	aplica	+ R1
op.acc.3	Segregación de funciones y tareas	C I T A	n.a.	aplica	+ R1
op.acc.4	Proceso de gestión de derechos de acceso	C I T A	aplica	aplica	aplica
op.acc.5	Mecanismo de autenticación (usuarios externos)	C I T A	+ [R1 o R2 o R3 o R4]	+ [R2 o R3 o R4] + R5	+ [R2 o R3 o R4] + R5
op.acc.6	Mecanismo de autenticación (usuarios de la organización)	C I T A	+ [R1 o R2 o R3 o R4] + R8 + R9	+ [R1 o R2 o R3 o R4] + R5 + R8 + R9	+ [R1 o R2 o R3 o R4] + R5 + R6 + R7 + R8 + R9
op.exp	Explotación				
op.exp.1	Inventario de activos	Categoría	aplica	aplica	aplica
op.exp.2	Configuración de seguridad	Categoría	aplica	aplica	aplica
op.exp.3	Gestión de la configuración de seguridad	Categoría	aplica	+ R1	+ R1 + R2 + R3
op.exp.4	Mantenimiento y actualizaciones de seguridad	Categoría	aplica	+ R1	+ R1 + R2
op.exp.5	Gestión de cambios	Categoría	n.a.	aplica	+ R1
op.exp.6	Protección frente a código dañino	Categoría	aplica	+ R1 + R2	+ R1 + R2 + R3 + R4
op.exp.7	Gestión de incidentes	Categoría	aplica	+ R1 + R2	+ R1 + R2 + R3

Medidas de Seguridad		Por categoría o dimensión(es)	NIVEL DE LAS DIMENSIONES DE SEGURIDAD		
			BAJO	MEDIO	ALTO
			CATEGORÍA DE SEGURIDAD DEL SISTEMA		
			BÁSICA	MEDIA	ALTA
op.exp.8	Registro de la actividad	T	aplica	+ R1 + R2 + R3 + R4	+ R1 + R2 + R3 + R4 + R5
op.exp.9	Registro de la gestión de incidentes	Categoría	aplica	aplica	aplica
op.exp.10	Protección de claves criptográficas	Categoría	aplica	+ R1	+ R1
op.ext	Recursos externos				
op.ext.1	Contratación y acuerdos de nivel de servicio	Categoría	n.a.	aplica	aplica
op.ext.2	Gestión diaria	Categoría	n.a.	aplica	aplica
op.ext.3	Protección de la cadena de suministro	Categoría	n.a.	n.a.	aplica
op.ext.4	Interconexión de sistemas	Categoría	n.a.	aplica	+ R1
op.nub	Servicios en la nube				
op.nub.1	Protección de servicios en la nube	Categoría	aplica	+ R1	+ R1 + R2
op.cont	Continuidad del servicio				
op.cont.1	Análisis de impacto	D	n.a.	aplica	aplica
op.cont.2	Plan de continuidad	D	n.a.	n.a.	aplica
op.cont.3	Pruebas periódicas	D	n.a.	n.a.	aplica
op.cont.4	Medios alternativos	D	n.a.	n.a.	aplica
op.mon	Monitorización del sistema				
op.mon.1	Detección de intrusión	Categoría	aplica	+ R1	+ R1 + R2
op.mon.2	Sistema de métricas	Categoría	aplica	+ R1 + R2	+ R1 + R2
op.mon.3	Vigilancia	Categoría	aplica	+ R1 + R2	+ R1 + R2 + R3 + R4 + R5 + R6
mp	Medidas de protección				
mp.if	Protección de las instalaciones e infraestructuras				
mp.if.1	Áreas separadas y con control de acceso	Categoría	aplica	aplica	aplica
mp.if.2	Identificación de las personas	Categoría	aplica	aplica	aplica
mp.if.3	Acondicionamiento de los locales	Categoría	aplica	aplica	aplica
mp.if.4	Energía eléctrica	D	aplica	+ R1	+ R1
mp.if.5	Protección frente a incendios	D	aplica	aplica	aplica
mp.if.6	Protección frente a inundaciones	D	n.a.	aplica	aplica
mp.if.7	Registro de entrada y salida de equipamiento	Categoría	aplica	aplica	aplica

Medidas de Seguridad		Por categoría o dimensión(es)	NIVEL DE LAS DIMENSIONES DE SEGURIDAD		
			BAJO	MEDIO	ALTO
			CATEGORÍA DE SEGURIDAD DEL SISTEMA		
			BÁSICA	MEDIA	ALTA
mp.per	Gestión del personal				
mp.per.1	Caracterización del puesto de trabajo	Categoría	n.a.	aplica	aplica
mp.per.2	Deberes y obligaciones	Categoría	aplica	+ R1	+ R1
mp.per.3	Concienciación	Categoría	aplica	aplica	aplica
mp.per.4	Formación	Categoría	aplica	aplica	aplica
mp.eq	Protección de los equipos				
mp.eq.1	Puesto de trabajo despejado	Categoría	aplica	+ R1	+ R1
mp.eq.2	Bloqueo de puesto de trabajo	A	n.a.	aplica	+ R1
mp.eq.3	Protección de dispositivos portátiles	Categoría	aplica	aplica	+ R1 + R2
mp.eq.4	Otros dispositivos conectados a la red	C	aplica	+ R1	+ R1
mp.com	Protección de las comunicaciones				
mp.com.1	Perímetro seguro	Categoría	aplica	aplica	aplica
mp.com.2	Protección de la confidencialidad	C	aplica	+ R1	+ R1 + R2 + R3
mp.com.3	Protección de la integridad y de la autenticidad	I A	aplica	+ R1 + R2	+ R1 + R2 + R3 + R4
mp.com.4	Separación de flujos de información en la red	Categoría	n.a.	+ [R1 o R2 o R3]	+ [R2 o R3] + R4
mp.si	Protección de los soportes de información				
mp.si.1	Marcado de soportes	C	n.a.	aplica	aplica
mp.si.2	Criptografía	C I	n.a.	aplica	+ R1 + R2
mp.si.3	Custodia	Categoría	aplica	aplica	aplica
mp.si.4	Transporte	Categoría	aplica	aplica	aplica
mp.si.5	Borrado y destrucción	C	aplica	+ R1	+ R1
mp.sw	Protección de las aplicaciones informáticas				
mp.sw.1	Desarrollo de aplicaciones	Categoría	n.a.	+ R1 + R2 + R3 + R4	+ R1 + R2 + R3 + R4
mp.sw.2	Aceptación y puesta en servicio	Categoría	aplica	+ R1	+ R1
mp.info	Protección de la información				
mp.info.1	Datos personales	Categoría	aplica	aplica	aplica
mp.info.2	Calificación de la información	C	n.a.	aplica	aplica
mp.info.3	Firma electrónica	I A	aplica	+ R1 + R2 + R3	+ R1 + R2 + R3 + R4
mp.info.4	Sellos de tiempo	T	n.a.	n.a.	aplica
mp.info.5	Limpieza de documentos	C	aplica	aplica	aplica

Medidas de Seguridad		Por categoría o dimensión(es)	NIVEL DE LAS DIMENSIONES DE SEGURIDAD		
			BAJO	MEDIO	ALTO
			CATEGORÍA DE SEGURIDAD DEL SISTEMA		
			BÁSICA	MEDIA	ALTA
mp.info.6	Copias de seguridad	D	aplica	+ R1	+ R1 + R2
mp.s	Protección de los servicios				
mp.s.1	Protección del correo electrónico	Categoría	aplica	aplica	aplica
mp.s.2	Protección de servicios y aplicaciones web	Categoría	+ [R1 o R2]	+ [R1 o R2]	+ R2 + R3
mp.s.3	Protección de la navegación web	Categoría	aplica	aplica	+ R1
mp.s.4	Protección frente a denegación de servicio	D	n.a.	aplica	+ R1

Tabla 1. Medidas de seguridad. (Fuente: Real Decreto 311/2022, Anexo II)

Un aspecto novedoso también del Real Decreto 311/2022, que se clarifica en el punto 6 del Anexo II, es la aplicación del nivel de madurez a la implantación de las medidas de seguridad usando el modelo de madurez de capacidad (CMM).

Se identifican cinco "niveles de madurez", de modo que una organización que tenga institucionalizadas todas las prácticas incluidas en un nivel y sus inferiores, se considera que ha alcanzado ese **nivel de madurez**:

- L0-Inexistente: No existe un proceso que soporte el servicio requerido.
- L1 - Inicial. Ad hoc: Las organizaciones en este nivel no disponen de un ambiente estable para la prestación del servicio requerido. Aunque se utilicen técnicas correctas de ingeniería, los esfuerzos se ven minados por falta de planificación. El éxito de los proyectos se basa, la mayoría de las veces, en el esfuerzo personal, aunque a menudo se producen fracasos y casi siempre retrasos y sobrecostos. El resultado es impredecible. A menudo las soluciones se implementan de forma reactiva a los incidentes. Los procedimientos de trabajo, cuando existen, son informales, incompletos y no se aplican de forma sistemática.
- L2-Reproducible, pero intuitivo: En este nivel las organizaciones disponen de unas prácticas institucionalizadas de gestión, existen unas métricas básicas y un razonable seguimiento de la calidad. Existen procedimientos de trabajo, pero no están suficientemente documentados o no cubren todos los aspectos requeridos.
- L3-Proceso definido: Además de una buena gestión, a este nivel las organizaciones disponen de normativa y procedimientos detallados y documentados de coordinación entre grupos, formación del personal, técnicas de ingeniería, etc.
- L4-Gestionado y medible: Se caracteriza porque las organizaciones disponen de un conjunto de métricas de efectividad y eficiencia, que se usan de modo sistemático para la toma de decisiones y la gestión de riesgos. El servicio resultante es de alta calidad.
- L5 – Optimizado: La organización completa está volcada en la mejora continua de los procesos. Se hace uso intensivo de las métricas y se gestiona el proceso de innovación.

De forma que para cada medida de seguridad que sea de aplicación al sistema de información se exigirá un determinado nivel de madurez. Los niveles mínimos de madurez requeridos por el ENS en función de la categoría del sistema son:

- BÁSICA: L2-Reproducible, pero intuitivo.
- MEDIA: L3-Proceso definido.
- ALTA: L4-Gestionado y medible.

2.11. El uso de infraestructuras y servicios comunes

Para lograr un mejor cumplimiento del Esquema, en el artículo 29 'Infraestructuras y servicios comunes' se hace referencia a los servicios e infraestructuras comunes que facilitarán el cumplimiento de los principios básicos y los requisitos mínimos en condiciones de mejor eficiencia.

El interés de las infraestructuras y servicios comunes radica en su capacidad para aportar aspectos tales como los siguientes:

- **Reducción del perímetro físico:** se reduce la carga en medidas de protección de las instalaciones e infraestructuras [mp.if] para las entidades usuarias.
- **Reducción del perímetro lógico:** se reduce la carga para las entidades usuarias en medidas tales como: explotación [mp.exp], protección de las aplicaciones informáticas [mp.sw], protección de los servicios [mp.s] y monitorización del sistema [op.mon].
- **Gestión de incidentes:** se reduce la carga de gestión de incidentes [op.exp7].
- **Mejor elasticidad:** para hacer frente a picos de actividad o ataques de denegación de servicio [mp.s.8].
- **Mejor conformidad con estándares:** para mejor recuperación, integración, interoperabilidad, portabilidad, integración con herramientas de seguridad (medidas varias de tipo [op]).

2.12. Los perfiles de cumplimiento específicos

El artículo 30 introduce una nueva figura, los **perfiles de cumplimiento específicos** que comprenderán aquel conjunto de medidas de seguridad que, a la luz del análisis de riesgos, resulten idóneas para una concreta categoría de seguridad. Mediante estos perfiles se pueden ajustar los requisitos del ENS a necesidades específicas de ciertos colectivos (por ejemplo, Entidades Locales, Universidades, Organismos Pagadores, etc.) o de ámbitos tecnológicos (por ejemplo, servicios en la nube), al objeto de que se pueda alcanzar una adaptación al ENS más eficaz y eficiente sin menoscabo de la protección perseguida y exigible. El CCN validará y publicará los correspondientes perfiles de cumplimiento específicos. También en este artículo 30 se habilita que se podrán implementar **esquemas de acreditación de entidades** y validación de personas para posibilitar la adecuada implantación y configuración de soluciones o plataformas suministradas por terceros.

Algunos **ejemplos** de perfiles de cumplimiento específicos ya disponibles son los siguientes:

- CCN-STIC-881A. Perfil de Cumplimiento Específico Universidades
- CCN-STIC 883A Perfil de Cumplimiento Específico Ayuntamientos pequeños (menos de 5.000 habitantes)
- CCN-STIC 883B Perfil Cumplimiento Específico Ayuntamientos de menos de 20.000 habitantes
- CCN-STIC 883C Perfil de Cumplimiento Específico Ayuntamientos de entre 20.000 y 75.000 habitantes
- CCN-STIC 883D Perfil de Cumplimiento Específico Diputaciones
- CCN-STIC-884 Perfil de cumplimiento específico para Azure Servicio de Cloud Corporativo
- CCN-STIC-885 Perfil de cumplimiento específico para Office 365 Servicio de Cloud Corporativo
- CCN-STIC-886 Perfil de cumplimiento específico para Sistemas Cloud Privados y Comunitarios
- CCN-STIC-887 Perfil de cumplimiento específico para AWS Servicio de Cloud Corporativo
- CCN-STIC-888 Perfil de Cumplimiento Específico para Google Cloud Servicio de Cloud Corporativo

Si nos fijamos a título ilustrativo en el documento «CCN-STIC-881A. Perfil de Cumplimiento Específico Universidades» observamos lo siguiente:

- Se ha realizado un estudio de las necesidades de seguridad y de los riesgos a los que se ven expuestas las universidades, para la implantación del ENS en las mismas, con necesidades de categoría MEDIA.
- Se ha determinado la relación de medidas que son de aplicación y la exigencia del nivel de seguridad de cada medida. Se han señalado con un “*” aquellas medidas para las que se establecen criterios específicos de aplicación. Así de las 73 medidas del anexo II aplican 69.
- Como ejemplos de las ocho medidas para las que se establecen criterios específicos cabe mostrar las siguientes como ejemplo:
 - [op.acc.5] Mecanismos de autenticación (usuarios externos): Para el acceso a aquellos servicios que manejan información cuya dimensión Confidencialidad [C] se haya valorado a nivel BAJO, podrán aplicarse los criterios de categoría BÁSICA, más el refuerzo R5 – Registro.
 - [mp.info.4] Sellos de tiempo: Serán de aplicación los requisitos de nivel ALTO para aquella información que sea susceptible de ser utilizada como evidencia electrónica en el futuro. En caso contrario, esta medida no será de aplicación.

2.13. La respuesta a incidentes de seguridad

En el Real Decreto 311/2022 se ha perfeccionado lo relativo al tratamiento de los incidentes de seguridad, de forma que se explicita y se clarifica el papel de los principales actores interesados en la cuestión, a la luz del escenario asentado en el Real Decreto-ley 12/2018 y en el Real Decreto 43/2021. Las pautas de actuación asentadas son las siguientes:

- En primer lugar, se establece en el artículo 33 que *“el Centro Criptológico Nacional (CCN) articulará la respuesta a los incidentes de seguridad en torno a la estructura denominada CCN-CERT (Centro Criptológico Nacional-Computer Emergency Reaction Team), que actuará sin perjuicio de las capacidades de respuesta a incidentes de seguridad que pueda tener cada administración pública y de la función de coordinación a nivel nacional e internacional del CCN”*.
- Dicho lo anterior, **las entidades del sector público notificarán al CCN** aquellos incidentes que tengan un impacto significativo en la seguridad y de acuerdo con la correspondiente Instrucción Técnica de Seguridad, sin perjuicio de lo establecido en el artículo 19.4 del Real Decreto-ley 12/2018, de 7 de septiembre.
- Siguen en los apartados tercero y cuarto **precisiones adicionales en relación con el ámbito de ciertos operadores**:
 - Cuando un operador esencial que haya sido designado como operador crítico sufra un incidente, los CSIRT de referencia se coordinarán con el Ministerio del Interior, a través de su Oficina de Coordinación de Ciberseguridad, según lo previsto en el artículo 11.2 del Real Decreto-ley 12/2018, de 7 de septiembre.
 - Cuando un operador con incidencia en la Defensa Nacional sufra un incidente deberá analizar si, por su alcance, éste pudiera tener impacto en el funcionamiento del Ministerio de Defensa o en la operatividad de las Fuerzas Armadas, lo pondrá de inmediato en conocimiento de su CSIRT de referencia, quien informará a la capacidad de respuesta e incidentes de seguridad de referencia para el ámbito de la Defensa nacional, denominada ESPDEF-CERT, del Mando Conjunto del Ciberespacio (MCCE).
- Tras un incidente de seguridad, **el CCN-CERT determinará técnicamente el riesgo de reconexión del sistema o sistemas afectados**, indicando los procedimientos a seguir y las salvaguardas a implementar, correspondiéndole la coordinación nacional de la respuesta a incidentes de seguridad informática en materia de seguridad de las redes y sistemas de información del sector público.
- Por su parte, la **Secretaría General de Administración Digital autorizará la reconexión a los medios y servicios comunes comprendidos bajo su ámbito de responsabilidad**, incluidos los compartidos o transversales, si un informe de superficie de exposición del CCN-CERT hubiere determinado que el riesgo es asumible. Si se trata de un incidente de seguridad que afecta a un medio o servicio común bajo ámbito de responsabilidad de la **Intervención**

General de la Administración del Estado, esta participará en el proceso de autorización de la reconexión.

- **Las organizaciones del sector privado que presten servicios a las entidades públicas notificarán al INCIBE-CERT**, quien lo pondrá inmediatamente en conocimiento del CCN-CERT.

De acuerdo con el artículo 34 del ENS 'Prestación de servicios de respuesta a incidentes de seguridad a las Administraciones públicas' **el CCN-CERT prestará los siguientes servicios:**

- **Soporte y coordinación para el tratamiento de vulnerabilidades** y la resolución de incidentes de seguridad o agresiones recibidas por las distintas administraciones públicas (general, autonómica y local) y las entidades de derecho público con personalidad jurídica propia dependientes de éstas. Para este fin se podrán recabar informes de auditoría de los sistemas afectados, registros de auditoría, configuraciones y cualquier otra información que se considere relevante, así como los soportes informáticos que se estimen necesarios para la investigación del incidente de los sistemas afectados.
- **Investigación y divulgación de las mejores prácticas** sobre seguridad de la información entre todos los miembros de la Administración.
- **Formación** destinada al personal de la Administración especialista en el campo de la seguridad de las tecnologías de la información.
- **Información sobre vulnerabilidades, alertas y avisos** de nuevas amenazas a los sistemas de información, recopiladas de diversas fuentes de reconocido prestigio, incluidas las propias.
- De igual modo, se regula el desarrollo por parte del CCN-CERT de un **programa que ofrezca apoyo a las Administraciones públicas** para que desarrollen sus propias capacidades de respuesta a incidentes de seguridad.

La «Instrucción Técnica de Seguridad de Notificación de Incidentes de Seguridad», junto con la guía «CCN-STIC 817 Gestión de Ciberincidentes», proporciona a los Responsables de Seguridad un acercamiento a la tipificación de los ciberincidentes, unas recomendaciones para determinar la peligrosidad de los ciberincidentes, así como una metodología de notificación al CCN-CERT, atendiendo al momento y a la tipología del ciberincidente y para garantizar en todo momento la cadena de custodia. Esta Guía se encuentra alineada con la herramienta LUCIA para la Gestión de Ciberincidentes en las entidades del ámbito de aplicación del ENS, desarrollada por el CCN-CERT y mencionada también en la citada Instrucción Técnica de Seguridad.

2.14. El uso de productos y servicios de seguridad

En relación con los productos de seguridad de las tecnologías de la información y comunicaciones, como ya se ha apuntado más arriba, el artículo 19 del ENS se expresa en términos de que *“en la adquisición de productos de seguridad o contratación de servicios de seguridad de las tecnologías de la información y la comunicación que vayan a ser empleados en los sistemas de información del ámbito de aplicación de este real decreto, se utilizarán, de forma proporcionada a la categoría del sistema y el nivel de seguridad determinados, aquellos que tengan certificada la funcionalidad de seguridad relacionada con el objeto de su adquisición”*.

El Esquema destaca, por tanto, la importancia de la **certificación** a la hora de adquirir productos de seguridad.

Según la medida **Componentes certificados [op.pl.5]**, para las categorías MEDIA y ALTA, esencialmente:

- Se utilizará el **Catálogo de Productos y Servicios de Seguridad de las Tecnologías de la Información y Comunicación (CPSTIC)** del CCN, para seleccionar los productos o servicios suministrados por un tercero que formen parte de la arquitectura de seguridad del sistema y aquellos que se referencien expresamente en las medidas de este real decreto.
- Si el sistema suministra un servicio de seguridad a un tercero bajo el alcance del ENS, el producto o productos que en los que se sustente dicho servicio debe superar un proceso de cualificación y ser incluido en el CPSTIC, o aportar una certificación que cumpla con los requisitos funcionales de seguridad y de aseguramiento de acuerdo con lo establecido en el artículo 19.

El «Catálogo de Productos y Servicios de Seguridad de las Tecnologías de la Información y Comunicación (CPSTIC)», recogido en la Guía CCN-STIC 105, ofrece un conjunto de productos de referencia cuyas funcionalidades de seguridad relacionadas con el objeto de su adquisición han sido certificadas. Permite proporcionar un nivel mínimo de confianza al usuario final en los productos adquiridos, en base a las mejoras de seguridad derivadas del proceso de evaluación y certificación y a un procedimiento de empleo seguro. Consta de dos partes:

- Productos Aprobados: productos que se consideran adecuados para el manejo de información clasificada (DIFUSIÓN LIMITADA, CONFIDENCIAL, RESERVADO, SECRETO).
- Productos y Servicios Cualificados: productos que cumplen los requisitos de seguridad exigidos para el manejo de información sensible en el ENS, en cualquiera de sus categorías (ALTA, MEDIA y BÁSICA).

2.15. Las instrucciones técnicas de seguridad

La disposición adicional segunda ‘Desarrollo del Esquema Nacional de Seguridad’ trata las **instrucciones técnicas de seguridad**, de obligado cumplimiento. Dichas instrucciones técnicas de seguridad son esenciales para lograr una adecuada, homogénea y coherente implantación de los requisitos y medidas recogidos en el Esquema y, particularmente, para indicar el modo común de actuar en aspectos concretos.

A la fecha se han publicado en el Boletín Oficial del Estado cuatro instrucciones técnicas de seguridad:

- **Informe del Estado de la Seguridad** (Resolución de 7 de octubre de 2016): tiene por objeto establecer las condiciones relativas a la recopilación y comunicación de datos que permita conocer las principales variables de la seguridad de la información de los sistemas comprendidos en el ámbito de aplicación del Esquema Nacional de Seguridad, y confeccionar un perfil general del estado de la ciberseguridad en las Administraciones públicas.
- **Notificación de incidentes de Seguridad** (Resolución de 13 de abril de 2018): tiene por objeto la notificación y gestión de incidentes de seguridad en los sistemas de información de las entidades del Sector Público, cuando tales incidentes tengan un impacto significativo en la seguridad de la información que manejan o los servicios que prestan, en relación con la categoría del sistema y con independencia de los requerimientos adicionales que cada organismo o entidad implemente para adaptarlos a sus entornos singulares.

Cabe destacar que, según esta instrucción, **“se notificarán al Centro Criptológico Nacional los incidentes de seguridad que tengan un impacto significativo en la seguridad de la información manejada o los servicios prestados en relación con la categoría del sistema, determinada de acuerdo con lo dispuesto en los artículos 40, 41 y Anexo I del Real Decreto 3/2010 (entiéndase 311/2022). Se dice que un incidente tiene impacto significativo cuando, por su magnitud o características, impide el tratamiento de la información o los servicios prestados. A estos efectos, se considerará que tienen un impacto significativo los niveles Alto, Muy Alto y Crítico recogidos en la tabla Criterios de Determinación del Nivel de Impacto de la Guía CCN-STIC 817.”**

- **Auditoría de la Seguridad** (Resolución de 27 de marzo de 2018): tiene por objeto establecer las condiciones para la realización de las auditorías, ordinarias o extraordinarias, previstas en el artículo 31 del Real Decreto 311/2022.
- **Conformidad con el Esquema Nacional de Seguridad** (Resolución de 13 de octubre de 2016): tiene por objeto establecer los criterios y procedimientos para la determinación de la conformidad con el ENS y para la publicidad de dicha conformidad; así, determina los mecanismos de obtención y ulterior publicidad de las declaraciones de conformidad y los distintivos de seguridad de los que sean acreedores y que se hubieren obtenido respecto al cumplimiento del ENS.

El Real Decreto 311/2022 se refiere adicionalmente a otras instrucciones que regularán los siguientes aspectos:

- Esquema de Certificación de Responsables de la Seguridad (artículo 13.4).
- Interconexión en el Esquema Nacional de Seguridad (artículo 23).

- Adquisición de productos de seguridad (Anexo II, medida Componentes certificados [op.pl.5]).
- Criptología de empleo en el Esquema Nacional de Seguridad (Anexo II medida Firma electrónica [mp.info.3]).

Todo lo anterior sin perjuicio de las propuestas que pueda acordar la Comisión Sectorial de Administración Electrónica, según lo establecido en la disposición adicional segunda.

2.16. La formación

La formación es necesaria para garantizar el conocimiento del Esquema Nacional de Seguridad por parte del personal del Sector Público. Se trata en la disposición adicional primera, en los requisitos mínimos y en las medidas de seguridad.

En esta cuestión, hay que señalar la oferta de cursos de formación que realiza en CCN, disponibles en línea, y en colaboración con el Instituto Nacional de Administración Pública (INAP).

2.17. Gobernanza, cooperación y comunidad

La **Secretaría General de Administración Digital** (Secretaría de Estado de Digitalización e Inteligencia Artificial, Ministerio de Asuntos Económicos y Transformación Digital) gobierna el Esquema Nacional de Seguridad en estrecha colaboración con el **Centro Criptológico Nacional (CCN)** del Centro Nacional de Inteligencia.

A la **Secretaría General de Administración Digital (SGAD)** le corresponde el desarrollo y aplicación de lo dispuesto en el Real Decreto 311/2022 (anteriormente RD 3/2010) Esquema Nacional de Seguridad y sus Instrucciones Técnicas de Seguridad. En especial, la definición de estándares, de directrices técnicas y de gobierno TIC, de normas de seguridad de aplicación a las Administraciones Públicas y la realización de propuestas e interlocución con el Centro Criptológico Nacional en el desarrollo de guías de seguridad CCN-STIC.

El **CCN** pone a disposición del ENS sus capacidades, servicios y soluciones de ciberseguridad a la vez que desempeña las competencias que le atribuye el Real Decreto 311/2022 y que se han ido apuntando a lo largo del tema en relación con cuestiones tales como la evaluación y certificación de la seguridad de las tecnologías de la información, los perfiles de cumplimiento específicos, el informe del estado de la seguridad (INES), las instrucciones técnicas de seguridad, las guías de seguridad de las tecnologías de la información y la comunicación (Guías CCN-STIC) y la capacidad de respuesta a incidentes de seguridad CCN-CERT.

La cooperación desempeña un papel relevante, pues el ENS se elaboró en su día con la participación de todas las administraciones públicas, incluyendo los ámbitos de las universidades públicas a través de la CRUE y de la Justicia (que cuenta con el EJIS – Esquema Judicial de Interoperabilidad y Seguridad), junto con aportaciones del sector privado mediante la colaboración con las principales asociaciones de la Industria del sector TIC.

Dicho lo anterior, la cooperación relativa al ENS se viene articulando fundamentalmente a través de los órganos colegiados con competencia en materia TIC.

En el ámbito de la Administración General del Estado, se trata de los previstos en el «Real Decreto 806/2014, de 19 de septiembre, sobre organización e instrumentos operativos de las tecnologías de la información y las comunicaciones en la Administración General del Estado y sus Organismos Públicos», fundamentalmente a través del **Comité de Dirección de las Tecnologías de la Información y las Comunicaciones (CDTIC)**.

En el ámbito de la cooperación con las demás administraciones públicas se trata de la **Comisión Sectorial de Administración Electrónica** prevista en la disposición adicional novena de la «Ley 40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público». En ambos casos a través de los correspondientes grupos de trabajo del ENS.

De forma más especializada es especialmente relevante el **Consejo de Certificación del ENS (CoCENS)** constituido en 2018. El CoCENS está presidido por el Centro Criptológico Nacional y son miembros la Secretaría General de Administración Digital, la Entidad Nacional de Acreditación (ENAC), las entidades de certificación acreditadas por la ENAC y los órganos de auditoría técnica del ENS del Sector Público.

Las funciones fundamentales del CoCENS son velar por la adecuada implantación de la certificación de la conformidad con el ENS; proponer para su análisis y, en su caso, redactar y publicar Normas, Criterios o Buenas Prácticas en materia de certificación de la conformidad con el ENS; y asesorar a las partes implicadas respecto de los métodos, procedimientos, herramientas y criterios en materia de Certificación de la Conformidad con el ENS.

Toda esta cooperación y gobernanza se ubica en el marco más amplio configurado por lo tratado en el capítulo 1 de este tema sobre el Sistema de Seguridad Nacional.

Adicionalmente, la gobernanza y la cooperación se complementan con **la comunidad de expertos**, tanto del sector público como del sector privado, que se ha formado alrededor del ENS y que contribuye activamente a su aplicación, dinámica y progreso.

Por otra parte, detrás de la elaboración y desarrollo del Esquema Nacional de Seguridad hay **personas concretas**, con nombres y apellidos; aquellas personas que forman parte de los grupos de trabajo que vienen contribuyendo al ENS con sus opiniones y aportaciones, tanto de la Administración General del Estado como de las demás Administraciones Públicas, y, particularmente, aquellas personas que de forma más directamente han contribuido a lo que el ENS es actualmente, en un trabajo sostenido en el tiempo como Luis Jiménez, Javier Candau, Pablo López y su equipo, José M^a Molina, José A. Mañas, Carlos Galán, José M^a Fernández Lacasa y Miguel A. Amutio, sin olvidar a los superiores jerárquicos que apoyaron, a menudo con paciencia, las sucesivas versiones y actualizaciones del ENS como Juan Miguel Márquez, Fernando de Pablo, Esther Arizmendi, Domingo Molina, Juan Jesús Torres, Félix Sanz Roldán y Paz Esteban; y teniendo en cuenta que ha habido numerosas personas de los grupos de trabajo citados que han contribuido con aportaciones significativas.

3. ADECUACIÓN AL ENS, AUDITORÍA DE LA SEGURIDAD, CONFORMIDAD E INFORME DEL ESTADO DE LA SEGURIDAD

3.1. Adecuación al Esquema Nacional de Seguridad

La adecuación ordenada al Esquema Nacional de Seguridad requiere el tratamiento de las siguientes cuestiones, expresadas de forma muy sucinta:

- **Preparar y aprobar la política de seguridad**, incluyendo la **definición de roles y la asignación de responsabilidades**.
- **Categorizar los sistemas** atendiendo a la valoración de la información manejada y de los servicios prestados.
- **Realizar el análisis de riesgos**, incluyendo la valoración de las medidas de seguridad existentes.
- **Preparar y aprobar la Declaración de aplicabilidad** de las medidas del Anexo II del ENS.
- **Elaborar un plan de adecuación** para la mejora de la seguridad, sobre la base de las insuficiencias detectadas, incluyendo plazos estimados de ejecución.
- **Implantar, operar y monitorizar las medidas de seguridad** a través de la gestión continuada de la seguridad correspondiente.
- **Auditar** para verificar el cumplimiento de los requisitos del ENS.
- **Obtener y publicitar la conformidad con el ENS.**

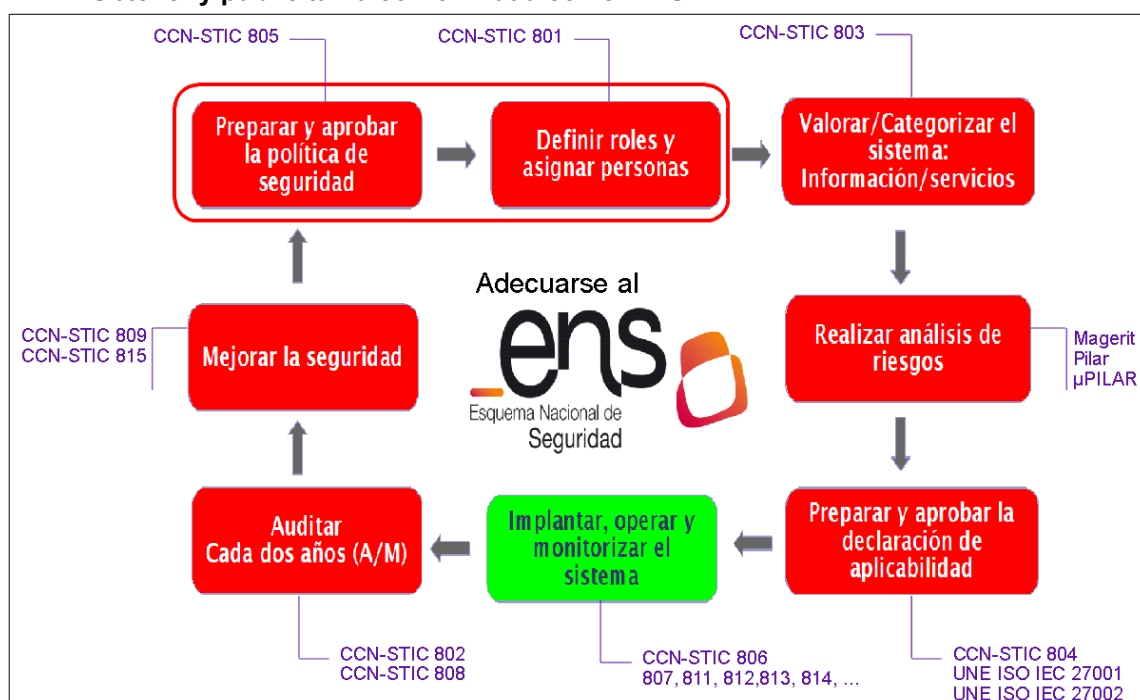


Figura 9. Acciones claves de la adecuación al Esquema Nacional de Seguridad. (Fuente: José A. Mañas, Miguel A. Amutio)

Habrà que formular preguntas básicas como las siguientes:

- ¿Hay una política de seguridad formalmente adoptada?
- ¿Hay normas de seguridad y procedimientos?
- ¿Hay roles y responsables designados?

- ¿Hay una categorización del sistema? (que establece cuán importantes son la información y servicios manejados)
- ¿Hay un análisis de riesgos?
- ¿Hay una declaración de aplicabilidad?
- ¿Se dispone de medidas implantadas y monitorizadas?
- ¿Se audita periódicamente?
- ¿Se cuenta con una declaración o certificación de la conformidad con el ENS?

En la práctica habitualmente no se parte de cero, sino que habrá que evaluar la situación del estado de la seguridad para determinar las insuficiencias, habrá que diseñar una ruta de adecuación que contemplen la planificación y despliegue de las medidas correspondientes y finalmente se abordará la conformidad mediante la auditoría y la certificación.

Para ampliar esta cuestión de la adecuación al ENS de forma más pormenorizada véase la Guía CCN-STIC 806 “Plan de adecuación al ENS”.

Adicionalmente, el CCN facilita la **solución AMPARO** para facilitar la gobernanza de la ciberseguridad mediante funcionalidades que permiten llevar a cabo el proceso de adecuación al ENS de forma guiada gracias a su ‘Asistente de Implantación’, que señala los pasos que se deben seguir, muestra ayudas a lo largo de todo el proceso y evalúa automáticamente la conformidad del sistema para detectar carencias; evaluar el sistema y obtener automáticamente la ‘Declaración de Conformidad’ del sistema para categoría BÁSICA del ENS, o solicitar una ‘Auditoría de Conformidad’ a una Entidad de Certificación acreditada; descargar desde la sección de ‘Soporte’ todos los modelos de procedimientos y normativas necesarios para la adecuación al ENS, y gestionar la documentación del marco normativo; gestionar la conformidad, mantener la comunicación con la entidad auditora, ver el estado del sistema, y facilitar todo el proceso de auditoría; y gestionar la seguridad del sistema, mediante los registros de usuarios, registros de soportes, formación y cualquier otro registro necesario para mantener la seguridad.

3.2. La auditoría de la seguridad

Se establece en el artículo 31, junto con el Anexo III, la auditoría de la seguridad para los sistemas comprendidos en el ámbito de aplicación que verifique el cumplimiento del Esquema, al menos cada dos años, para la cual se utilizarán los criterios, métodos de trabajo y de conducta generalmente reconocidos, así como la normalización nacional e internacional aplicable a la misma.

La seguridad de los sistemas de información de una organización **será auditada en los siguientes términos:**

- Que la **política de seguridad** define los roles y funciones de los responsables de la información, los servicios, los activos y la seguridad del sistema de información.
- Que existen **procedimientos para resolución de conflictos** entre dichos responsables.
- Que **se han designado personas** para dichos roles a la luz del principio de «separación de funciones».
- Que **se ha realizado un análisis de riesgos**, con revisión y aprobación anual.
- Que **se cumplen las recomendaciones de protección** descritas en el anexo II, sobre Medidas de Seguridad, en función de las condiciones de aplicación en cada caso.
- Que **existe un sistema de gestión de la seguridad de la información**, documentado y con un proceso regular de aprobación por la dirección.

Dicha auditoría se realizará **en función de la categoría del sistema.**

- **Los sistemas de información de categoría BÁSICA**, o inferior, no necesitarán realizar una auditoría. Bastará una autoevaluación realizada por el mismo personal que administra el sistema de información, o en quien éste delegue. Nada impide que un sistema de categoría BÁSICA se someta a un proceso de auditoría.
- **Para los sistemas de categoría MEDIA O ALTA** se realizará un informe de auditoría.

El **informe de auditoría** deberá dictaminar sobre el grado de cumplimiento de este real decreto identificando los hallazgos de cumplimiento e incumplimiento detectados; deberá, igualmente, incluir

los criterios metodológicos de auditoría utilizados, el alcance y el objetivo de la auditoría, y los datos, hechos y observaciones en que se basen las conclusiones formuladas, todo ello de conformidad con la **«Instrucción Técnica de Seguridad de Auditoría de la Seguridad de los Sistemas de Información»** que establece las condiciones para la realización de la preceptiva auditoría a la que deben someterse los sistemas de información del ámbito de aplicación del ENS.

Según esta instrucción, el informe de auditoría documentará los **hallazgos** aplicando la siguiente clasificación:

- «No Conformidad Menor»: Se documentará una «No Conformidad Menor» ante la ausencia o el fallo en la implantación o mantenimiento de uno o más de los requisitos del ENS, incluyendo cualquier situación que pudiese, en base a una evidencia objetiva, sustentar una duda significativa sobre la conformidad del sistema de información con uno o más de tales requisitos.
- «No Conformidad Mayor»: Se documentará una «No Conformidad Mayor» cuando se detecten «No Conformidades Menores» en relación con cualquiera de los preceptos contenidos en el RD 3/2010 (entiéndase 311/2022), o en el Marco organizativo, o en alguno de los subgrupos que integran el Marco operacional o las Medidas de protección (Planificación, Control de Accesos, Explotación, Servicios Externos, Continuidad del Servicio, Monitorización del Sistema, Protección de las Infraestructuras, Gestión del Personal, Protección de Equipos, Comunicaciones, Soportes de Información, Aplicaciones Informáticas, Información o Servicios) que, evaluadas en su conjunto, puedan implicar el incumplimiento del objetivo del Grupo o Subgrupo considerados.
- Se documentará una Observación cuando se encuentren evidencias de una debilidad, una vulnerabilidad o una situación que, sin comprometer cualquier área del sistema de gestión definida en el ENS o por la organización, pueda, en la actualidad o en el futuro, derivar en un problema.

El **dictamen final de la Auditoría de la Seguridad** será uno de los tres siguientes:

- «FAVORABLE»: Cuando no se evidencie ninguna «No Conformidad Mayor» o «No Conformidad Menor».
- «FAVORABLE CON NO CONFORMIDADES»: Cuando se evidencie cualquier no conformidad, mayor o menor. En este caso, la entidad titular responsable del sistema de información auditado deberá presentar, en el plazo máximo de un mes, un Plan de Acciones Correctivas sobre tales hallazgos de no conformidad a la entidad certificadora para su evaluación.
- «DESFAVORABLE»: Cuando, por el número o la trascendencia de las no conformidades detectadas, no sea posible decidir sobre su resolución a través de un Plan de Acciones Correctivas. En este caso se requerirá la realización de una auditoría extraordinaria que verifique la adopción de las medidas correctoras adecuadas.

Los informes de auditoría serán presentados al responsable del sistema y al responsable de seguridad competentes. Estos informes serán analizados por este último que presentará sus conclusiones al responsable del sistema para que adopte las medidas correctoras adecuadas.

Se contempla que, en el caso de los sistemas de categoría ALTA, visto el dictamen de auditoría, el responsable del sistema podrá acordar la retirada de operación de alguna información, de algún servicio o del sistema en su totalidad, durante el tiempo que estime prudente y hasta la satisfacción de las modificaciones prescritas.

Los informes de auditoría podrán ser requeridos por los responsables de cada organización, con competencias sobre seguridad de las tecnologías de la información, y por el CCN.

Son de interés las guías «CCN-STIC 802 Guía de auditoría», «CCN-STIC 804 Guía de Implantación», «CCN-STIC 808 Verificación del cumplimiento de las medidas en el ENS» y «CCN-STIC 824 Informe del Estado de Seguridad» que ofrecerá pautas de ayuda para el dictamen final de la Auditoría de la Seguridad.

3.3. La conformidad con el Esquema Nacional de Seguridad y relación con los mecanismos de certificación europeos

El artículo 38 sobre 'Procedimientos de determinación de la conformidad con el Esquema Nacional de Seguridad' señala que:

- Los sistemas de categoría MEDIA o ALTA precisarán de una auditoría para la **certificación de su conformidad**, sin perjuicio de la auditoría de la seguridad prevista en el artículo 31 que podrá servir asimismo para los fines de la certificación.
- Los sistemas de categoría BÁSICA solo requerirán de una autoevaluación para su **declaración de la conformidad**, sin perjuicio de que se puedan someter igualmente a una auditoría de certificación.

Se distingue por tanto entre la **Declaración de Conformidad**, de aplicación a sistemas de información de categoría BÁSICA, para la que bastaría con una autoevaluación; y la **Certificación de Conformidad**, de aplicación obligatoria a sistemas de información de categoría MEDIA o ALTA y voluntaria en el caso de sistemas de información de categoría BÁSICA, para la que se requiere una auditoría independiente.

El citado artículo 38 también establece que los sujetos responsables de los sistemas de información a que se refiere el apartado anterior darán **publicidad**, en los correspondientes portales de internet o sedes electrónicas a las declaraciones y certificaciones de conformidad con el ENS.

Tanto el procedimiento de autoevaluación, como la auditoría de certificación se realizarán según lo dispuesto en el artículo 31 'Auditoría de la seguridad' y en el anexo III 'Auditoría de la seguridad', así como en los términos establecidos en la «**Instrucción Técnica de Seguridad de Conformidad con el ENS**» que establece los criterios y procedimientos para la determinación de la conformidad, así como para la publicidad de los distintivos de seguridad obtenidos respecto al cumplimiento del ENS.

La citada Instrucción precisa también los **requisitos de las entidades certificadoras**, que quieran certificar el cumplimiento con el ENS.

ENAC es la entidad encargada de acreditar a las entidades de certificación que realizan las preceptivas auditorías de conformidad con el ENS, acreditación que se realiza conforme a la norma «UNE-EN ISO/IEC 17065:2012 Evaluación de la conformidad. Requisitos para organismos que certifican productos, procesos y servicios».

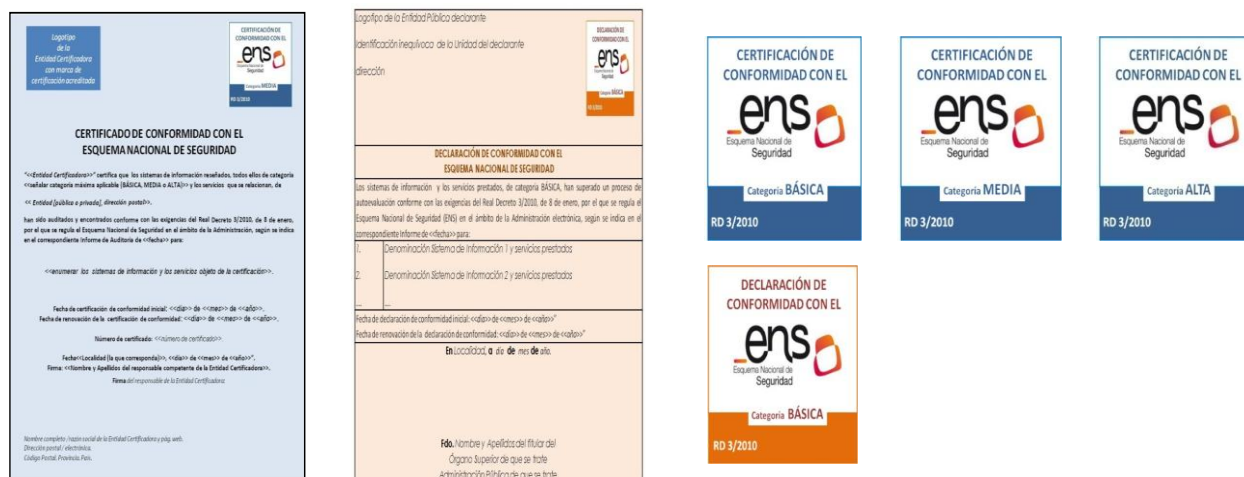


Figura 10. Declaración de conformidad, certificación de conformidad y distintivos asociados (Fuente: ITS de Conformidad con el ENS).

Como se ha apuntado más arriba al exponer el ámbito de aplicación del ENS, los **pliegos de prescripciones administrativas o técnicas** de los contratos que celebren las entidades del sector público **contemplarán todos aquellos requisitos necesarios para asegurar la conformidad con el ENS** de los sistemas de información en los que se sustenten los servicios prestados por los contratistas, tales como la presentación de las correspondientes Declaraciones o Certificaciones de Conformidad con el ENS.

La «Instrucción Técnica de Seguridad de Conformidad con el ENS», en su apartado VII sobre soluciones y servicios prestados por el Sector Privado, párrafo 1, establece que *“Cuando los operadores del Sector Privado presten servicios o provean soluciones a las entidades públicas, a los que resulte exigible el cumplimiento del Esquema Nacional de Seguridad, deberán estar en condiciones de exhibir la correspondiente Declaración de Conformidad con el Esquema Nacional de Seguridad, cuando se trate de sistemas de categoría BÁSICA, o la Certificación de Conformidad con el Esquema Nacional de Seguridad, cuando se trate de sistemas de categorías MEDIA o ALTA, utilizando los mismos procedimientos que los exigidos en esta Instrucción Técnica de Seguridad para las entidades públicas”*.

Se refuerza lo anterior con lo establecido en párrafo VII.2 al establecer que *“Es responsabilidad de las entidades públicas contratantes notificar a los operadores del Sector Privado que participen en la provisión de soluciones tecnológicas o la prestación de servicios, la obligación de que tales soluciones o servicios sean conformes con lo dispuesto en el Esquema Nacional de Seguridad y posean las correspondientes Declaraciones o Certificaciones de Conformidad”*.

Además, se añade lo indicado en el párrafo VII.3 en cuanto a que *“Cuando la provisión de las soluciones o la prestación de los servicios sujetos al cumplimiento del Esquema Nacional de Seguridad sean realizados por operadores del Sector Privado, estos utilizarán los mismos modelos documentales utilizados para las Declaraciones, las Certificaciones o los Distintivos de Conformidad...”*.

La lista de entidades del Sector Público certificadas se puede consultar en el Portal del CCN-CERT, en la sección del ‘ENS’, y en el apartado ‘Certificación’. En este mismo apartado se puede consultar también la relación de empresas certificadas en el ENS.

Igualmente, en dicha sección de ‘Certificación’ se pueden consultar las entidades de certificación acreditadas o en vías de acreditación por ENAC.

Se añaden a las entidades de certificación los denominados **Órganos de Auditoría Técnica del ENS del Sector Público (OAT)** cuyo procedimiento de reconocimiento se establece en la Guía CCN-STIC 122 “Procedimiento de Reconocimiento y Requisitos del Órgano de Auditoría Técnica del ENS”. Se trata, como se precisa en dicha guía de reconocer formalmente que *“la capacidad técnica y resto de requisitos de aquellas entidades, organismos, órganos y unidades vinculadas o dependientes de las Administraciones Públicas cuyas competencias incluyan el desarrollo de auditorías de sistemas de información, así conste en su normativa de creación o decretos de estructura, quede garantizada la debida imparcialidad y la ausencia de conflicto de intereses entre los elementos auditor y auditado, en relación con las Auditorías de Seguridad exigidas por el Esquema Nacional de Seguridad (ENS) de cara a alcanzar la preceptiva Certificación de Conformidad con el ENS”*.

El **Consejo de Certificación del ENS (CoCENS)**, que se trata más adelante, es el actor clave para velar por la adecuada implantación de la certificación de la conformidad con el ENS.

Dicho lo anterior, interesa también la relación con los mecanismos de certificación en el ámbito europeo.

El **Reglamento (UE) 2019/881, conocido como el “Cybersecurity Act”** encomienda a la Agencia de Ciberseguridad de la Unión Europea ENISA la creación del marco europeo de certificación de la ciberseguridad con el objetivo de crear un mercado único digital para los productos, servicios y procesos de TIC que permitirá que los certificados emitidos en los Estados miembros sean válidos en toda la Unión Europea.

En este marco, ENISA estableció el Grupo Europeo de Certificación (*European Certification Group – EUCG*), grupo de trabajo ad hoc que viene trabajando en los siguientes esquemas candidatos:

- **“Esquema europeo de certificación europeo basado en los criterios comunes” (Common Criteria based European Certification Scheme – EUCC).**

El esquema EUCC persigue la certificación de la ciberseguridad de productos de las tecnologías de la información sobre la base de los Criterios Comunes, la Metodología Común de Evaluación de la Seguridad de Tecnología de la Información y de las normas correspondientes, en particular, de ISO/IEC 15408 e ISO/IEC 18045. Vendrá a sustituir a los esquemas que operan bajo el ámbito de SOG-IS MRA.

La Comisión establecerá el Esquema EUCC mediante el correspondiente acto o actos de ejecución.

El Esquema Nacional de Seguridad contempla en su artículo 19 la adquisición de productos que tengan certificada la funcionalidad de seguridad, el papel del Organismo de Certificación del Esquema Nacional de evaluación y Certificación de la Seguridad de las Tecnologías de la Información y el Catálogo de Productos y Servicios de Seguridad de las Tecnologías de la Información y Comunicación (Guía CCN-STIC 105).

- **“Esquema europeo de certificación de seguridad de servicios en la nube” (*European Union Certification Scheme on Cloud Services – EUCS*).**

El proyecto de esquema EUCS, publicado el 22 de diciembre de 2020, persigue armonizar la seguridad de los servicios en la nube con las regulaciones de la Unión Europea, los estándares internacionales, las mejores prácticas de la Industria, así como con las certificaciones existentes en los Estados miembros de la UE.

Algunos rasgos destacables del “Esquema de certificación de seguridad de servicios en la nube” son: carácter voluntario; sus certificados serán de aplicación en los Estados miembros de la Unión Europea; aplicable a todo tipo de servicios en la nube; definición de un conjunto de requisitos de seguridad; establecimiento de tres escalones: ‘BAJO’, ‘MEDIO’ y ‘ALTO’; inspirado en esquemas nacionales y en estándares internacionales; certificados válidos durante tres años y renovables; requisitos de transparencia en relación con la ubicación y almacenamiento de los datos.

La Comisión establecerá el Esquema EUCS mediante el correspondiente acto o actos de ejecución.

En relación con el EUCS el Esquema Nacional de Seguridad incluye la nueva familia de medidas ‘Servicios en la nube [op.nub.]’ con la medida ‘Protección de servicios en la nube [op.nub.1]’ que incluye el requisito básico [op.nub.1.2] que establece que cuando se utilicen servicios en la nube suministrados por terceros, los sistemas de información que los soportan deberán ser conformes con el Esquema Nacional de Seguridad o cumplir con las medidas desarrolladas en una guía del Centro Criptológico Nacional que incluirá, entre otros, requisitos relativos a: auditoría de pruebas de penetración, transparencia, cifrado y gestión de claves y jurisdicción de los datos.

Además, la citada medida [op.nub.1] incluye el refuerzo [op.nub.1.r1.1] que establece que cuando se utilicen servicios en la nube suministrados por terceros, estos deberán estar certificados bajo una metodología de certificación reconocida por el Organismo de Certificación del Esquema Nacional de Evaluación y Certificación de Seguridad de las Tecnologías de la Información. Este refuerzo prevé que los servicios en la nube suministrados por terceros cuenten con la certificación europea en el “Esquema de certificación de seguridad de servicios en la nube” (que NO sustituye al Esquema Nacional de Seguridad) cuando esté formalmente adoptado.

3.4. El Esquema Nacional de Seguridad y la norma ISO/IEC 27001

El ENS requiere la protección de la información y los servicios, proporcionada para racionalizar la implantación de las medidas de seguridad, contempla aspectos de interés específico para el Sector Público de una forma amplia y exhaustiva, a la vez que precisa los requisitos de seguridad y exige la gestión continuada de la seguridad. En concreto, la medida ‘Arquitectura de seguridad [op.pl.2]’ incluye los refuerzos:

- R1 ‘Sistema de gestión’, con el requisito “[op.pl.2.r1.1] *Sistema de gestión, relativo a la planificación, organización y control de los recursos relativos a la seguridad de la información.*”
- R2 ‘Sistema de gestión de la seguridad con mejora continua’, con el requisito “[op.pl.2.r2.1] *Sistema de gestión de la seguridad de la información, con actualización y aprobación periódica.*”

Los anteriores refuerzos implican que el ENS requiere la aplicación de un sistema de gestión de la seguridad de la información, conocido de forma abreviada como SGSI. Este concepto de SGSI es utilizado principalmente por la norma **«UNE-EN ISO/IEC 27001:2017 Tecnología de la información. Técnicas de seguridad. Sistemas de Gestión de la Seguridad de la Información. Requisitos»**; norma **que proporciona los requisitos para la construcción** (y posterior certificación, en su caso) **de un sistema de gestión de seguridad de la información**.

Desde la concepción del ENS existe un diálogo con la norma ISO/IEC 27001 por ser este un referente que, en su día, cabía aplicar en ausencia de otros instrumentos específicos para el Sector Público, por la potencial complementariedad entre ambos y por ser una exigencia por parte de la Comisión Europea para ciertas entidades de la Administración como se expone a continuación.

La relación entre el ENS y la norma ISO/IEC 27001 es de particular interés para aquellas entidades del Sector Público que tienen la obligación de estar certificadas de conformidad con la norma ISO/IEC 27001.

Es el caso de los **organismos pagadores y de coordinación de los fondos europeos agrícolas** según lo previsto en el Reglamento Delegado (UE) 907/2014 de la Comisión, de 11 de marzo de 2014, que completa el Reglamento (UE) 1306/2013 del Parlamento Europeo y del Consejo; con el interés de que dicho Reglamento Delegado establece que la Comisión podrá autorizar a los estados miembros para certificar la seguridad de sus sistemas de información de conformidad con otras normas aceptadas, siempre y cuando garanticen un nivel de seguridad equivalente, como mínimo, al previsto en la norma ISO/IEC 27001.

Para orientar a estos organismos pagadores, así como a otras entidades interesadas en aplicar ambos instrumentos en combinación (más las auditoras), se han desarrollado las guías CCN-STIC que se citan a continuación.

La guía «**CCN-STIC-825** Esquema Nacional de Seguridad. Certificaciones 27001» explica la aplicación y en su caso certificación 27001 como soporte de cumplimiento del ENS, a la vez que ayuda a determinar qué controles del Anexo A de la norma ISO/IEC 27001, desarrollados en la norma ISO/IEC 27002, son necesarios para cumplimiento de cada medida del Anexo II del ENS y, en su caso, qué elementos adicionales son requeridos.

La Guía «**CCN-STIC-852** Aplicación del ENS en organismos pagadores» persigue identificar la equivalencia entre los requisitos del ENS y los de ISO/IEC 27001/27002, así como las medidas adicionales necesarias a aplicar de forma que el ENS, en el ámbito de los organismos pagadores, pueda ser considerado como una alternativa aceptada por la Comisión, y así evitar el exceso de carga de trabajo y recursos que implica mantener ambas normativas.

A la fecha de redacción de este tema se progresa en un **perfil de cumplimiento específico para los organismos pagadores** y de coordinación de fondos europeos agrícolas.

Dicho lo anterior, puede haber, aparte de la norma ISO/IEC 27001, otros referentes para la implantación de un sistema de gestión de la seguridad de la información; pero no se han suscitado en relación con el ENS a lo largo de su historia hasta el momento y carecerían del carácter de norma internacional y nacional de la citada UNE ISO/IEC 27001.

3.5. El informe nacional del estado de la seguridad (INES)

El artículo 32 'Informe del estado de la seguridad' del ENS trata la recogida de información que permita conocer regularmente el estado general de la seguridad en el Sector Público y su plasmación, con periodicidad anual, en el Informe del estado de la seguridad, conocido como **informe INES**.

Entre las medidas de seguridad del ENS, la medida '**Sistema de métricas**' [op.mon.2] contempla que para la categoría BÁSICA se recopilarán los datos necesarios para conocer el grado de implantación de las medidas de seguridad que apliquen y para proveer el informe anual requerido por el artículo 32; para las categorías MEDIA y ALTA, además, se recopilarán datos para evaluar el comportamiento del sistema de gestión de incidentes, de acuerdo con la Instrucción Técnica de Seguridad de Notificación de Incidentes de Seguridad y con la correspondiente guía CCN-STIC; y se recopilarán los datos precisos para conocer la eficiencia del sistema de seguridad, en relación con los recursos consumidos, en términos de horas y presupuesto.

La herramienta INES facilita la recogida y consolidación de información para la elaboración de este Informe, según las condiciones indicadas en la «Instrucción Técnica de Seguridad de Informe del Estado de la Seguridad» y los detalles explicados en la guía «CCN-STIC 824 Información del Estado de Seguridad».

Sobre la base de la información recogida se produce un informe general e informes específicos, para la Administración General del Estado, las Comunidades Autónomas, las Entidades Locales y las Universidades Públicas (CRUE) y otros ámbitos.

4. CAPACIDADES DE CIBERSEGURIDAD, EL CCN-CERT Y LAS GUÍAS CCN-STIC

4.1. EL CCN-CERT

El **CCN-CERT** es la capacidad de respuesta ante incidentes de seguridad de la información del Centro Criptológico Nacional, CCN, adscrito al Centro Nacional de Inteligencia, CNI. Se creó en el año 2006 como CERT Gubernamental Nacional español y sus funciones quedaron recogidas en la Ley 11/2002 reguladora del CNI, el Real Decreto 421/2004 de regulación del CCN y en el Real Decreto 3/2010 (a la fecha ya en el Real decreto 311/2022).

Además, en el «Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información», en su artículo 11 'Equipos de respuesta a incidentes de seguridad informática de referencia' se establece que le corresponde al CCN-CERT la coordinación nacional de la respuesta técnica de los equipos de respuesta a incidentes de seguridad informática (CSIRT) en materia de seguridad de las redes y sistemas de información del sector público comprendido en la Ley 39/2015 y en la Ley 40/2015.

También en el citado Real Decreto-ley 12/2018 se establece que, en los supuestos de especial gravedad que reglamentariamente se determinen y que requieran un nivel de coordinación superior al necesario en situaciones ordinarias, el CCN-CERT ejercerá la coordinación nacional de la respuesta técnica de los CSIRT (equipos de respuesta a incidentes de seguridad informática - Computer Security Incident Response Team). También ejercerá el CCN la función de enlace para garantizar la cooperación transfronteriza de los CSIRT de las Administraciones Públicas con los CSIRT internacionales, en la respuesta a los incidentes y gestión de riesgos de seguridad que les correspondan.

En el ámbito específico del ENS, de acuerdo con lo establecido en el artículo 33 del real Decreto 311/2022, **el CCN articulará la respuesta a los incidentes de seguridad en torno a la estructura denominada CCN-CERT** (por su acrónimo en inglés de Computer Emergency Response Team), que actuará sin perjuicio de las capacidades de respuesta a incidentes de seguridad que pueda tener cada administración pública y de la función de coordinación a nivel nacional e internacional del CCN citada más arriba.

Según el artículo 34 del ENS, **el CCN-CERT prestará los siguientes servicios:**

- a) **Soporte y coordinación para el tratamiento de vulnerabilidades y la resolución de incidentes** de seguridad que tengan las entidades del ámbito de aplicación de este real decreto.
- b) **Investigación y divulgación de las mejores prácticas** sobre seguridad de la información entre todos los miembros de las entidades del sector público. Con esta finalidad, las series de documentos CCN-STIC (CCN-Seguridad de las Tecnologías de Información y la Comunicación), elaboradas por el CCN, ofrecerán normas, instrucciones, guías, recomendaciones y mejores prácticas para aplicar el ENS y para garantizar la seguridad de los sistemas de información del ámbito de aplicación de este real decreto.
- c) **Formación destinada al personal del sector público especialista** en el campo de la seguridad de las tecnologías de la información, al objeto de facilitar la actualización de conocimientos y de lograr la sensibilización y mejora de sus capacidades para la prevención, detección y gestión de incidentes.
- d) **Información sobre vulnerabilidades, alertas y avisos** de nuevas amenazas a los sistemas de información, recopiladas de diversas fuentes de reconocido prestigio, incluidas las propias.

Dicho lo anterior, **las entidades del sector público notificarán al CCN aquellos incidentes** que tengan un impacto significativo en la seguridad de los sistemas de información concernidos, de acuerdo con la correspondiente Instrucción Técnica de Seguridad. Y **tras un incidente de seguridad, el CCN-CERT** determinará técnicamente el riesgo de reconexión del sistema o sistemas afectados, indicando los procedimientos a seguir y las salvaguardas a implementar con objeto de reducir el impacto para, en la medida de lo posible, evitar que vuelvan a darse las circunstancias que lo propiciaron.

4.2. Soluciones de ciberseguridad proporcionadas por el CCN

El CCN proporciona una colección de **soluciones de ciberseguridad** “*que garanticen la seguridad de los sistemas y contribuyan a una mejor gestión de la ciberseguridad en cualquier organización y permitan una mejor defensa frente a los ciberataques*”.

Se trata de soluciones para las cuestiones siguientes (sin exhaustividad en la relación de soluciones):

- gestión de la ciberseguridad y conformidad con el ENS (AMPARO)
- automatización y normalización de auditorías (ANA)
- protección y trazabilidad del dato (CARLA)
- informe del estado de la seguridad (INES)
- gestión de ciberincidentes (LUCIA)
- búsqueda de indicios y anomalías (CARMEN)
- detección de amenazas complejas en el puesto de usuario (CLAUDIA) y vacunación (microCLAUDIA)
- intercambio de información de ciberinteligencia (REYES)
- sistemas de alerta temprana (SAT)
- análisis de malware (ADA)
- análisis de riesgos (PILAR)
- formación (VANESA)

4.3. Las guías de seguridad CCN-STIC

La disposición adicional segunda ‘Desarrollo del Esquema Nacional de Seguridad’ trata también las guías de seguridad (**guías CCN-STIC**) para el mejor cumplimiento de lo establecido en el Real Decreto 311/2022, que elaborará y difundirá el CCN en el ejercicio de sus competencias, particularmente de la **serie 800**, y que se incorporarán al conjunto documental utilizado para la realización de las auditorías de seguridad.

Las guías CCN-STIC se encuentran disponibles en el Portal del CCN-CERT. La serie 800 relativa al ENS incluye a la fecha más de 100 guías. A lo largo de este tema se van citado diversas guías de particular interés para ciertos temas tales como auditoría, informe del estado de la seguridad, notificación de incidentes de seguridad o ámbito de aplicación del ENS. Además, son de particular interés las guías siguientes: CCN-STIC-801 Responsabilidades y Funciones en el ENS y CCN-STIC-803 Valoración de Sistemas en el ENS.

4.4. El Centro de Operaciones de Ciberseguridad de la Administración General del Estado y sus Organismos Públicos

También es especialmente reseñable como capacidad de ciberseguridad el **Centro de Operaciones de Ciberseguridad** de la Administración General del Estado y sus organismos públicos (COCS), previsto en la Medida 9 del Plan de Digitalización de las Administraciones Públicas 2021 – 2025, que reforzará a través de servicios horizontales de ciberseguridad las capacidades de prevención, protección, detección y respuesta ante incidentes de ciberseguridad, de forma que gracias a la optimización y las economías de escala se obtenga una mejor eficacia y eficiencia.

El COCS es responsabilidad de la Secretaría General de Administración Digital (SGAD) que asume la dirección técnica y estratégica del servicio. El CCN-CERT pone a disposición su apoyo al despliegue del COCS, su capacidad de operación de ciberseguridad, herramientas y soluciones de ciberseguridad, así como capacidades de investigación y respuesta experta ante incidentes de seguridad complejos. Así mismo apoya a la SGAD en la dirección técnica y estratégica del servicio y en el seguimiento y ejecución del contrato.

El COCS ha de contribuir a mejorar la situación de seguridad de cada entidad y su grado de conocimiento, así como a actuar como elemento facilitador para el cumplimiento del Esquema Nacional de Seguridad (ENS).

4.5. La Red Nacional de Centros de Operaciones de Ciberseguridad

La **Red Nacional de Centros de Operaciones de Ciberseguridad** es una iniciativa del Centro Criptológico Nacional que persigue integrar una amplia tipología de centros del ámbito nacional, y que permitirá el intercambio de información de ciberincidentes, compartir reglas para la vigilancia y la detección, capacidad de correlación de logs, así como el intercambio de ciberinteligencia con la Plataforma Nacional de Notificación y Seguimiento de Ciberincidentes.

Se trata de una iniciativa estrechamente relacionada, por un lado, con la promoción de capacidades de ciberseguridad en Entidades Locales y Comunidades Autónomas, mediante los instrumentos del Plan de Recuperación, Transformación y Resiliencia, de forma que la ciberseguridad sea un elemento prioritario en los proyectos de transformación digital de las Administraciones, a través de la implantación en las Administraciones Públicas de servicios de ciberseguridad destinados a mejorar sus capacidades de prevención, protección, detección y respuesta ante incidentes de ciberseguridad, así como la mejora de la adecuación al Esquema Nacional de Seguridad. Y, por otro lado, relacionada también con los trabajos para desplegar una red transfronteriza de centros de operaciones de ciberseguridad bajo el liderazgo de la Comisión Europea, en el contexto de las actuaciones del Centro Europeo de Competencias en Ciberseguridad y de la financiación a través de instrumentos tales como el Programa Europa Digital (Digital Europe Programme) en su línea de ciberseguridad.

5. MÁS CUESTIONES A LAS QUE HAY QUE PRESTAR ATENCIÓN

Al cierre de la redacción del presente tema se encuentran en curso las siguientes **cuestiones que merecen atención** por su relación con lo tratado más arriba y por su finalización en fechas próximas.

5.1. En el ámbito europeo

En el ámbito europeo conviene prestar atención a los siguientes:

- Propuesta de DIRECTIVA DEL PARLAMENTO EUROPEO Y DEL CONSEJO relativa a las medidas destinadas a garantizar un elevado nivel común de ciberseguridad y por la que se deroga la Directiva (UE) 2016/1148.
- Conclusiones del Consejo de la seguridad de la cadena de suministro.
- Propuesta de REGLAMENTO DEL PARLAMENTO EUROPEO Y DEL CONSEJO sobre la seguridad de la información en las instituciones, órganos y organismos de la Unión.
- Propuesta de REGLAMENTO DEL PARLAMENTO EUROPEO Y DEL CONSEJO por el que se establecen medidas destinadas a garantizar un elevado nivel común de ciberseguridad en las instituciones, los órganos y los organismos de la Unión.
- Esquema europeo de certificación europeo basado en los criterios comunes (Common Criteria based European Certification Scheme - EUCC).
- Esquema europeo de certificación de seguridad de servicios en la nube (European Union Certification Scheme on Cloud Services – EUCCS).

En la Unión Europea la actuación en materia de ciberseguridad se viene intensificando en los últimos tiempos de forma que cabe esperar novedades en materia del marco legal, de la gobernanza, la cooperación y la construcción de comunidad, así como de capacidades de ciberseguridad según la perspectiva que se ofrece en la figura siguiente.

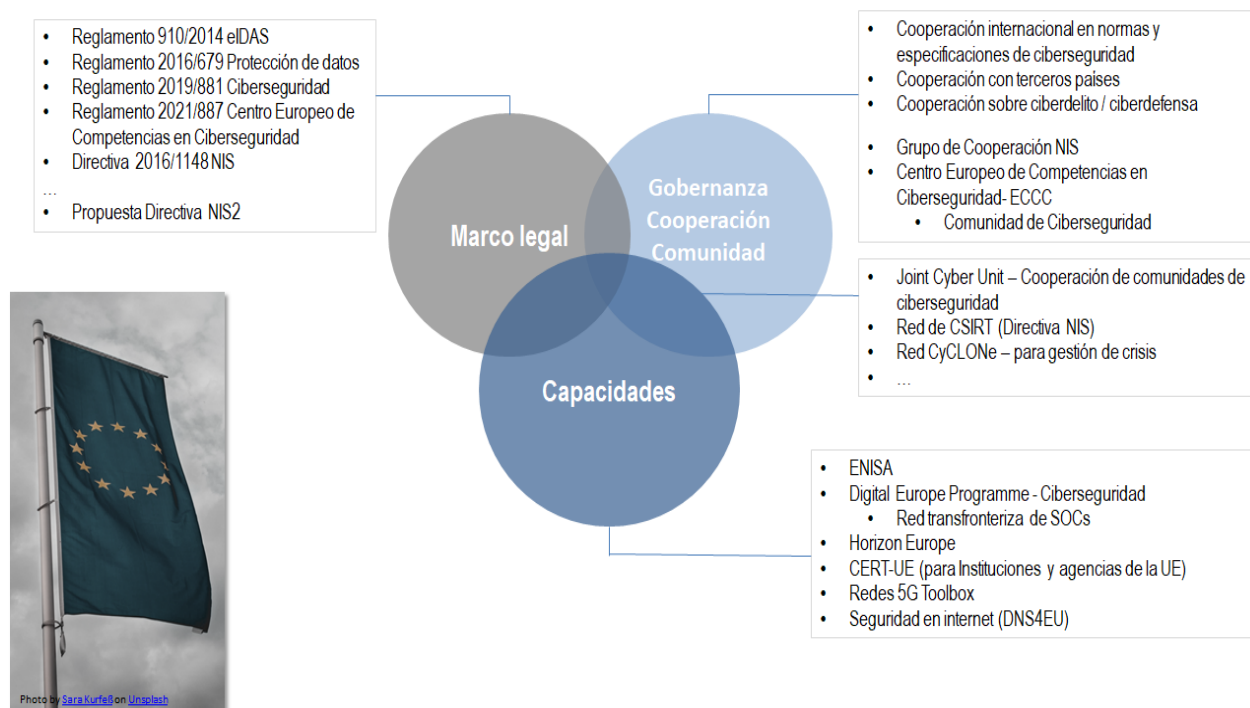


Figura 11. Panorámica de marco legal; gobernanza, cooperación y comunidad; y capacidades de ciberseguridad en la Unión Europea. (Fuente: Miguel A. Amutio)

5.2. En el ámbito nacional

En el ámbito nacional conviene prestar atención a los siguientes:

- Instrumentos de contratación dinámicos para la adquisición de software y hardware de ciberseguridad.
- Anteproyecto de Ley de Información Clasificada.

6. RESUMEN ESQUEMÁTICO

En el capítulo 1 se exponen el **Sistema de Seguridad Nacional** con sus componentes principales desde el punto de vista de la ciberseguridad (Consejo de Seguridad Nacional, Comité Especializado de Situación, Consejo Nacional de Ciberseguridad, Comisión Permanente de Ciberseguridad, Foro Nacional de Ciberseguridad); las estrategias (Estrategia de Seguridad Nacional 2021 y Estrategia Nacional de Ciberseguridad 2019); las claves de la Protección de Infraestructuras Críticas (marco legal, actores y organización del sistema PIC, sectores estratégicos, planes estratégicos sectoriales, operadores críticos, nivel de alerta de infraestructuras críticas); y, finalmente, la seguridad de las redes y sistemas de información (servicios esenciales, servicios digitales, autoridades competentes, CSIRTS de referencia, obligaciones de seguridad, y obligación de los operadores de servicios esenciales y de los proveedores de servicios digitales de notificar los incidentes de seguridad que puedan tener efectos perturbadores significativos).

Es preciso tener conocimiento de los siguientes aspectos esenciales de la **ciberseguridad en la Seguridad Nacional**:

- **En relación con el Sistema de Seguridad Nacional interesan:** lo establecido al respecto en la Ley 36/2015, de 28 de septiembre, de Seguridad Nacional, y la estructura institucional con el Consejo de Seguridad Nacional, el Consejo Nacional de Ciberseguridad, el Comité Especializado de Situación y el Departamento de Seguridad Nacional.
- **En relación con la Estrategia de Seguridad Nacional 2021 interesa** especialmente lo que se apunta sobre el ciberespacio y la ciberseguridad en sus capítulos 3 y 4.
- **En relación con la Estrategia Nacional de Ciberseguridad 2019 interesan:** el propósito, los principios por los que se rige, el objetivo general y los 5 objetivos específicos para la ciberseguridad, las 7 líneas de acción y sus medidas, y la ciberseguridad en el Sistema de Seguridad Nacional, con especial atención a aquellos aspectos especialmente dirigidos a la seguridad de la Administración y del Sector Público en general (objetivo I y línea de acción 2).
- **En relación con la Protección de Infraestructuras Críticas interesan:** el marco legal (Ley 8/2011 y Real Decreto 704/2011), el concepto de infraestructura crítica y los 12 sectores estratégicos, la estructura organizativa del sistema PIC, con el Centro Nacional para la Protección de las Infraestructuras Críticas (CNPIC) y su Oficina de Coordinación Cibernética (OCC) y la Comisión Nacional PIC; los planes estratégicos sectoriales (PES); y los Operadores Críticos y sus obligaciones.
- **En relación con la seguridad de las redes y sistemas de información interesan,** el marco legal de la seguridad de las redes y sistemas de información (Real Decreto-ley 12/2018 y Real Decreto 43/2021); los servicios esenciales y los servicios digitales; quiénes son los operadores de servicios esenciales y los prestadores de servicios digitales; cuáles son las autoridades competentes; cuáles son los CSIRTS de referencia; las obligaciones de seguridad de los operadores de servicios esenciales y de los proveedores de servicios digitales; y la obligación de los operadores de servicios esenciales y de los proveedores de servicios digitales de notificar a la autoridad competente, a través del correspondiente CSIRT de referencia, los incidentes de seguridad que puedan tener efectos perturbadores significativos.

En el capítulo 2 se desarrolla de forma pormenorizada el **Esquema Nacional de Seguridad (ENS)**: la seguridad para la administración digital; desarrollo del ENS; objetivos del ENS; estructura y contenido del ENS; ámbito de aplicación del ENS; los principios básicos; la política de seguridad; los requisitos mínimos; el mecanismo para el cumplimiento de los requisitos mínimos; las medidas de seguridad; el uso de infraestructuras y servicios comunes; los perfiles de cumplimiento específicos; la auditoría de la seguridad; el informe nacional del estado de la seguridad (INES); la respuesta a incidentes de seguridad; el uso de productos y servicios de seguridad; las instrucciones técnicas de seguridad; las guías de seguridad CCN-STIC; las capacidades, servicios y soluciones de ciberseguridad; la adecuación al Esquema Nacional de Seguridad; el Esquema Nacional de Seguridad y la norma ISO/IEC 27001; la conformidad con el Esquema Nacional de Seguridad y relación con los mecanismos de certificación europeos; la formación; y la gobernanza, cooperación y comunidad.

Es preciso tener conocimiento particularmente de los siguientes aspectos esenciales del **Esquema Nacional de Seguridad**:

- **La base legal del ENS: Real Decreto 311/2022**, más las referencias al ENS en las leyes 40/2015 y 39/2015, en la Ley Orgánica 3/2018, en el Real Decreto-ley 12/2018 y en el Real Decreto 43/2021.
- El **ámbito de aplicación del ENS** que abarca a todo el sector público, a los sistemas que tratan información clasificada, a los sistemas de información de las entidades del sector privado que presten servicios o provean soluciones a las entidades del sector público para el ejercicio por estas de sus competencias y potestades administrativas. Que, además, los pliegos de prescripciones administrativas o técnicas contemplarán todos aquellos requisitos necesarios para asegurar la conformidad con el ENS. Y que esta cautela se extenderá también a la cadena de suministro.
- Los **principios básicos**, los **requisitos mínimos** y el mecanismo para su cumplimiento a través de la **categorización**.
- Las **medidas de seguridad**: marco organizativo, marco operacional y medidas de protección; con su enfoque de **requisitos** y de **refuerzos** codificados; la **declaración de aplicabilidad**; y aplicación del nivel de madurez a la implantación de las medidas.
- Qué son los **perfiles de cumplimiento específicos**.
- **La respuesta a incidentes de seguridad y el papel de los diversos actores**: CCN-CERT, Secretaría General de Administración Digital, Intervención General de la Administración del Estado, Oficina de Coordinación de Ciberseguridad, ESPDEF-CERT e INCIBE-CERT.
- El papel de **infraestructuras y servicios comunes** en relación con la seguridad.
- El uso de **productos y servicios de seguridad**, su adquisición y el Catálogo de Productos y Servicios de Seguridad de las Tecnologías de la Información y Comunicación (Guía CCN-STIC 105).
- Las **instrucciones técnicas de seguridad** publicadas: informe del estado de la seguridad, auditoría de la seguridad, conformidad con el ENS y notificación de incidentes de seguridad.
- La **cooperación y gobernanza** en el ámbito del ENS, el papel de la Secretaría General de Administración Digital, del Centro Criptológico Nacional, del Comité de Dirección de las Tecnologías de la Información y las Comunicaciones, de la Comisión Sectorial de Administración Electrónica, del Consejo de Certificación del ENS (CoCENS) y la relación con los mecanismos de certificación europeos.

En el capítulo 3 se tratan:

- La **adecuación al Esquema Nacional de Seguridad**: interesan los aspectos básicos que se han de abordar, los referentes y la solución que apoya que proporciona el CCN denominada AMPARO.
- La **auditoría** de la seguridad: interesan especialmente, la periodicidad, los términos de la auditoría, qué sistemas se encuentran sujetos a la auditoría y la relación con la categorización.
- La **conformidad** con el Esquema Nacional de Seguridad: interesa comprender de forma clara la declaración de conformidad y la certificación de conformidad con el ENS, cuándo aplican y cuáles son sus diferencias. También se apuntan en este capítulo unas claves de los mecanismos de certificación europeos y se referencian esquemas europeos de certificación en curso de elaboración a la fecha.
- La **relación del ENS con la norma ISO/IEC 27001**: es preciso comprender qué es cada instrumento y cómo se relacionan entre sí.
- Y el **informe** nacional del estado de la seguridad (INES): interesa conocer qué información maneja el informe y qué herramienta se usa para su recogida.

En el capítulo 4 se tratan capacidades, servicios y soluciones de ciberseguridad:

- Se explica **qué es el CCN-CERT**, qué servicios presta y cuál es su actuación en el ámbito del ENS.
- También se tratan las **soluciones proporcionadas por el CCN**.
- El **Centro de Operaciones de Ciberseguridad de la Administración General del Estado y sus Organismos Públicos**. Interesa saber qué es y las capacidades principales que proporciona.

- La **Red Nacional de Centros de Operaciones de Ciberseguridad**. Interesa saber qué es y su relación con otros instrumentos.
- Las **guías de seguridad CCN-STIC**, interesan particularmente las guías de la serie 800 que son las que se elaboran para el ámbito del ENS.

En el capítulo 5 se apunta una serie de cuestiones que, al cierre de la redacción del presente tema, se encuentran en curso y que merecen atención, en los ámbitos de la Unión Europea y nacional, por su relación con todo lo tratado en relación con la ciberseguridad nacional y con el Esquema Nacional de Seguridad y por su finalización prevista en fechas próximas.

7. GLOSARIO

El glosario de términos relativo a las cuestiones tratadas en este tema, generales de ciberseguridad y específicos del Esquema Nacional de Seguridad es de una extensión potencialmente considerable. Para facilitar la comprensión de los términos de forma exhaustiva que aparecen en este tema se recomienda manejar las siguientes fuentes:

- Guía CCN-STIC 800 Glosario de términos y abreviaturas del ENS
- Real Decreto 311/2022, Anexo IV Glosario
- Diccionario de términos y conceptos de la Administración Electrónica.

No obstante, para facilitar la comprensión del tema de una forma más autocontenida se incluye a continuación una selección de términos.

- **Activo:** Componente o funcionalidad de un sistema de información susceptible de ser atacado deliberada o accidentalmente con consecuencias para la organización. Incluye: información, datos, servicios, aplicaciones (software), equipos (hardware), comunicaciones, recursos administrativos, recursos físicos y recursos humanos.
- **Administrador del sistema/de la seguridad del sistema:** Persona encargada de la instalación y el mantenimiento de un sistema de información, implantando los procedimientos y la configuración de seguridad que se haya establecido en el marco de la política de seguridad del organismo.
- **Análisis de riesgos:** Estudio de las consecuencias previsibles de un posible incidente de seguridad, considerando su impacto en la organización (en la protección de sus activos, en su misión, en su imagen o reputación, o en sus funciones) y la probabilidad de que ocurra.
- **Área controlada:** Zona o área en la que una organización considera cumplidas las medidas de seguridad físicas y procedimentales requeridas para la protección de la información y los sistemas de información ubicados en ella.
- **Arquitectura de seguridad:** Conjunto de elementos físicos y lógicos que forman parte de la arquitectura del sistema y cuyo objetivo es la protección de los activos dentro del sistema y en las interconexiones con otros sistemas.
- **Auditoría de la seguridad:** Es un proceso sistemático, independiente y documentado que persigue la obtención de evidencias objetivas y su evaluación objetiva para determinar en qué medida se cumplen los criterios de auditoría en relación con la idoneidad de los controles de seguridad adoptados, el cumplimiento de la política de seguridad, las normas y los procedimientos operativos establecidos, y detectando desviaciones a los antedichos criterios.
- **Autenticación:** Ratificación de la identidad de un usuario, proceso o dispositivo.
- **Autenticación multifactor:** Exigencia de dos o más factores de autenticación para ratificar una autenticación como válida.
- **Autenticidad:** Propiedad o característica consistente en que una entidad es quien dice ser o bien que garantiza la fuente de la que proceden los datos.
- **Cadena de suministro:** Conjunto relacionado de recursos y procesos que comienza con la provisión de materias primas y se extiende a través de la entrega de productos o servicios al usuario final a través de los modos de transporte. Incluye a los proveedores (primer, segundo y tercer nivel), los almacenes de materia prima (directa o indirecta), las líneas de producción, los almacenes de productos terminados y los canales de distribución (mayoristas y minoristas), hasta llegar al cliente final.
- **Categoría de seguridad de un sistema:** Es un grado, dentro de la escala Básica-Media-Alta, con el que se adjetiva un sistema de información a fin de seleccionar las medidas de seguridad necesarias para el mismo. La categoría de seguridad del sistema recoge la visión holística del conjunto de activos como un todo armónico, orientado a la prestación de unos servicios.
- **Ciberamenaza:** Amenaza a los sistemas y servicios presentes en el ciberespacio o alcanzables a través de éste.
- **Ciberataque:** Cualquier conducta dolosa de individuos u organizaciones, conocidos o no, desarrollada a través del ciberespacio contra sistemas de información, con el propósito de sustraer, alterar, abusar, desestabilizar, inutilizar, destruir o eliminar activos.

- **Ciberespacio:** Dominio global y dinámico compuesto por infraestructuras de tecnología de la información -incluyendo internet-, redes de telecomunicaciones y sistemas de información que configura un ámbito virtual.
- **Ciberincidente:** Incidente relacionado con la seguridad de las tecnologías de la información y las comunicaciones que se produce en el ciberespacio.
- **Ciberseguridad (seguridad de los sistemas de información):** La capacidad de las redes y sistemas de información de resistir, con un nivel determinado de fiabilidad, toda acción que comprometa la disponibilidad, autenticidad, integridad o confidencialidad de los datos almacenados, transmitidos o tratados, o los servicios correspondientes ofrecidos por tales redes y sistemas de información o accesibles a través de ellos.
- **Compromiso de la seguridad:** Incidente de seguridad en el que, debido a una violación de las medidas técnicas u organizativas de seguridad, una información o un servicio quedan expuestos, o potencialmente expuestos, a un acceso no autorizado.
- **Confidencialidad:** Propiedad o característica consistente en que la información ni se pone a disposición, ni se revela a individuos, entidades o procesos no autorizados.
- **Contraseña:** Un secreto memorizado por el usuario, compuesto por varios caracteres según unas reglas de complejidad frente a ataques de adivinación o fuerza bruta.
- **Criterios Comunes (Criterios Comunes (CC) para la Evaluación de la Seguridad de las Tecnologías de la Información):** estándar internacional que junto con la Metodología Común de Evaluación (CEM) permite que laboratorios acreditados evalúen las propiedades de seguridad de los productos hasta un cierto nivel de aseguramiento. Los Criterios Comunes son la base del Arreglo de Reconocimiento Mutuo (CCRA).
- **Disponibilidad:** Propiedad o característica de los activos consistente en que las entidades o procesos autorizados tienen acceso a los mismos cuando lo requieren.
- **Distintivo de Certificación de Conformidad con el ENS:** Documento electrónico, en formato PDF-A, firmado electrónicamente por la Entidad de Certificación responsable de la evaluación de los sistemas de información concernidos, incluyendo un enlace a la Certificación de Conformidad con el ENS que, mientras se mantenga su vigencia, permanecerá accesible a través de la sede electrónica o página web de la entidad pública o privada, respectivamente, de que se trate.
- **Distintivo de Declaración de Conformidad con el ENS:** Documento electrónico, en formato PDF-A, firmado o sellado electrónicamente por la entidad bajo cuya responsabilidad se encuentre el sistema de información en cuestión, incluyendo un enlace a la Declaración de Conformidad con el ENS que, mientras se mantenga su vigencia, permanecerá accesible a través de la sede electrónica o página web de la entidad pública o privada de que se trate.
- **Dominio de seguridad:** Colección de activos uniformemente protegidos, típicamente bajo una única autoridad. Los dominios de seguridad se utilizan para diferenciar entre zonas en el sistema de información. Por ejemplo:
 - a) Instalaciones centrales, sucursales, comerciales trabajando con portátiles.
 - b) Servidor central (host), frontal Unix y equipos administrativos.
 - c) Seguridad física, seguridad lógica.
- **Evento de seguridad:** Ocurrencia identificada de un sistema, servicio o estado de red que indica un posible incumplimiento de la política de seguridad de la información, una falla de los controles o una situación desconocida que puede ser relevante para la seguridad.
- **Gestión de incidentes:** Procedimientos seguidos para detectar, analizar y limitar un incidente y responder ante éste.
- **Gestión de riesgos:** Actividades coordinadas para dirigir y controlar a una organización con respecto a los riesgos.
- **Incidente de seguridad (ciberincidente o incidente):** Suceso inesperado o no deseado con consecuencias en detrimento de la seguridad de las redes y sistemas de información.
- **Infraestructuras críticas:** las infraestructuras estratégicas cuyo funcionamiento es indispensable y no permite soluciones alternativas, por lo que su perturbación o destrucción tendría un grave impacto sobre los servicios esenciales.

- **Integridad:** Propiedad o característica consistente en que el activo de información no ha sido alterado de manera no autorizada.
- **Lista de componentes software:** Documento que detalla los componentes software utilizados para construir algo, sea una aplicación o un servicio.
- **Medidas de seguridad:** Conjunto de disposiciones encaminadas a proteger al sistema de información de los riesgos a los que estuviere sometido, con el fin de asegurar sus objetivos de seguridad. Puede tratarse de medidas de prevención, de disuasión, de protección, de detección y reacción, o de recuperación.
- **Mínimo privilegio:** Principio que determina que el diseño de la arquitectura de seguridad de un sistema garantiza el uso de los servicios y permisos mínimos necesarios para su correcto funcionamiento.
- **Monitorización continua:** Proceso de gestión dinámica de la seguridad basado en el seguimiento de indicadores críticos de seguridad y parcheo de las vulnerabilidades descubiertas en los componentes del sistema de información.
- **Observatorio Digital:** Un observatorio digital, en su propósito de conocer realidades de la información que se transmite a través de medios digitales, es un conjunto de capacidades para la toma de decisiones dedicado a la detección y seguimiento de anomalías en el origen, definición o diseminación de contenidos digitales, las cuales pudieran representar indicadores de amenaza.
- **Operadores críticos:** las entidades u organismos responsables de las inversiones o del funcionamiento diario de una instalación, red, sistema, o equipo físico o de tecnología de la información designada como infraestructura crítica con arreglo a la Ley 8/2011, de 28 de abril.
- **Operador de servicios esenciales:** entidad pública o privada que se identifique considerando los factores establecidos en el artículo 6 de este real decreto-ley, que preste dichos servicios en alguno de los sectores estratégicos definidos en el anexo de la Ley 8/2011, de 28 de abril.
- **Perfil de cumplimiento específico:** Conjunto de medidas de seguridad, comprendidas o no en el anexo II de este real decreto, que, como consecuencia del preceptivo análisis de riesgos, resulten de aplicación a una entidad o sector de actividad concreta y para una determinada categoría de seguridad, y que haya sido habilitado por el CCN.
- **Política de seguridad (Política de seguridad de la información):** Conjunto de directrices plasmadas en un documento, que rigen la forma en que una organización gestiona y protege la información que trata y los servicios que presta.
- **Principios básicos de seguridad:** Fundamentos que deben regir toda acción orientada a asegurar la información y los servicios.
- **Proceso:** Conjunto organizado de actividades que se llevan a cabo para producir un producto o prestar un servicio, que tiene un principio y fin delimitados, que implica recursos y da lugar a un resultado.
- **Proceso de seguridad:** Método que se sigue para alcanzar los objetivos de seguridad de la organización. El proceso se diseña para identificar, medir, gestionar y mantener bajo control los riesgos a que se enfrenta el sistema en materia de seguridad.
- **Proceso TIC:** Conjunto de actividades llevadas a cabo para la concepción, elaboración, suministro y mantenimiento de un producto o servicio TIC.
- **Producto TIC:** Elemento o grupo de elementos de las redes o los sistemas de información.
- **Protección de infraestructuras críticas:** el conjunto de actividades destinadas a asegurar la funcionalidad, continuidad e integridad de las infraestructuras críticas con el fin de prevenir, paliar y neutralizar el daño causado por un ataque deliberado contra dichas infraestructuras y a garantizar la integración de estas actuaciones con las demás que procedan de otros sujetos responsables dentro del ámbito de su respectiva competencia
- **Proveedor de servicios digitales:** persona jurídica que presta un servicio digital.
- **Redes y sistemas de información, cualquiera de los elementos siguientes:**

1º Las redes de comunicaciones electrónicas, tal y como vienen definidas en el número 31 del anexo II de la Ley 9/2014, de 9 de mayo, General de Telecomunicaciones;

2º Todo dispositivo o grupo de dispositivos interconectados o relacionados entre sí, en el que uno o varios de ellos realicen, mediante un programa, el tratamiento automático de datos digitales;

3º Los datos digitales almacenados, tratados, recuperados o transmitidos mediante los elementos contemplados en los números 1º y 2º anteriores, incluidos los necesarios para el funcionamiento, utilización, protección y mantenimiento de dichos elementos.

- **Requisitos mínimos de seguridad:** Exigencias mínimas necesarias para asegurar la información tratada y los servicios prestados.
- **Riesgo:** Estimación del grado de exposición a que una amenaza se materialice sobre uno o más activos causando daños o perjuicios a la organización.
- **Sector estratégico:** cada una de las áreas diferenciadas dentro de la actividad laboral, económica y productiva, que proporciona un servicio esencial o que garantiza el ejercicio de la autoridad del Estado o de la seguridad del país.
- **Seguridad de las redes y sistemas de información:** la capacidad de las redes y sistemas de información de resistir, con un nivel determinado de fiabilidad, toda acción que comprometa la disponibilidad, autenticidad, integridad o confidencialidad de los datos almacenados, transmitidos o tratados, o los servicios correspondientes ofrecidos por tales redes y sistemas de información o accesibles a través de ellos.
- **Servicio digital:** servicio de la sociedad de la información entendido en el sentido recogido en la letra a) del anexo de la Ley 34/2002, de 11 de julio, de servicios de la sociedad de la información y de comercio electrónico.
- **Servicio esencial:** servicio necesario para el mantenimiento de las funciones sociales básicas, la salud, la seguridad, el bienestar social y económico de los ciudadanos, o el eficaz funcionamiento de las Instituciones del Estado y las Administraciones Públicas, que dependa para su provisión de redes y sistemas de información.
- **Sistema de información:** Cualquiera de los elementos siguientes:
 - 1º Las redes de comunicaciones electrónicas que utilice la entidad del ámbito de aplicación de este real decreto sobre las que posea capacidad de gestión.
 - 2º Todo dispositivo o grupo de dispositivos interconectados o relacionados entre sí, en el que uno o varios de ellos realicen, mediante un programa, el tratamiento automático de datos digitales.
 - 3º Los datos digitales almacenados, tratados, recuperados o transmitidos mediante los elementos contemplados en los números 1º y 2º anteriores, incluidos los necesarios para el funcionamiento, utilización, protección y mantenimiento de dichos elementos.
- **SOG-IS MRA:** acuerdo que se produjo en respuesta a la Decisión del Consejo de la UE del 31 de marzo de 1992 (92/242/EEC) en el campo de la seguridad de los sistemas de información, y la posterior recomendación del Consejo del 7 de abril (1995/144/EC) sobre la seguridad común de la tecnología de la información. criterios de evaluación. El acuerdo se actualizó en enero de 2010. Los participantes en este Acuerdo son organizaciones o agencias gubernamentales de países de la Unión Europea o EFTA (Asociación Europea de Libre Comercio), en representación de su país o países.
- **Trazabilidad:** Propiedad o característica consistente en que las actuaciones de una entidad (persona o proceso) pueden ser trazadas de forma indiscutible hasta dicha entidad.
- **USO OFICIAL:** Designa información con algún tipo de restricción en su manejo por su sensibilidad y confidencialidad.
- **Usuarios de la organización:** Personal del organismo, propio o contratado, estable o circunstancial, que acceden al sistema para desarrollar las funciones o actividades que les han sido encomendadas por la organización.
- **Usuarios externos:** Usuarios con acceso al sistema que no entran en el conjunto de usuarios de la organización. En particular, los ciudadanos administrados.

8. TEST

8.1. Preguntas de test

- 1)Cuál de las siguientes NO es obligación de un Operador Crítico:
 - a)Elaborar el Plan Estratégico Sectorial.
 - b)Elaborar el Plan de Seguridad del Operador.
 - c)Elaborar el Plan de Protección Específico.
 - d)Designar un Responsable de Seguridad y Enlace.

- 2)En relación con las medidas de seguridad recogidas en el anexo II del ENS es VERDAD que:
 - a)Se determinan a criterio del auditor del sistema.
 - b)Se determinan a criterio del responsable del sistema.
 - c)Se determinan en función de la dimensión de seguridad y categoría del sistema.
 - d)Se determinan según las medidas establecidas en la norma ISO/IEC 27001.

- 3)Tras un incidente de seguridad en una entidad del Sector Público:
 - a)El INCIBE-CERT determinará técnicamente el riesgo de reconexión del sistema o sistemas afectados.
 - b)El CCN-CERT determinará técnicamente el riesgo de reconexión del sistema o sistemas afectados.
 - c)La Oficina de Coordinación de Ciberseguridad determinará técnicamente el riesgo de reconexión del sistema o sistemas afectados.
 - d)La Secretaría General de Administración Digital determinará técnicamente el riesgo de reconexión del sistema o sistemas afectados.

- 4)La categoría de un sistema en el ENS viene dada por:
 - a)La decisión del órgano superior correspondiente.
 - b)El tipo de datos de carácter personal manejados.
 - c)El tipo de información clasificada manejada.
 - d)Las posibles repercusiones en las dimensiones de seguridad.

- 5)En relación con la auditoría de la seguridad, el ENS contempla la obligación de:
 - a)Realizar auditorías cuando se produce la declaración de la categoría de los sistemas.
 - b)Realizar auditorías cada dos años a todos los sistemas con independencia de su categoría, que verifique el cumplimiento de los requisitos del Esquema.
 - c)Realizar auditorías cada dos años a los sistemas de categoría MEDIA o ALTA, que verifique el cumplimiento de los requisitos del Esquema.
 - d)Realizar auditorías anualmente a los sistemas de categoría MEDIA o ALTA, que verifique el cumplimiento de los requisitos del Esquema.

- 6)En relación con las infraestructuras comunes y la seguridad es VERDAD que:
 - a)Reducen el perímetro físico y lógico.
 - b)Reducen el perímetro físico, pero aumentan el perímetro lógico.
 - c)Aumentan el perímetro físico y lógico.
 - d)Reducen el perímetro lógico, pero aumentan el perímetro físico.

- 7)El Consejo Nacional de Ciberseguridad es:

- a) Una comisión delegada del Gobierno.
 - b) Un órgano colegiado adscrito a la Secretaría de Estado de Seguridad.
 - c) Un órgano que asegura la coordinación técnica entre el Ministerio del Interior y sus organismos dependientes.
 - d) Un comité especializado que da apoyo al Consejo de Seguridad Nacional en el ámbito de la ciberseguridad.
- 8) La identificación de los servicios esenciales y de los operadores que los presten corresponde a:
- a) El Consejo Nacional de Ciberseguridad.
 - b) La Comisión Nacional PIC.
 - c) El Centro Nacional para la Protección de Infraestructuras Críticas.
 - d) La Oficina de Coordinación de Ciberseguridad.
- 9) En el ENS, para indicar una mayor exigencia se emplean:
- a) Los requisitos codificados de seguridad.
 - b) Los niveles de las dimensiones de seguridad.
 - c) Los refuerzos de seguridad.
 - d) Las categorías de seguridad.
- 10) Sobre la relación entre el ENS y la norma ISO/IEC 27001 es FALSO que:
- a) Es posible aplicar la 27001 y su certificación como soporte de cumplimiento del ENS.
 - b) Una certificación 27001 satisface la conformidad con el ENS.
 - c) La norma 27001 proporciona los requisitos para la construcción de un sistema de gestión de seguridad de la información.
 - d) El alcance de la certificación 27001 debe cubrir lo exigido por el ENS.

8.2. Soluciones a las preguntas de test

PREGUNTA	SOLUCIÓN
----------	----------

1	a
2	c
3	b
4	d
5	c
6	a
7	d
8	b
9	c
10	b

9. BIBLIOGRAFÍA

9.1. Bibliografía básica

1. [BOE-A-2015-10389](#). Ley 36/2015, de 28 de septiembre, de Seguridad Nacional
2. <https://www.boe.es/eli/es/rd/2021/12/28/1150>. Estrategia de Seguridad Nacional 2021
3. [BOE-A-2017-15181](#). Estrategia de Seguridad Nacional 2017
4. [BOE-A-2019-6347](#). Estrategia Nacional de Ciberseguridad 2019
5. <https://www.dsn.gob.es/es/estrategias-publicaciones/estrategias/estrategia-ciberseguridad-nacional>. Estrategia de Ciberseguridad Nacional de 2013
6. [BOE-A-2011-7630](#). Ley 8/2011, de 28 de abril, por la que se establecen medidas para la protección de las infraestructuras críticas
7. [BOE-A-2011-8849](#). Real Decreto 704/2011, de 20 de mayo, por el que se aprueba el Reglamento de protección de las infraestructuras críticas
8. [BOE-A-2018-12257](#). Real Decreto-ley 12/2018, de 7 de septiembre, de seguridad de las redes y sistemas de información
9. [BOE-A-2010-1330](#). Real Decreto 3/2010, de 8 de enero, por el que se regula el Esquema Nacional de Seguridad en el ámbito de la Administración Electrónica.
10. [BOE-A-2016-10108](#). Resolución de 7 de octubre de 2016, de la Secretaría de Estado de Administraciones Públicas, por la que se aprueba la Instrucción Técnica de Seguridad de Informe del Estado de la Seguridad
11. [BOE-A-2018-5370](#). Resolución de 13 de abril de 2018, de la Secretaría de Estado de Función Pública, por la que se aprueba la Instrucción Técnica de Seguridad de Notificación de Incidentes de Seguridad
12. [BOE-A-2018-4573](#). Resolución de 27 de marzo de 2018, de la Secretaría de Estado de Función Pública, por la que se aprueba la Instrucción Técnica de Seguridad de Auditoría de la Seguridad de los Sistemas de Información
13. [BOE-A-2016-10109](#). Resolución de 13 de octubre de 2016, de la Secretaría de Estado de Administraciones Públicas, por la que se aprueba la Instrucción Técnica de Seguridad de conformidad con el Esquema Nacional de Seguridad

9.2. Bibliografía complementaria

14. <https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=CELEX%3A32016L1148>. Directiva (UE) 2016/1148 del Parlamento Europeo y del Consejo, de 6 de julio de 2016, relativa a las medidas destinadas a garantizar un elevado nivel común de seguridad de las redes y sistemas de información en la Unión
15. <http://www.oecd.org/governance/digital-security-risk-management-for-economic-and-social-prosperity-9789264245471-en.htm>. OCDE. Digital Security Risk Management for Economic and Social Prosperity - OECD Recommendation and Companion Document.
16. <https://administracionelectronica.gob.es/pae/Home/pae/Documentacion/pae/Metodolog/pae/Magerit.html>. Metodología de análisis y gestión de riesgos de los sistemas de información, Magerit v3
17. <https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/guias-de-acceso-publico-ccn-stic/1579-ccn-stic-001-informacion-clasificada-en-la-administracion/file.html>. CCN-STIC 001 Información clasificada en la Administración
18. [DOCUMENTO 5 - Normas de la Autoridad.pdf \(uma.es\)](#) Normas de la Autoridad Nacional para la Protección de la Información Clasificada
19. <https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/guias-de-acceso-publico-ccn-stic/2536-ccn-stic-105-catalogo-de-productos-de-seguridad-de-las-tecnologias-de-la-informacion-y-la>

- [comunicacion/file.html](#). CCN-STIC 105 Catálogo de Productos de Seguridad de las Tecnologías de la Información y la Comunicación
20. <https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/guias-de-acceso-publico-ccn-stic/5765-ccn-stic-122-procedimiento-de-reconocimiento-de-entidades-de-certificacion-del-ens-del-sector-publico-y-requisitos-del-organ-de-auditoria-tecnica.html>. CCN-STIC 122 Procedimiento de Reconocimiento y Requisitos del Órgano de Auditoría Técnica del ENS
 21. <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/499-ccn-stic-800-glosario-de-terminos-y-abreviaturas-del-ens/file.html>. Guía CCN-STIC 800 Glosario de términos y abreviaturas del ENS
 22. <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/501-ccn-stic-801-responsabilidades-y-funciones-en-el-ens/file.html>. CCN-STIC 801 Responsabilidades y Funciones en el ENS
 23. <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/502-ccn-stic-802-auditoria-del-ens/file.html>. CCN-STIC 802 Guía de auditoría
 24. <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/682-ccn-stic-803-valoracion-de-sistemas-en-el-ens-1/file.html>. CCN-STIC 803 Valoración de Sistemas en el ENS
 25. [https://www.ccn-cert.cni.es/documentos-publicos/x-jornadas-stic-ccn-cert/1954-como-categorizar-un-sistema-en-el-ens/file.html#:~:text=cabe%20recordar%20que%3A-a\)%20Un%20sistema%20de%20informaci%C3%B3n%20ser%C3%A1%20de%20categor%C3%ADa%20ALTA%20si,ninguna%20alcanza%20un%20nivel%20superior](https://www.ccn-cert.cni.es/documentos-publicos/x-jornadas-stic-ccn-cert/1954-como-categorizar-un-sistema-en-el-ens/file.html#:~:text=cabe%20recordar%20que%3A-a)%20Un%20sistema%20de%20informaci%C3%B3n%20ser%C3%A1%20de%20categor%C3%ADa%20ALTA%20si,ninguna%20alcanza%20un%20nivel%20superior). Como categorizar un Sistema en el ENS
 26. <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/505-ccn-stic-804-medidas-de-implantacion-del-ens/file.html>. CCN-STIC 804 Guía de Implantación
 27. <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/511-ccn-stic-806-plan-de-adequacion-al-ens/file.html> CCN-STIC 806 Plan de adecuación al ENS.
 28. <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/518-ccn-stic-808-verificacion-del-cumplimiento-de-las-medidas-en-el-ens-borrador/file.html>. CCN-STIC 808 Verificación del cumplimiento de las medidas en el ENS
 29. <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/988-ccn-stic-817-gestion-de-ciberincidentes/file.html>. CCN-STIC 817 Gestión de Ciberincidentes proporciona a los Responsables de Seguridad
 30. <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/542-ccn-stic-824-informaci%C3%B3n-del-estado-de-seguridad/file.html>. CCN-STIC 824 Informe del Estado de Seguridad
 31. <https://www.ccn-cert.cni.es/series-ccn-stic/800-guia-esquema-nacional-de-seguridad/543-ccn-stic-825-ens-iso27001/file.html>. CCN-STIC-825 Esquema Nacional de Seguridad. Certificaciones 27001
 32. <https://www.ccn-cert.cni.es/pdf/guias/series-ccn-stic/guias-de-acceso-publico-ccn-stic/1674-ccn-stic-830-ambito-aplicacion-ens/file.html>. CCN-STIC-830 Ámbito de aplicación del Esquema Nacional de Seguridad
 33. <http://www.interior.gob.es/documents/10180/9814700/Gu%C3%ADa+Nacional+de+notificaci%C3%B3n+y+gesti%C3%B3n+de+ciberincidentes/f01d9ed6-2e14-4fb0-b585-9b0df20f2906>. Guía Nacional de Notificación y Gestión de Ciberincidentes

9.3. Bibliografía para ampliar

34. <http://www.boe.es/legislacion/codigos/codigo.php?id=029> Código de Administración Electrónica
35. <http://administracionelectronica.gob.es>. Portal de la Administración Electrónica
36. <https://www.ccn-cert.cni.es>. Portal CCN-CERT, Esquema Nacional de Seguridad.

37. http://www.hacienda.gob.es/Documentacion/Publico/SGT/CATALOGO_SEFP/014_MinHFP_diccionario_AE.pdf. Diccionario de términos y conceptos de la Administración Electrónica